



SQL control audit evidence report

Target: No database evidence supplied

Benchmark: SQLIQ sql-2022-stigs / 1; 1

SHA-256: 2d8022eededf6312eb2eef77cab660c12d9515b24c1d848b794a864b50bd9d94

Coverage: all 102 selected register entries included.

Assessment coverage: Full selected catalogs; no baseline or applicability filtering

Provenance: Pinned publisher sources, source integrity checked by CLI

PASS: 0 | FAIL: 0 | NOT_APPLICABLE: 0 | NOT_ASSESSED: 102

Offline evidence review. No database connection or automated checks performed. Results are operator assertions, not independently verified audit conclusions. Missing evidence is NOT_ASSESSED. Verify official benchmark origin, product applicability, evidence freshness and reviewer authority. No overall pass issued.

Framework boundaries

DISA publishes SQL STIG benchmarks. NIST SP 800-52 Rev. 2 addresses TLS; this report does not claim full NIST or financial framework assessment. TLS review remains NOT_ASSESSED: protocols, negotiation, cipher suites, certificates, validation and cryptographic modules require separate evidence.

NIST source: <https://csrc.nist.gov/pubs/sp/800/52/r2/final>

Azure inheritance remains UNDETERMINED per rule. Provider responsibility does not establish a pass. Obtain service-specific assurance and customer configuration evidence. Finance owners must approve applicable obligations.

Microsoft source: <https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility>

Recommendations are proposals. Validate fixes in staging with recovery plans. Live reads and writes each require exact externally signed approval.



SV-271118r1107970_rule

SQL Server must integrate with an organization-level authentication/access mechanism providing account management and automation for all users, groups, roles, and any other principals.

Rule version

SQLD-22-000100

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Enterprise environments make account management for applications and databases challenging and complex. A manual process for account management functions adds the risk of a potential oversight or other error. Managing accounts for the same person in multiple places is inefficient and prone to problems with consistency and synchronization.

A comprehensive application account management process that includes automation helps to ensure that accounts designated as requiring attention are consistently and promptly addressed.

Examples include using automation to act on multiple accounts designated as inactive, suspended, or terminated, or by disabling accounts located in noncentralized account stores, such as multiple servers. Account management functions can also include assignment of group or role membership; identifying account type; specifying user access authorizations (i.e., privileges); account removal, update, or termination; and administrative alerts. Using automated mechanisms can include, for example: using email or text messaging to notify account managers when users are terminated or transferred; using the information system to monitor account usage; and using automated telephone notification to report atypical system account usage.

SQL Server must be configured to automatically use organization-level account management functions, and these functions must immediately enforce the organization's current account policy.

Automation may comprise differing technologies that when placed together contain an overall mechanism supporting an organization's automated account management requirements.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000015; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions



Determine if SQL Server is configured to allow the use of contained databases, if it is, take the appropriate precautions to limit their risk.

1. In the Object Explorer in SQL Server Management Studio (SSMS), right-click on the server instance, select "Properties", and then select the "Advanced" page.

If "Enabled Contained Databases" is "False", this is not a finding.

2. If "Enabled Contained Databases" is "True", then in a query interface such as the SSMS Transact-SQL editor, run the statement:

```
EXEC sp_configure 'contained database authentication'
```

If the returned value in the "config_value" or "run_value" column is "0", this is not a finding.

3. Determine whether SQL Server is configured to use only Windows authentication. In a query interface such as the SSMS Transact-SQL editor, run the statement:

```
SELECT CASE SERVERPROPERTY('IsIntegratedSecurityOnly')
WHEN 1 THEN 'Windows Authentication'
WHEN 0 THEN 'Windows and SQL Server Authentication'
END as [Authentication Mode]
```

If the returned value in the "Authentication Mode" column is "Windows Authentication", this is not a finding.

If mixed mode (both SQL Server authentication and Windows authentication) is in use, then it must be documented and approved.

From the documentation, obtain the list of accounts authorized to be managed by SQL Server. Determine the accounts (SQL Logins) actually managed by SQL Server.

Run the statement:

```
SELECT name
FROM sys.database_principals
WHERE type_desc = 'SQL_USER'
AND authentication_type_desc = 'DATABASE';
```

If any accounts listed by the query are not listed in the documentation, this is a finding.

Documentation must be approved by the information system security officer (ISSO)/information system security manager (ISSM). Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer



Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

If mixed mode is required, document the need and justification; describe the measures taken to ensure the use of SQL Server authentication is kept to a minimum; describe the measures taken to safeguard passwords; list or describe the SQL Logins used; and obtain official approval.

If mixed mode is not required, disable it as follows:

In the SSMS Object Explorer, right-click on the server instance, select Properties >> Security page. Click the radio button for "Windows Authentication Mode", and then click "OK".

Restart the SQL Server instance.

OR

Run the statement:

```
USE [master]
EXEC xp_instance_regwrite N'HKEY_LOCAL_MACHINE', N'Software\Microsoft\MSSQLServer\MSSQLServer',
N'LoginMode', REG_DWORD, 2
GO
```

Restart the SQL Server instance.

For each account being managed by SQL Server but not requiring it, drop or disable the SQL Database user. Replace it with an appropriately configured account, as needed.

To drop a User in the SSMS Object Explorer:

Navigate to Databases >> Security Users. Right-click on the username and then click "Delete".

To drop a User via a query:

```
USE database_name;
DROP USER <user_name>;
```

Source benchmark

MS_SQL_Server_2022_Database_STIG



Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271119r1137654_rule

SQL Server must enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

Rule version

SQLD-22-000300

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Authentication with a DOD-approved PKI certificate does not necessarily imply authorization to access the DBMS. To mitigate the risk of unauthorized access to sensitive information by entities that have been issued certificates by DOD-approved PKIs, all DOD systems, including databases, must be properly configured to implement access control policies.

Successful authentication must not automatically give an entity access to an asset or security boundary. Authorization procedures and controls must be implemented to ensure each authenticated entity also has a validated and current authorization. Authorization is the process of determining whether an entity, once authenticated, is permitted to access a specific asset. Information systems use access control policies and enforcement mechanisms to implement this requirement.

Access control policies include identity-based policies, role-based policies, and attribute-based policies. Access enforcement mechanisms include access control lists, access control matrices, and cryptography. These policies and mechanisms must be employed by the application to control access between users (or processes acting on behalf of users) and objects (e.g., devices, files, records, processes, programs, and domains) in the information system.

This requirement is applicable to access control enforcement applications, a category that includes database management systems. If SQL Server does not follow applicable policy when approving access, it may be in conflict with networks or other applications in the information system. This may result in users either gaining or being denied access inappropriately and in conflict with applicable policy.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000213; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

If the database is tempdb, this is Not Applicable.



Check SQL Server settings to determine whether users are restricted from accessing objects and data they are not authorized to access.

Review the system documentation to determine the required levels of protection for securables in the database by type of user.

Review the permissions in place in the database.

If the permissions do not match the documented requirements, this is a finding.

Use the supplemental file "Database permission assignments to users and roles.sql". Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure SQL Server settings and access controls to permit user access only to objects and data that the user is authorized to view or interact with, and to prevent access to all other objects and data.

Use GRANT, REVOKE, DENY, ALTER ROLE ... ADD MEMBER ... and/or ALTER ROLE DROP MEMBER statements to add and remove permissions on database-level securables, bringing them into line with the documented requirements.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271121r1109177_rule

SQL Server must protect against a user falsely repudiating by using system-versioned tables (Temporal Tables).

Rule version

SQLD-22-000500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Nonrepudiation of actions taken is required to maintain data integrity. Examples of particular actions taken by individuals include creating information, sending a message, approving information (e.g., indicating concurrence or signing a contract), and receiving a message.

Nonrepudiation protects against later claims by a user of not having created, modified, or deleted a particular data item or collection of data in the database.

In designing a database, the organization must define the types of data and the user actions that must be protected from repudiation. The implementation must then include building audit features into the application data tables and configuring SQL servers' audit tools to capture the necessary audit trail. Design and implementation also must ensure that applications pass individual user identification to SQL Server, even where the application connects to the DBMS with a standard, shared account.

Applications should use temporal tables to track the changes and history of sensitive data.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000166; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Check the server documentation to determine if collecting and keeping historical versions of a table is required.

If collecting and keeping historical versions of a table is NOT required, this is not a finding.

Find all of the temporal tables in the database using the following query:

```
SELECT SCHEMA_NAME(T.schema_id) AS schema_name, T.name AS table_name, T.temporal_type_desc,
SCHEMA_NAME(H.schema_id) + '.' + H.name AS history_table
FROM sys.tables T
```



```
JOIN sys.tables H ON T.history_table_id = H.object_id
WHERE T.temporal_type != 0
ORDER BY schema_name, table_name
```

Using the system documentation, determine which tables are required to be temporal tables.

If any tables listed in the documentation are not in the list created by running the above statement, this is a finding.

Verify that a field exists documenting the login and/or user who last modified the record. If this does not exist, this is a finding.

Review the system documentation to determine the history retention period.

Navigate to the table in Object Explorer. Right-click on the table and then select Script Table As >> CREATE To >> New Query Editor Window.

Locate the line that contains "SYSTEM_VERSIONING".

Locate the text that states "HISTORY_RETENTION_PERIOD".

If this text is missing or is set to a value less than the documented history retention period, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Alter sensitive tables to use system versioning.

```
--Alter non-temporal table to define periods for system versioning
ALTER TABLE <MyTableName>
ADD PERIOD FOR SYSTEM_TIME (SysStartTime, SysEndTime),
```



```
SysStartTime datetime2 GENERATED ALWAYS AS ROW START HIDDEN NOT NULL  
DEFAULT SYSUTCDATETIME(),  
SysEndTime datetime2 GENERATED ALWAYS AS ROW END HIDDEN NOT NULL  
DEFAULT CONVERT(DATETIME2, '9999-12-31 23:59:59.99999999') ;
```

--Enable system versioning with 1 year retention for historical data

```
ALTER TABLE <MyTableName>
```

```
SET (SYSTEM_VERSIONING = ON (HISTORY_RETENTION_PERIOD = 1 YEAR)) ;
```

https://docs.microsoft.com/sql/t-sql/statements/alter-table-transact-sql?view=sql-server-2022#system_versionin

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271122r1109180_rule

SQL Server must protect against a user falsely repudiating by ensuring databases are not in a trust relationship.

Rule version

SQLD-22-000600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Nonrepudiation of actions taken is required to maintain data integrity. Examples of particular actions taken by individuals include creating information, sending a message, approving information (e.g., indicating concurrence or signing a contract), and receiving a message.

Nonrepudiation protects against later claims by a user of not having created, modified, or deleted a particular data item or collection of data in the database.

In designing a database, the organization must define the types of data and the user actions that must be protected from repudiation. The implementation must then include building audit features into the application data tables and configuring the DBMS's audit tools to capture the necessary audit trail. Design and implementation also must ensure that applications pass individual user identification to the DBMS, even where the application connects to the DBMS with a standard, shared account.

SQL Server provides the ability for high privileged accounts to impersonate users in a database using the TRUSTWORTHY feature. This will allow members of the fixed database role to impersonate any user within the database.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000166; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

If the database being reviewed is MSDB, trustworthy is required to be enabled, and therefore this is not a finding.

Execute the following query:

```
SELECT  
[DatabaseName] = d.name  
,[DatabaseOwner] = login.name
```



```
,[IsTrustworthy] = CASE
WHEN d.is_trustworthy_on = 0 THEN 'No'
WHEN d.is_trustworthy_on = 1 THEN 'Yes'
END
,[IsOwnerPrivilege] = CASE
WHEN role.name IN ('sysadmin','securityadmin')
OR permission.permission_name = 'CONTROL SERVER'
THEN 'YES'
ELSE 'No'
END
FROM sys.databases d
LEFT JOIN sys.server_principals login ON d.owner_sid = login.sid
LEFT JOIN sys.server_role_members rm ON login.principal_id = rm.member_principal_id
LEFT JOIN sys.server_principals role ON rm.role_principal_id = role.principal_id
LEFT JOIN sys.server_permissions permission ON login.principal_id = permission.grantee_principal_id
WHERE d.name <> 'msdb'
```

If trustworthy is not enabled, this is not a finding.

If trustworthy is enabled and the database owner is not a privileged account, this is not a finding.

If trustworthy is enabled and the database owner is a privileged account, review the system documentation to determine if the trustworthy property is required and authorized. If this is not documented, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable trustworthy on the database.

```
ALTER DATABASE [<database name>] SET TRUSTWORTHY OFF;
```



Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271124r1109215_rule

SQL Server must allow only the information system security manager (ISSM) (or individuals or roles appointed by the ISSM) to select which auditable events are to be audited.

Rule version

SQLD-22-000700

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Without the capability to restrict which roles and individuals can select which events are audited, unauthorized personnel may be able to prevent or interfere with the auditing of critical events.

Suppression of auditing could permit an adversary to evade detection.

Misconfigured audits can degrade the system's performance by overwhelming the audit log. Misconfigured audits may also make it more difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000171; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Obtain the list of approved audit maintainers from the system documentation.

Use the following query to review database roles and their membership, all of which enable the ability to create and maintain audit specifications.

```
SELECT
R.name AS role_name,
RM.name AS role_member_name,
RM.type_desc
FROM sys.database_principals R
JOIN sys.database_role_members DRM ON
R.principal_id = DRM.role_principal_id
JOIN sys.database_principals RM ON
DRM.member_principal_id = RM.principal_id
```



```
WHERE R.type = 'R'
AND R.name = 'db_owner'
ORDER BY
role_member_name
```

If any role memberships are not documented and authorized, this is a finding.

Review the database roles and individual users that have the following permissions, all of which enable the ability to create and maintain audit definitions.

```
ALTER ANY DATABASE AUDIT
CONTROL
```

Use the following query to determine the roles and users that have the listed permissions:

```
SELECT
PERM.permission_name,
DP.name AS principal_name,
DP.type_desc AS principal_type,
DBRM.role_member_name
FROM sys.database_permissions PERM
JOIN sys.database_principals DP ON PERM.grantee_principal_id = DP.principal_id
LEFT OUTER JOIN (
SELECT
R.principal_id AS role_principal_id,
R.name AS role_name,
RM.name AS role_member_name
FROM sys.database_principals R
JOIN sys.database_role_members DRM ON R.principal_id = DRM.role_principal_id
JOIN sys.database_principals RM ON DRM.member_principal_id = RM.principal_id
WHERE R.type = 'R'
) DBRM ON DP.principal_id = DBRM.role_principal_id
WHERE PERM.permission_name IN ('CONTROL','ALTER ANY DATABASE AUDIT')
ORDER BY
permission_name,
principal_name,
role_member_name
```

If any of the roles or users returned have permissions that are not documented, or the documented audit maintainers do not have permissions, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned



Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Create a database role specifically for audit maintainers, and give it permission to maintain audits without granting it unnecessary permissions. (The role name used below is an example; other names may be used.)

```
CREATE ROLE DATABASE_AUDIT_MAINTAINERS;  
GO
```

```
GRANT ALTER ANY DATABASE AUDIT TO DATABASE_AUDIT_MAINTAINERS;  
GO
```

Use REVOKE and/or DENY and/or ALTER ROLE ... DROP MEMBER ... statements to remove the ALTER ANY DATABASE AUDIT permission from all users. Then, for each authorized database user, run the statement:

```
ALTER ROLE DATABASE_AUDIT_MAINTAINERS ADD MEMBER;  
GO
```

Use REVOKE and/or DENY and/or ALTER SERVER ROLE ... DROP MEMBER ... statements to remove CONTROL DATABASE permission from logins that do not need it.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271143r1167490_rule

SQL Server must limit privileges to change software modules, to include stored procedures, functions, and triggers, and links to software external to SQL Server.

Rule version

SQLD-22-001200

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If the system were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process.

Accordingly, only qualified and authorized individuals must be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Unmanaged changes that occur to the database software libraries or configuration can lead to unauthorized or compromised installations.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-001499; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Obtain a listing of schema ownership from the server documentation.

Execute the following query to obtain a current listing of schema ownership.

```
SELECT s.name AS schema_name, p.name AS owning_principal
FROM sys.schemas s
JOIN sys.database_principals p ON s.principal_id = p.principal_id
WHERE p.name != 'dbo'
AND (s.name != p.name
or p.name not in
( 'db_accessadmin'
, 'db_backupoperator'
, 'db_datareader'
```



```
, 'db_datawriter'  
, 'db_ddladmin'  
, 'db_denydatareader'  
, 'db_denydatawriter'  
, 'db_owner'  
, 'db_securityadmin'  
, 'guest'  
, 'INFORMATION_SCHEMA'  
, 'sys'  
, 'TargetServersRole'  
, 'SQLAgentUserRole'  
, 'SQLAgentReaderRole'  
, 'SQLAgentOperatorRole'  
, 'DatabaseMailUserRole'  
, 'db_ssisadmin'  
, 'db_ssisltduser'  
, 'db_ssisoperator'  
, 'replmonitor'  
, '##MS_SSISServerCleanupJobLogin##'  
)  
)  
ORDER BY schema_name
```

If any schema is owned by an unauthorized database principal, this is a finding. Check reference:
MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Transfer ownership of database schemas to authorized database principals.



ALTER AUTHORIZATION ON SCHEMA::[<Schema Name>] TO [<Principal Name>]

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271146r1109183_rule

Database objects (including but not limited to tables, indexes, storage, stored procedures, functions, triggers, links to software external to SQL Server, etc.) must be owned by database/DBMS principals authorized for ownership.

Rule version

SQLD-22-001300

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Within the database, object ownership implies full privileges to the owned object, including the privilege to assign access to the owned objects to other subjects. Database functions and procedures can be coded using definer's rights. This allows anyone who uses the object to perform the actions if they were the owner. If not properly managed, this can lead to privileged actions being taken by unauthorized individuals.

Conversely, if critical tables or other objects in SQL Server rely on unauthorized owner accounts, these objects may be lost when an account is removed.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-001499; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review system documentation to identify SQL Server accounts authorized to own database objects.

If the SQL Server database ownership list does not exist or needs to be updated, this is a finding.

Use the following query to make this determination:

```
;with objects_cte as
(SELECT o.name, o.type_desc,
CASE
WHEN o.principal_id is null then s.principal_id
ELSE o.principal_id
END as principal_id
FROM sys.objects o
INNER JOIN sys.schemas s
ON o.schema_id = s.schema_id
```



```
WHERE o.is_ms_shipped = 0
)
SELECT cte.name, cte.type_desc, dp.name as ObjectOwner
FROM objects_cte cte
INNER JOIN sys.database_principals dp
ON cte.principal_id = dp.principal_id
ORDER BY dp.name, cte.name
```

If any of the listed owners are not authorized, this is a finding. Check reference:
MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Document and obtain approval for any account(s) authorized for object ownership. If necessary, use the ALTER AUTHORIZATION command to change object ownership to an authorized account.

Example provided below.

```
ALTER AUTHORIZATION ON OBJECT::test.table TO AuthorizedUser;
```

<https://docs.microsoft.com/en-us/sql/t-sql/statements/alter-authorization-transact-sql>

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271147r1111078_rule

The role(s)/group(s) used to modify database structure (including but not limited to tables, indexes, storage, etc.) and logic modules (stored procedures, functions, triggers, links to software external to SQL Server, etc.) must be restricted to authorized users.

Rule version

SQLD-22-001400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If SQL Server were to allow any user to make changes to database structure or logic, those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process.

Accordingly, only qualified and authorized individuals must be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Unmanaged changes that occur to the database software libraries or configuration can lead to unauthorized or compromised installations.

DBMS functionality and the nature and requirements of databases will vary; so, while users are not permitted to install unapproved software, there may be instances where the organization allows the user to install approved software packages such as from an approved software repository. The requirements for production servers will be more restrictive than those used for development and research.

The DBMS must enforce software installation by users based on what types of software installations are permitted (e.g., updates and security patches to existing software) and what types of installations are prohibited (e.g., software whose pedigree regarding being potentially malicious is unknown or suspect) by the organization.

In the case of a database management system, this requirement covers stored procedures, functions, triggers, views, etc.

Satisfies: SRG-APP-000133-DB-000362, SRG-APP-000133-DB-000179, SRG-APP-000378-DB-000365

Documentable: false

References

<http://cyber.mil/cci>: CCI-001499; <http://cyber.mil/cci>: CCI-003980; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676



Check instructions

If the SQL Server instance supports only software development, experimentation, and/or developer-level testing (i.e., excluding production systems, integration testing, stress testing, and user acceptance testing), this is not a finding.

Obtain a listing of users and roles who are authorized to create, alter, or replace logic modules from the server documentation.

In each user database, execute the following query:

```
SELECT P.type_desc AS principal_type, P.name AS principal_name,  
O.type_desc,  
CASE class  
WHEN 0 THEN DB_NAME()  
WHEN 1 THEN OBJECT_SCHEMA_NAME(major_id) + '.' + OBJECT_NAME(major_id)  
WHEN 3 THEN SCHEMA_NAME(major_id)  
ELSE class_desc + '(' + CAST(major_id AS nvarchar) + ')'  
END AS securable_name, DP.state_desc, DP.permission_name  
FROM sys.database_permissions DP  
JOIN sys.database_principals P ON DP.grantee_principal_id = P.principal_id  
LEFT OUTER JOIN sys.all_objects O ON O.object_id = DP.major_id AND O.type IN  
( 'TR', 'TA', 'P', 'X', 'RF', 'PC', 'IF', 'FN', 'TF', 'U' )  
WHERE DP.type IN ( 'AL', 'ALTG' ) AND DP.class IN ( 0, 1, 53 )
```

```
SELECT R.name AS role_name, M.type_desc AS principal_type, M.name AS principal_name  
FROM sys.database_principals R  
JOIN sys.database_role_members DRM ON R.principal_id = DRM.role_principal_id  
JOIN sys.database_principals M ON DRM.member_principal_id = M.principal_id  
WHERE R.name IN ( 'db_ddladmin', 'db_owner' )  
AND M.name <> 'dbo'
```

If any users or role permissions returned are not authorized to modify the specified object or type, this is a finding.

If any user or role membership is not authorized, this is a finding. Check reference:
MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility



UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Document and obtain approval for any nonadministrative users who require the ability to create, alter, or replace logic modules.

Revoke the ALTER permission from unauthorized users and roles:

REVOKE ALTER ON [<Object Name>] FROM [<Principal Name>]

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271168r1109218_rule

In the event of a system failure, hardware loss or disk failure, SQL Server must be able to restore necessary databases with least disruption to mission processes.

Rule version

SQLD-22-001500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Failure to a known state can address safety or security in accordance with the mission/business needs of the organization. Failure to a known secure state helps prevent a loss of confidentiality, integrity, or availability in the event of a failure of the information system or a component of the system. In the event of a system failure, SQL Server must be able to bring the database back to a consistent state.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-001665; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review the system documentation to determine whether the database is static, the recovery model to be used, the backup schedule, and the plan for testing database restoration.

If the documentation does not state that the database is static, assume that it is not static. If any of the other information is absent, this is a finding.

If the database is not static, and the documented recovery model is Bulk Logged, but the justification and authorization for this are not documented, this is a finding.

Run the following to determine Recovery Model:

```
USE [master]
GO
```

```
SELECT name, recovery_model_desc
FROM sys.databases
ORDER BY name
```



If the recovery model description does not match the documented recovery model, this is a finding.

Review the jobs set up to implement the backup plan. If they are absent, this is a finding.

Check the history of the backups by running the following query. It checks the last 30 days of backups by database.

```
USE [msdb]
GO

SELECT database_name,
CASE type
WHEN 'D' THEN 'Full'
WHEN 'I' THEN 'Differential'
WHEN 'L' THEN 'Log'
ELSE type
END AS backup_type,
is_copy_only,
backup_start_date, backup_finish_date
FROM dbo.backupset
WHERE backup_start_date >= dateadd(day, - 30, getdate())
ORDER BY database_name, backup_start_date DESC
```

If the history indicates a pattern of job failures by missing or gaps in backups, this is a finding.

Review evidence that database recovery is tested annually or more often, and that the most recent test was successful. If not, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance



Modify the system security plan to include whether the database is static, the correct recovery model to be used, the backup schedule, and the plan for testing database restoration.

In SQL Server Management Studio Object Explorer, right-click on the name of the database; select Properties >> Options page. Set the Recovery Model field (near the top of the page) to the correct value.

In Object Explorer, expand >> SQL Server Agent >> Jobs. Create, modify, and delete jobs to implement the backup schedule. (Alternatively, this may be done using T-SQL code or third-party backup software.)

Correct any issues that have been causing backups to fail.

Test the restoration of the database at least once a year; correct any issues that cause it to fail. Maintain a record of these tests.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271169r1109188_rule

The Database Master Key encryption password must meet DOD password complexity requirements.

Rule version

SQLD-22-001600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Weak passwords may be easily guessed. When passwords are used to encrypt keys used for encryption of sensitive data, the confidentiality of all data encrypted using that key is at risk.

Current DOD passwords require the following:

- minimum of 15 characters;
- at least one uppercase character;
- one lowercase character;
- one special character;
- one numeric character, and
- at least eight characters changed from the previous password.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001199; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

From the query prompt:

```
SELECT name  
FROM [master].sys.databases  
WHERE state = 0
```

Repeat for each database:

From the query prompt:

```
USE [database name]  
SELECT COUNT(name)  
FROM sys.symmetric_keys s, sys.key_encryptions k  
WHERE s.name = '##MS_DatabaseMasterKey##'
```



```
AND s.symmetric_key_id = k.key_id  
AND k.crypt_type in ('ESKP', 'ESP2', 'ESP3')
```

If the value returned is zero, this is not applicable.

If the value returned is greater than zero, a Database Master Key exists and is encrypted with a password.

Review procedures and evidence of password requirements used to encrypt Database Master Keys.

If the passwords do not meet DOD password standards, this is a finding. Check reference:
MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Assign an encryption password to the Database Master Key that is a minimum of 15 characters with at least one uppercase character, one lowercase character, one special character, one numeric character, and at least eight characters changed from the previous password. To change the Database Master Key encryption password:

```
USE [database name];  
ALTER MASTER KEY REGENERATE WITH ENCRYPTION BY PASSWORD = 'new password';
```

Note: Do not change the Database Master Key encryption method until the effects are thoroughly reviewed. Changing the master key encryption causes all encryption using the Database Master Key to be decrypted and reencrypted. This action should not be taken during a high-demand time.

Refer to the SQL Server documentation found here prior to reencrypting the Database Master Key:
<https://learn.microsoft.com/en-us/sql/relational-databases/security/encryption/create-a-database-master-key?>

Source benchmark



MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271170r1109190_rule

The Database Master Key must be encrypted by the Service Master Key, where a Database Master Key is required and another encryption method has not been specified.

Rule version

SQLD-22-001700

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: When not encrypted by the Service Master Key, system administrators or application administrators may access and use the Database Master Key to view sensitive data that they are not authorized to view. Where alternate encryption means are not feasible, encryption by the Service Master Key may be necessary. To help protect sensitive data from unauthorized access by DBAs, mitigations may be required. Mitigations may include automatic alerts or other audit events when the Database Master Key is accessed outside of the application or by a DBA account.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-001199; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

If no databases require encryption, this is not a finding.

From the query prompt:

```
SELECT name
FROM [master].sys.databases
WHERE is_master_key_encrypted_by_server = 1
AND state = 0;
```

If no databases are returned by the query, this is not a finding.

For any databases returned, verify in the System Security Plan that encryption of the Database Master Key using the Service Master Key is acceptable and approved by the Information Owner, and the encrypted data does not require additional protections to deter or detect DBA access. If not approved, this is a finding.

If approved and additional protections are required, verify the additional requirements are in place in accordance with



the System Security Plan. These may include additional auditing on access of the Database Master Key with alerts or other automated monitoring.

If the additional requirements are not in place, this is a finding. Check reference:
MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Where possible, encrypt the Database Master Key with a password known only to the application administrator.

Where not possible, configure additional audit events or alerts to detect unauthorized access to the Database Master Key by users not authorized to view sensitive data.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271171r1109192_rule

The certificate used for encryption must be backed up and stored in a secure location that is not on the SQL Server.

Rule version

SQLD-22-001800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Backup and recovery of the certificate used for encryption is critical to the complete recovery of the database. Not having this key can lead to loss of data during recovery.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001199; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

If the application owner and authorizing official have determined that encryption of data at rest is not required, this is not a finding.

Review procedures for and evidence of backup of the certificate used for encryption in the System Security Plan.

If the procedures or evidence does not exist, this is a finding.

If the procedures do not indicate that a backup of the certificate used for encryption is stored in a secure location that is not on the SQL Server, this is a finding.

If procedures do not indicate access restrictions to the certificate backup, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer



Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Document and implement procedures to safely back up and store the Certificate used for encryption. Include in the procedures methods to establish evidence of backup and storage, and careful, restricted access and restoration of the Certificate. Also, include provisions to store the backup off-site.

BACKUP CERTIFICATE 'CertificateName' TO FILE = 'path_to_file' WITH PRIVATE KEY (FILE = 'path_to_pvk', ENCRYPTION BY PASSWORD = 'password');

As this requires a password, ensure it is not exposed to unauthorized persons or stored as plain text.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271172r1109195_rule

SQL Server must isolate security functions from nonsecurity functions.

Rule version

SQLD-22-001900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: An isolation boundary provides access control and protects the integrity of the hardware, software, and firmware that perform security functions.

Security functions are the hardware, software, and/or firmware of the information system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based.

Developers and implementers can increase the assurance in security functions by employing well-defined security policy models; structured, disciplined, and rigorous hardware and software development techniques; and sound system/security engineering principles.

Database Management Systems typically separate security functionality from nonsecurity functionality via separate databases or schemas. Database objects or code implementing security functionality should not be commingled with objects or code implementing application logic. When security and nonsecurity functionality are commingled, users who have access to nonsecurity functionality may be able to access security functionality.

Documentable: false

References

<http://cyber.mil/ccr: CCI-001084; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676>

Check instructions

Determine elements of security functionality (lists of permissions, additional authentication information, stored procedures, application specific auditing, etc.) being housed inside SQL Server.

For any elements found, check SQL Server to determine if these objects or code implementing security functionality are located in a separate security domain, such as a separate database, schema, or table created specifically for security functionality.

Review the system documentation to determine if the necessary database changes cannot be made and that the blockers are also documented. If the necessary changes are documented as not possible, this is not a finding.

Review the database structure to determine where security-related functionality is stored. If security-related database



objects or code is not kept separate, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml
M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Check documentation and locate security-related database objects and code in a separate database, schema, table, or other separate security domain from database objects and code implementing application logic.

Schemas are analogous to separate namespaces or containers used to store database objects. Security permissions apply to schemas, making them an important tool for separating and protecting database objects based on access rights. Schemas reduce the work required, and improve the flexibility, for security-related administration of a database.

User-schema separation allows for more flexibility in managing database object permissions. A schema is a named container for database objects, which allows the user group objects into separate namespaces.

Where possible, locate security-related database objects and code in a separate database, schema, or other separate security domain from database objects and code implementing application logic. In all cases, use GRANT, REVOKE, DENY, ALTER ROLE ... ADD MEMBER ... and/or ALTER ROLE DROP MEMBER statements to add and remove permissions on server-level and database-level security-related objects to provide effective isolation.

Consider submitting a request to the vendor for changes to a COTS database when database structure does not isolate security functions and cannot be altered directly by the database administrators without loss of official support.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release



Release: 3 Benchmark Date: 01 Apr 2026



SV-271173r1137656_rule

Database contents must be protected from unauthorized and unintended information transfer by enforcement of a data transfer policy.

Rule version

SQLD-22-002000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Applications, including DBMSs, must prevent unauthorized and unintended information transfer via shared system resources.

Data used for the development and testing of applications often involves copying data from production. It is important that specific procedures exist for this process, including the conditions under which such transfer may take place, where the copies may reside, and the rules for ensuring sensitive data are not exposed.

Copies of sensitive data must not be misplaced or left in a temporary location without the proper controls.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001090; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review the procedures for the refreshing of development/test data from production.

Review any scripts or code that exists for the movement of production data to development/test systems, or to any other location or for any other purpose.

Verify that copies of production data are not left in unprotected locations.

If the code that exists for data movement does not comply with the organization-defined data transfer policy and/or fails to remove any copies of production data from unprotected locations, this is a finding. Check reference:

MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at



Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Modify any code used for moving data from production to development/test systems to comply with the organization-defined data transfer policy, and to ensure copies of production data are not left in unsecured locations.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271176r1109200_rule

SQL Server must check the validity of all data inputs except those specifically identified by the organization.

Rule version

SQLD-22-002100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Invalid user input occurs when a user inserts data or characters into an application's data entry fields and the application is unprepared to process that data. This results in unanticipated application behavior, potentially leading to an application or information system compromise. Invalid user input is one of the primary methods employed when attempting to compromise an application.

With respect to database management systems, one class of threat is known as SQL Injection, or more generally, code injection. It takes advantage of the dynamic execution capabilities of various programming languages, including dialects of SQL. Potentially, the attacker can gain unauthorized access to data, including security settings, and severely corrupt or destroy the database.

Even when no such hijacking takes place, invalid input that gets recorded in the database, whether accidental or malicious, reduces the reliability and usability of the system. Available protections include data types, referential constraints, uniqueness constraints, range checking, and application-specific logic. Application-specific logic can be implemented within the database in stored procedures and triggers, where appropriate.

This calls for inspection of application source code, which will require collaboration with the application developers. It is recognized that in many cases, the database administrator (DBA) is organizationally separate from the application developers, and may have limited, if any, access to source code. Nevertheless, protections of this type are so important to the secure operation of databases that they must not be ignored. At a minimum, the DBA must attempt to obtain assurances from the development organization that this issue has been addressed and must document what has been discovered.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001310; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review SQL Server code (stored procedures, functions, triggers), application code, settings, column and field definitions, and constraints to determine whether the database is protected against invalid input. If code exists that



allows invalid data to be acted upon or input into the database, this is a finding.

If column/field definitions do not reflect the data, this is a finding.

If columns/fields do not contain constraints and validity checking where required, this is a finding.

Where a column/field is noted in the system documentation as necessarily free-form, even though its name and context suggest that it should be strongly typed and constrained, the absence of these protections is not a finding.

Where a column/field is clearly identified by name, caption, or context as Notes, Comments, Description, Text, etc., the absence of these protections is not a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Use parameterized queries, constraints, foreign keys, etc., to validate data input. Modify SQL Server to properly use the correct column data types as required in the database.

Consider submitting a request to the vendor for changes to a COTS database when code is discovered that could create invalid inputs and cannot be altered directly by the database administrators without loss of official support.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271179r1108921_rule

SQL Server must provide nonprivileged users with error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries.

Rule version

SQLD-22-002400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Any DBMS or associated application providing too much information in error messages on the screen or printout risks compromising the data and security of the system. The structure and content of error messages need to be carefully considered by the organization and development team.

Databases can inadvertently provide a wealth of information to an attacker through improperly handled error messages. In addition to sensitive business or personal information, database errors can provide host names, IP addresses, usernames, and other system information not required for troubleshooting but very useful to someone targeting the system.

Carefully consider the structure/content of error messages. The extent to which information systems are able to identify and handle error conditions is guided by organizational policy and operational requirements. Information that could be exploited by adversaries includes, for example, logon attempts with passwords entered by mistake as the username, mission/business information that can be derived from (if not stated explicitly by) information recorded, and personal information, such as account numbers, social security numbers, and credit card numbers.

This calls for inspection of application source code, which will require collaboration with the application developers. It is recognized that in many cases, the database administrator (DBA) is organizationally separate from the application developers, and may have limited, if any, access to source code. Nevertheless, protections of this type are so important to the secure operation of databases that they must not be ignored. At a minimum, the DBA must attempt to obtain assurances from the development organization that this issue has been addressed and must document what has been discovered.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001312; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions



Review application behavior and custom database code (stored procedures, triggers), to determine whether error messages contain information beyond what is needed for explaining the issue to general users.

If database error messages contain PII data, sensitive business data, or information useful for identifying the host system or database structure, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Adjust database code to remove any information not required for explaining the error to an end user.

Consider enabling trace flag 3625 to mask certain system-level error information returned to nonadministrative users.

1. Launch SQL Server Configuration Manager >> SQL Services.
2. Open the instance properties.
3. Select the "Service Parameters" tab.
4. Enter "-T3625".
5. Click "Add" and then click "OK".
6. Restart SQL instance.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271184r1138541_rule

SQL Server must associate organization-defined types of security labels having organization-defined security label values with information in process, transit, or storage.

Rule version

SQLD-22-002600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Without the association of security labels to information, there is no basis for SQL Server to make security-related access-control decisions.

Security labels are abstractions representing the basic properties or characteristics of an entity (e.g., subjects and objects) with respect to safeguarding information.

These labels are typically associated with internal data structures (e.g., tables, rows) within the database and are used to enable the implementation of access control and flow control policies; reflect special dissemination, handling, or distribution instructions; or support other aspects of the information security policy.

One example includes marking data as classified or CUI. These security labels may be assigned manually or during data processing, but, either way, it is imperative these assignments are maintained while the data is in storage. If the security labels are lost when the data is stored, there is the risk of a data compromise.

The mechanism used to support security labeling may be a feature of SQL Server, a third-party product, or custom application code.

Satisfies: SRG-APP-000311-DB-000308, SRG-APP-000314-DB-000310

Documentable: false

References

<http://cyber.mil/ccr: CCI-002262>; <http://cyber.mil/ccr: CCI-002263>; <http://cyber.mil/ccr: CCI-002264>; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

If security labeling is not required, this is not a finding.

If security labeling requirements have been specified, but neither a third-party solution nor a SQL Server Row-Level security solution is implemented that reliably maintains labels on information, this is a finding. Check reference:



MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Deploy SQL Server Row-Level Security (refer to link below) or a third-party software, or add custom data structures, data elements, and application code, to provide reliable security labeling of information.

<https://msdn.microsoft.com/en-us/library/dn765131.aspx>

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271186r1109206_rule

SQL Server must enforce discretionary access control (DAC) policies, as defined by the data owner, over defined subjects and objects.

Rule version

SQLD-22-002800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: DAC is based on the notion that individual users are "owners" of objects and therefore have discretion over who should be authorized to access the object and in which mode (e.g., read or write). Ownership is usually acquired because of creating the object or via specified ownership assignment. DAC allows the owner to determine who will have access to objects they control. An example of DAC includes user-controlled table permissions.

When discretionary access control policies are implemented, subjects are not constrained regarding what actions they can take with information for which they have already been granted access. Thus, subjects that have been granted access to information are not prevented from passing (i.e., the subjects have the discretion to pass) the information to other subjects or objects.

A subject that is constrained in its operation by Mandatory Access Control policies is still able to operate under the less rigorous constraints of this requirement. Thus, while Mandatory Access Control imposes constraints preventing a subject from passing information to another subject operating at a different sensitivity level, this requirement permits the subject to pass the information to any subject at the same sensitivity level.

The policy is limited by the information system boundary. Once the information is passed outside of the control of the information system, additional means may be required to ensure the constraints remain in effect. While the older, more traditional definitions of DAC require identity-based access control, that limitation is not required for this use of DAC.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002165; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review system documentation to determine requirements for object ownership and authorization delegation.

Use the following query to discover database object ownership:



Schemas not owned by the schema or dbo:

```
SELECT name AS schema_name, USER_NAME(principal_id) AS schema_owner
FROM sys.schemas
WHERE schema_id <> principal_id
AND principal_id <> 1
```

Objects owned by an individual principal:

```
SELECT object_id, name AS securable,
USER_NAME(principal_id) AS object_owner,
type_desc
FROM sys.objects
WHERE is_ms_shipped = 0 AND principal_id IS NOT NULL
ORDER BY type_desc, securable, object_owner
```

Use the following query to discover database users who have been delegated the right to assign additional permissions:

```
SELECT U.type_desc, U.name AS grantee,
DP.class_desc AS securable_type,
CASE DP.class
WHEN 0 THEN DB_NAME()
WHEN 1 THEN OBJECT_NAME(DP.major_id)
WHEN 3 THEN SCHEMA_NAME(DP.major_id)
ELSE CAST(DP.major_id AS nvarchar)
END AS securable,
permission_name, state_desc
FROM sys.database_permissions DP
JOIN sys.database_principals U ON DP.grantee_principal_id = U.principal_id
WHERE DP.state = 'W'
ORDER BY grantee, securable_type, securable
```

If any of these rights are not documented and authorized, this is a finding. Check reference:
MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence



Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

To correct object ownership:

ALTER AUTHORIZATION ON <Securable> TO <Principal>

To revoke any unauthorized permissions:

REVOKE [Permission] ON <Securable> FROM <Principal>

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271188r1167492_rule

Execution of stored procedures and functions that use execute as must be restricted to necessary cases only.

Rule version

SQLD-22-002900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: In certain situations, to provide required functionality, a DBMS must execute internal logic (stored procedures, functions, triggers, etc.) and/or external code modules with elevated privileges. However, if the privileges required for execution are at a higher level than the privileges assigned to organizational users invoking the functionality applications/programs, those users are indirectly provided with greater privileges than assigned by organizations.

Privilege elevation must be used only where necessary and protected from misuse.

This calls for inspection of application source code, which will require collaboration with the application developers. It is recognized that in many cases, the database administrator (DBA) is organizationally separate from the application developers, and may have limited, if any, access to source code. Nevertheless, protections of this type are so important to the secure operation of databases that they must not be ignored. At a minimum, the DBA must attempt to obtain assurances from the development organization that this issue has been addressed and must document what has been discovered.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002233; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review the system documentation to obtain a listing of stored procedures and functions that use impersonation. Execute the following query:

```
SELECT S.name AS schema_name, O.name AS module_name,  
USER_NAME(  
CASE M.execute_as_principal_id  
WHEN -2 THEN COALESCE(O.principal_id, S.principal_id)  
ELSE M.execute_as_principal_id  
END
```



```
) AS execute_as
FROM sys.sql_modules M
JOIN sys.objects O ON M.object_id = O.object_id
JOIN sys.schemas S ON O.schema_id = S.schema_id
WHERE execute_as_principal_id IS NOT NULL
and O.name not in
(
'fn_sysdac_get_username',
'fn_sysutility_ucp_get_instance_is_mi',
'sp_send_dbmail',
'sp_SendMailMessage',
'sp_syscollector_create_collection_set',
'sp_syscollector_delete_collection_set',
'sp_syscollector_disable_collector',
'sp_syscollector_enable_collector',
'sp_syscollector_get_collection_set_execution_status',
'sp_syscollector_run_collection_set',
'sp_syscollector_start_collection_set',
'sp_syscollector_update_collection_set',
'sp_syscollector_upload_collection_set',
'sp_syscollector_verify_collector_state',
'sp_syspolicy_add_policy',
'sp_syspolicy_add_policy_category_subscription',
'sp_syspolicy_delete_policy',
'sp_syspolicy_delete_policy_category_subscription',
'sp_syspolicy_update_policy',
'sp_sysutility_mi_add_ucp_registration',
'sp_sysutility_mi_disable_collection',
'sp_sysutility_mi_enroll',
'sp_sysutility_mi_initialize_collection',
'sp_sysutility_mi_remove',
'sp_sysutility_mi_remove_ucp_registration',
'sp_sysutility_mi_upload',
'sp_sysutility_mi_validate_enrollment_preconditions',
'sp_sysutility_ucp_add_mi',
'sp_sysutility_ucp_add_policy',
'sp_sysutility_ucp_calculate_aggregated_dac_health',
'sp_sysutility_ucp_calculate_aggregated_mi_health',
'sp_sysutility_ucp_calculate_computer_health',
'sp_sysutility_ucp_calculate_dac_file_space_health',
'sp_sysutility_ucp_calculate_dac_health',
'sp_sysutility_ucp_calculate_filegroups_with_policy_violations',
'sp_sysutility_ucp_calculate_health',
'sp_sysutility_ucp_calculate_mi_file_space_health',
'sp_sysutility_ucp_calculate_mi_health',
'sp_sysutility_ucp_configure_policies',
'sp_sysutility_ucp_create',
'sp_sysutility_ucp_delete_policy',
'sp_sysutility_ucp_delete_policy_history',
'sp_sysutility_ucp_get_policy_violations',
'sp_sysutility_ucp_initialize',
```



```
'sp_sysutility_ucp_initialize_mdw',  
'sp_sysutility_ucp_remove_mi',  
'sp_sysutility_ucp_update_policy',  
'sp_sysutility_ucp_update_utility_configuration',  
'sp_sysutility_ucp_validate_prerequisites',  
'sp_validate_user',  
'syscollector_collection_set_is_running_update_trigger',  
'sysmail_help_status_sp'  
)
```

ORDER BY schema_name, module_name

If any procedures or functions are returned that are not documented, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Alter stored procedures and functions to remove the "EXECUTE AS" statement.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271195r1109208_rule

SQL Server must enforce access restrictions associated with changes to the configuration of the database(s).

Rule version

SQLD-22-003100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Failure to provide logical access restrictions associated with changes to configuration may have significant effects on the overall security of the system.

When dealing with access restrictions pertaining to change control, it should be noted that any changes to the hardware, software, and/or firmware components of the information system can potentially have significant effects on the overall security of the system.

Accordingly, only qualified and authorized individuals should be allowed to obtain access to system components for the purposes of initiating changes, including upgrades and modifications.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001813; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Execute the following query to obtain a listing of user databases whose owner is a member of a fixed server role:

```
SELECT
D.name AS database_name, SUSER_SNAME(D.owner_sid) AS owner_name,
FRM.is_fixed_role_member
FROM sys.databases D
OUTER APPLY (
SELECT MAX(fixed_role_member) AS is_fixed_role_member
FROM (
SELECT IS_SRVROLEMEMBER(R.name, SUSER_SNAME(D.owner_sid)) AS fixed_role_member
FROM sys.server_principals R
WHERE is_fixed_role = 1
) A
) FRM
```



```
WHERE D.database_id > 4
AND (FRM.is_fixed_role_member = 1
OR FRM.is_fixed_role_member IS NULL)
ORDER BY database_name
```

If no databases are returned, this is not a finding.

For each database/login returned, review the Server Role memberships:

1. In SQL Server Management Studio, expand "Logins".
2. Double-click the name of the login.
3. Click the "Server Roles" tab.

If any server roles are selected, but not documented and authorized, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove unauthorized users from roles:

```
ALTER ROLE DROP MEMBER user;
```

<https://learn.microsoft.com/en-us/sql/t-sql/statements/alter-role-transact-sql?>

Set the owner of the database to an authorized login:

```
ALTER AUTHORIZATION ON database::DatabaseName TO login;
```

<https://learn.microsoft.com/en-us/sql/t-sql/statements/alter-authorization-transact-sql?>



Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271199r1117186_rule

SQL Server must use NSA-approved cryptography to protect classified information in accordance with the data owner's requirements.

Rule version

SQLD-22-003200

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Use of weak or untested encryption algorithms undermines the purposes of using encryption to protect data. The application must implement cryptographic modules adhering to the higher standards approved by the federal government since this provides assurance they have been tested and validated.

It is the responsibility of the data owner to assess the cryptography requirements in light of applicable federal laws, Executive Orders, directives, policies, regulations, and standards.

NSA-approved cryptography for classified networks is hardware based. This requirement addresses the compatibility of a DBMS with the encryption devices.

Documentable: false

References

<http://cyber.mil/ccr:CCI-002450>; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Detailed information on the NIST Cryptographic Module Validation Program (CMVP) is available at the following website: <http://csrc.nist.gov/groups/STM/cmvp/index.html>.

Review system documentation to determine whether cryptography for classified or sensitive information is required by the information owner.

If the system documentation does not specify the type of information hosted on SQL Server as classified, sensitive, and/or unclassified, this is a finding.

If neither classified nor sensitive information exists within SQL Server databases or configuration, this is not a finding.

Verify that Windows is configured to require the use of FIPS-compliant algorithms.

1. Click "Start".



2. Type "Local Security Policy".
3. Press "Enter".
4. Expand "Local Policies".
5. Select "Security Options".
6. Locate "System Cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing".

If the Security Setting for this option is "Disabled", this is a finding.

Note: The list of acceptable algorithms is "AES 256" and "Triple DES".

If cryptography is being used by SQL Server, verify that the cryptography is NIST FIPS 140-2 or 140-3 certified by running the following SQL query:

```
SELECT DISTINCT name, algorithm_desc
FROM sys.symmetric_keys
WHERE key_algorithm NOT IN ('D3','A3')
ORDER BY name
```

If any items listed show an uncertified NIST FIPS 140-2 algorithm type, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure cryptographic functions to use NSA-approved cryptography compliant algorithms.

Use DOD code-signing certificates to create asymmetric keys stored in the database used to encrypt sensitive data stored in the database.

Run the following SQL script to create a certificate:



```
USE
CREATE CERTIFICATE
ENCRYPTION BY PASSWORD = <'password'>
FROM FILE = <'path/file_name'>
WITH SUBJECT = 'name of person creating key',
EXPIRY_DATE = '<'expiration date: yyyyymmdd'>'
```

Run the following SQL script to create a symmetric key and assign an existing certificate:

```
USE
CREATE SYMMETRIC KEY <'key name'>
WITH ALGORITHM = AES_256
ENCRYPTION BY CERTIFICATE
```

For Transparent Data Encryption (TDE):

```
USE master;
CREATE MASTER KEY ENCRYPTION BY PASSWORD = "";
CREATE CERTIFICATE . . .;
USE ;
CREATE DATABASE ENCRYPTION KEY
WITH ALGORITHM = AES_256
ENCRYPTION BY SERVER CERTIFICATE ;
ALTER DATABASE
SET ENCRYPTION ON;
```

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271201r1192914_rule

SQL Server must implement cryptographic mechanisms to prevent unauthorized modification or disclosure of organization-defined information at rest (to include, at a minimum, PII and classified information) on organization-defined information system components.

Rule version

SQLD-22-003300

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: DBMSs handling data requiring "data at rest" protections must employ cryptographic mechanisms to prevent unauthorized disclosure and modification of the information at rest. These cryptographic mechanisms may be native to the DBMS or implemented via additional software or operating system/file system settings, as appropriate to the situation.

Selection of a cryptographic mechanism is based on the need to protect the integrity of organizational information. The strength of the mechanism is commensurate with the security category and/or classification of the information. Organizations have the flexibility to either encrypt all information on storage devices (i.e., full disk encryption) or encrypt specific data structures (e.g., files, records, or fields).

The decision whether and what to encrypt rests with the data owner and is also influenced by the physical measures taken to secure the equipment and media on which the information resides.

Satisfies: SRG-APP-000429-DB-000387

Documentable: false

References

<http://cyber.mil/cci>: CCI-002475; <http://cyber.mil/cci>: CCI-002476; DPMS Target MS SQL Server 2022 Database
DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Review the system documentation to determine whether the organization has defined the information at rest that is to be protected from disclosure or modification, which must include, at a minimum, PII and classified information.

If no information is identified as requiring such protection, this is not a finding.

Review the configuration of SQL Server, Windows, and additional software as relevant.



If full-disk encryption is required, and Windows or the storage system is not configured for this, this is a finding.

If database transparent data encryption (TDE) is called for, verify it is enabled:

```
SELECT db.name AS DatabaseName, db.is_encrypted AS IsEncrypted,
CASE
WHEN dm.encryption_state = 0 THEN 'No database encryption key present, no encryption'
WHEN dm.encryption_state = 1 THEN 'Unencrypted'
WHEN dm.encryption_state = 2 THEN 'Encryption in progress'
WHEN dm.encryption_state = 3 THEN 'Encrypted'
WHEN dm.encryption_state = 4 THEN 'Key change in progress'
WHEN dm.encryption_state = 5 THEN 'Decryption in progress'
WHEN dm.encryption_state = 6 THEN 'Protection change in progress'
END AS EncryptionState,
dm.encryption_state AS EncryptionState,
dm.key_algorithm AS KeyAlgorithm,
dm.key_length AS KeyLength
FROM sys.databases db
LEFT OUTER JOIN sys.dm_database_encryption_keys dm ON db.database_id = dm.database_id
WHERE db.database_id NOT IN (1,2,3,4)
```

For each user database requiring encryption that is marked Unencrypted, this is a finding.

If table/column encryption and/or a separation between those who own the data (and can view it) and those who manage the data (but should have no access) is required for PII or similar types of data, use Always Encrypted. The details for configuring Always Encrypted are located here: <https://msdn.microsoft.com/en-us/library/mt163865.aspx>.

Review the definitions and contents of the relevant tables/columns for the Always Encrypted settings. If any of the information requiring cryptographic protection that is not encrypted this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation



Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Where full-disk encryption is required, configure Windows and/or the storage system to provide this.

Where TDE is required, create a master key, obtain a certificate protected by the master key, create a database encryption key and protect it by the certificate, and then set the database to use encryption. For guidance from MSDN on how to do this, refer to: <https://msdn.microsoft.com/en-us/library/bb934049.aspx>.

Where table/column encryption is required, enable encryption on the tables/columns in question. For guidance from the Microsoft Developer Network on how to do this with Always Encrypted, refer to: <https://msdn.microsoft.com/en-us/library/mt163865.aspx>.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-283667r1192917_rule

SQL Server must protect against a user falsely repudiating by ensuring that only unique Active Directory user accounts can connect to the database.

Rule version

SQLD-22-004250

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Nonrepudiation is required to maintain data integrity. Examples of particular actions taken by individuals include creating information, sending a message, approving information (e.g., indicating concurrence or signing a contract), and receiving a message.

Nonrepudiation protects against later claims by a user of not having created, modified, or deleted a particular data item or collection of data in the database.

In designing a database, the organization must define the types of data and the user actions that must be protected from repudiation. The implementation must then include building audit features into the application data tables and configuring SQL Server's audit tools to capture the necessary audit trail. Design and implementation also must ensure that applications pass individual user identification to SQL Server, even where the application connects to the DBMS with a standard, shared account.

If the computer account of a remote computer is granted access to a SQL Server database, any service or scheduled task running as NT AUTHORITY\SYSTEM or NT AUTHORITY\NETWORK SERVICE can log into the instance and perform actions. These actions cannot be traced back to a specific user or process.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000166; DPMS Target MS SQL Server 2022 Database DISA DPMS Target MS SQL Server 2022 Database 5676

Check instructions

Execute the following query:

```
SELECT name
FROM sys.database_principals
WHERE type in ('U','G')
AND name LIKE '%$'
```



If no users are returned, this is not a finding.

If users are returned, determine whether each user is a computer account.

Launch PowerShell and execute the following code:

Note: <name> represents the username portion of the user. For example, if the user is "CONTOSO\user1\$", the username is "user1".

```
[ADSI Searcher]"(&(ObjectCategory=Computer)(Name=<name>))".FindAll()
```

If no account information is returned, this is not a finding.

If account information is returned, this is a finding. Check reference: MS_SQL_Server_2022_Database_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Ensure all logins are uniquely identifiable and authenticate all users who log on to the system. This likely would be done using a combination of Active Directory with unique accounts and the SQL Server by ensuring mapping to individual accounts. Verify server documentation to ensure accounts are documented and unique.

Remove any undocumented accounts or shared accounts that cannot be individually authenticated.

Source benchmark

MS_SQL_Server_2022_Database_STIG

Source release

Release: 3 Benchmark Date: 01 Apr 2026



SV-271263r1108405_rule

SQL Server must limit the number of concurrent sessions to an organization-defined number per user for all accounts and/or account types.

Rule version

SQLI-22-003600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Database management includes the ability to control the number of users and user sessions using a DBMS. Unlimited concurrent connections to the DBMS could allow a successful denial-of-service (DoS) attack by exhausting connection resources; and a system can also fail or be degraded by an overload of legitimate users. Limiting the number of concurrent sessions per user is helpful in reducing these risks.

This requirement addresses concurrent session control for a single account. It does not address concurrent sessions by a single user via multiple system accounts; and it does not deal with the total number of sessions across all accounts.

The capability to limit the number of concurrent sessions per user must be configured in or added to the DBMS (for example, by use of a logon trigger), when this is technically feasible. Note that it is not sufficient to limit sessions via a web server or application server alone, because legitimate users and adversaries can potentially connect to the DBMS by other means.

The organization will need to define the maximum number of concurrent sessions by account type, by account, or a combination thereof. In deciding on the appropriate number, it is important to consider the work requirements of the various types of users. For example, two might be an acceptable limit for general users accessing the database via an application; but 10 might be too few for a database administrator using a database management GUI tool, where each query tab and navigation pane may count as a separate session.

Sessions may also be referred to as connections or logons, which for the purposes of this requirement are synonyms.

Documentable: false

References

<http://cyber.mil/ccr: CCI-000054; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions



Review the system documentation to determine whether any concurrent session limits have been defined. If it does not, assume a limit of 10 for database administrators and two for all other users.

If a mechanism other than a logon trigger is used, verify its correct operation by the appropriate means. If it does not work correctly, this is a finding.

Due to excessive CPU consumption when using a logon trigger, an alternative method of limiting concurrent sessions is setting the max connection limit within SQL Server to an appropriate value. This serves to block a distributed denial-of-service (DDOS) attack by limiting the attacker's connections while allowing a database administrator to still force a SQL connection.

In SQL Server Management Studio's Object Explorer tree, right-click on the Server Name >> Properties >> Connections Tab.

OR

Run the query:
EXEC sys.sp_configure N'user connections'

If the max connection limit is set to 0 (unlimited) or does not match the documented value, this is a finding.

Otherwise, determine if a logon trigger exists:

In SQL Server Management Studio's Object Explorer tree, expand [SQL Server Instance] >> Server Objects >> Triggers.

OR

Run the query:
SELECT name FROM master.sys.server_triggers;

If no triggers are listed, this is a finding.

If triggers are listed, identify the trigger(s) limiting the number of concurrent sessions per user. If none are found, this is a finding. If they are present but disabled, this is a finding.

Examine the trigger source code for logical correctness and for compliance with the documented limit(s). If errors or variances exist, this is a finding.

Verify that the system does execute the trigger(s) each time a user session is established. If it does not operate correctly for all types of user, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned



Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

If a trigger consumes too much CPU, an example alternative method for limiting the concurrent users is setting the max connection limit on SQL Server.

In SQL Server Management Studio's Object Explorer tree, right-click on the Server Name >> Properties >> Connections Tab >> Set the Maximum Number of Concurrent Connections to a value other than 0 (0 = unlimited), and document it.

OR

Run the query:

```
EXEC sys.sp_configure N'user connections','5000' /* this is an example max limit */
GO
RECONFIGURE WITH OVERRIDE
GO
```

Restart SQL Server for the setting to take effect.

Reference: <https://learn.microsoft.com/en-us/sql/database-engine/configure-windows/configure-the-user-connections-server-configuration-option?>

Otherwise, establish the limit(s) appropriate to the type(s) of user account accessing the SQL Server instance, and record them in the system documentation. Implement one or more logon triggers to enforce the limit(s), without exposing the dynamic management views to general users.

Example script:

```
CREATE TRIGGER SQL_STIG_Connection_Limit
ON ALL SERVER WITH EXECUTE AS 'renamed_sa' /*Make sure to use the renamed SA account here*/
FOR LOGON
AS
BEGIN
If (Select COUNT(1) from sys.dm_exec_sessions WHERE is_user_process = 1 AND original_login_name =
ORIGINAL_LOGIN() ) >
(CASE ORIGINAL_LOGIN()
WHEN 'domain/ima.dba' THEN 150 /*this is a busy DBA's domain account */
WHEN 'application1_login' THEN 6 /* this is a SQL login for an application */
WHEN 'application2_login' THEN 20 /* this is a SQL login for another application */
...
ELSE 1 /* All unspecified users are restricted to a single login */
```



```
END)
BEGIN
PRINT 'The login [' + ORIGINAL_LOGIN() + '] has exceeded its concurrent session limit.'
ROLLBACK;
END
END;
```

Reference: <https://msdn.microsoft.com/en-us/library/ms189799.aspx>

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271264r1111061_rule

SQL Server must be configured to use the most-secure authentication method available.

Rule version

SQLI-22-003800

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Enterprise environments make account management for applications and databases challenging and complex. A manual process for account management functions adds the risk of a potential oversight or other error. Managing accounts for the same person in multiple places is inefficient and prone to problems with consistency and synchronization.

A comprehensive application account management process that includes automation helps to ensure that accounts designated as requiring attention are consistently and promptly addressed.

Examples include, but are not limited to, using automation to act on multiple accounts designated as inactive, suspended, or terminated, or by disabling accounts located in noncentralized account stores, such as multiple servers. Account management functions can also include assignment of group or role membership; identifying account type; specifying user access authorizations (i.e., privileges); account removal, update, or termination; and administrative alerts. The use of automated mechanisms can include, for example: using email or text messaging to notify account managers when users are terminated or transferred; using the information system to monitor account usage; and using automated telephone notification to report atypical system account usage.

SQL Server must be configured to automatically use organization-level account management functions, and these functions must immediately enforce the organization's current account policy.

Automation may comprise differing technologies that when placed together contain an overall mechanism supporting an organization's automated account management requirements.

SQL Server supports several authentication methods to allow operation in various environments, Kerberos, NTLM, and SQL Server. An instance of SQL Server must be configured to use the most secure method available. Service accounts used by SQL Server should be unique to a given instance.

Documentable: false

References

<http://cyber.mil/ccr:CCI-000015>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677



Check instructions

If the SQL Server is not part of an Active Directory domain, this is Not Applicable.

Obtain the fully qualified domain name of the SQL Server instance:

1. Launch Windows Explorer.
2. Right-click "Computer" or "This PC" (Varies by OS level).
3. Click "Properties". Note the value shown for "Full computer name".

Note: For a cluster, this value must be obtained from the Failover Cluster Manager.

Obtain the TCP port that is supporting the SQL Server instance:

1. Click "Start".
2. Type "SQL Server 2022 Configuration Manager".
3. From the search results, click "SQL Server 2022 Configuration Manager".
4. From the tree on the left, expand "SQL Server Network Configuration".
5. Click "Protocols for <Instance Name>" where <Instance Name> is the name of the instance (MSSQLSERVER is the default name).
6. In the right pane, right-click "TCP/IP" and choose "Properties".
7. In the window that opens, click the "IP Addresses" tab. Note the TCP port configured for the instance.

Obtain the service account that is running the SQL Server service:

1. Click "Start".
2. Type "SQL Server 2022 Configuration Manager".
3. From the search results, click "SQL Server 2022 Configuration Manager".
4. From the tree on the left, select "SQL Server Services". Note the account listed in the "Log On As" column for the SQL Server instance being reviewed.
5. Launch a command-line or PowerShell window.
6. Enter the following command where <Service Account> is the identity of the service account:
`setspn -L <Service Account>`
Example: `setspn -L CONTOSO\sql2016svc`
7. Review the Registered Service Principal Names returned.

If the listing does not contain the following supported service principal names (SPN) formats, this is a finding.

Named instance

`MSSQLSvc/<FQDN>:[<port> | <instancename>]`, where:

`MSSQLSvc` is the service that is being registered.

`<FQDN>` is the fully qualified domain name of the server.

`<port>` is the TCP port number.

`<instancename>` is the name of the SQL Server instance.

Default instance

`MSSQLSvc/<FQDN>:<port> | MSSQLSvc/<FQDN>`, where:

`MSSQLSvc` is the service that is being registered.

`<FQDN>` is the fully qualified domain name of the server.

`<port>` is the TCP port number.

If the MSSQLSvc service is registered for any fully qualified domain names that do not match the current server, this may indicate the service account is shared across SQL Server instances. Review server documentation, if the



sharing of service accounts across instances is not documented and authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Ensure Service Principal Names (SPNs) are properly registered for the SQL Server instance.

Use the Microsoft Kerberos Configuration Manager to review Kerberos configuration issues for a given SQL Server instance.

<https://www.microsoft.com/en-us/download/details.aspx?id=39046>

Alternatively, SPNs for SQL Server can be manually registered.

For other connections that support Kerberos the SPN is registered in the format MSSQLSvc/<FQDN>/<instancename> for a named instance. The format for registering the default instance is MSSQLSvc/<FQDN>.

Using an account with permissions to register SPNs, issue the following commands from a command-prompt:

```
setspn -S MSSQLSvc/<Fully Qualified Domain Name> <Service Account>
setspn -S MSSQLSvc/<Fully Qualified Domain Name>:<TCP Port> <Service Account>
For a named instance, use:
setspn -S MSSQLSvc/<FQDN>:<instancename> <Service Account>
setspn -S MSSQLSvc/<FQDN>:<TCP Port> <Service Account>
```

Restart the SQL Server instance.

More information regarding this process is available at <https://docs.microsoft.com/en-us/sql/database-engine/configure-windows/register-a-service-principal-name-for-kerberos-connections#Manual>.



Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271265r1108933_rule

SQL Server must integrate with an organization-level authentication/access mechanism providing account management and automation for all users, groups, roles, and any other principals.

Rule version

SQLI-22-003700

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Enterprise environments make account management for applications and databases challenging and complex. A manual process for account management functions adds the risk of a potential oversight or other error. Managing accounts for the same person in multiple places is inefficient and prone to problems with consistency and synchronization.

A comprehensive application account management process that includes automation helps to ensure that accounts designated as requiring attention are consistently and promptly addressed.

Examples include, but are not limited to, using automation to act on multiple accounts designated as inactive, suspended, or terminated, or by disabling accounts located in noncentralized account stores, such as multiple servers. Account management functions can also include assignment of group or role membership; identifying account type; specifying user access authorizations (i.e., privileges); account removal, update, or termination; and administrative alerts. The use of automated mechanisms can include, for example, using email or text messaging to notify account managers when users are terminated or transferred; using the information system to monitor account usage; and using automated telephone notification to report atypical system account usage.

SQL Server must be configured to automatically use organization-level account management functions, and these functions must immediately enforce the organization's current account policy.

Automation may be composed of differing technologies that when placed together contain an overall mechanism supporting an organization's automated account management requirements.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000015; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions



Determine whether SQL Server is configured to use only Windows authentication.

In the Object Explorer in SQL Server Management Studio (SSMS), right-click on the server instance. Select "Properties", then select the Security page.

If Windows Authentication Mode is selected, this is not a finding.

OR

In a query interface such as the SSMS Transact-SQL editor, run the statement:

```
SELECT CASE SERVERPROPERTY('IsIntegratedSecurityOnly')
WHEN 1 THEN 'Windows Authentication'
WHEN 0 THEN 'Windows and SQL Server Authentication'
END as [Authentication Mode]
```

If the returned value in the "Authentication Mode" column is "Windows Authentication", this is not a finding.

Mixed mode (both SQL Server authentication and Windows authentication) is in use. If the need for mixed mode has not been documented and approved by the information system security officer (ISSO)/information system security manager (ISSM), this is a finding.

From the documentation, obtain the list of accounts authorized to be managed by SQL Server.

Determine the accounts (SQL Logins) actually managed by SQL Server. Run the statement:

```
SELECT name
FROM sys.sql_logins
WHERE type_desc = 'SQL_LOGIN' AND is_disabled = 0;
```

If any accounts listed by the query are not listed in the documentation, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation



Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

If mixed mode is required, document the need and justification; describe the measures taken to ensure the use of SQL Server authentication is kept to a minimum; describe the measures taken to safeguard passwords; and list or describe the SQL Logins used.

Documentation must be approved by the ISSO/ISSM.

If mixed mode is not required, disable it as follows:

1. In the SSMS Object Explorer, right-click on the server instance.
2. Select Properties >> Security page.
3. Click the radio button for "Windows Authentication Mode".
4. Click "OK".
5. Restart the SQL Server instance.

OR

Run the statement:

```
USE [master]
EXEC xp_instance_regwrite N'HKEY_LOCAL_MACHINE', N'Software\Microsoft\MSSQLServer\MSSQLServer',
N'LoginMode', REG_DWORD, 2
GO
```

Restart the SQL Server instance.

For each account being managed by SQL Server but not requiring it, drop or disable the SQL Login. Replace it with an appropriately configured account, as needed.

To drop or disable a login in the SSMS Object Explorer, navigate to "Security Logins". Right-click on the login name and click "Delete" or "Disable".

To drop or disable a login by using a query:

```
USE master;
DROP LOGIN login_name;
ALTER LOGIN login_name DISABLE;
```

Dropping a login does not delete the equivalent database user(s). There may be more than one database containing a user mapped to the login. Drop the user(s) unless still needed.

To drop a user in the SSMS Object Explorer:
Navigate to Databases >> Security Users.
Right-click on the username.
Click "Delete".

To drop a user via a query:

```
USE database_name;
DROP USER <user_name>;
```



Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271266r1137654_rule

SQL Server must enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

Rule version

SQLI-22-003900

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Authentication with a DOD-approved PKI certificate does not necessarily imply authorization to access SQL Server. To mitigate the risk of unauthorized access to sensitive information by entities that have been issued certificates by DOD-approved PKIs, all DOD systems, including databases, must be properly configured to implement access control policies.

Successful authentication must not automatically give an entity access to an asset or security boundary. Authorization procedures and controls must be implemented to ensure each authenticated entity also has a validated and current authorization. Authorization is the process of determining whether an entity, once authenticated, is permitted to access a specific asset. Information systems use access control policies and enforcement mechanisms to implement this requirement.

Access control policies include identity-based policies, role-based policies, and attribute-based policies. Access enforcement mechanisms include access control lists, access control matrices, and cryptography. These policies and mechanisms must be employed by the application to control access between users (or processes acting on behalf of users) and objects (e.g., devices, files, records, processes, programs, and domains) in the information system.

This requirement is applicable to access control enforcement applications, a category that includes database management systems. If SQL Server does not follow applicable policy when approving access, it may be in conflict with networks or other applications in the information system. This may result in users either gaining or being denied access inappropriately and in conflict with applicable policy.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000213; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the system documentation to determine the required levels of protection for DBMS server securables by type of login.



Review the permissions in place on the server.

If the permissions do not match the documented requirements, this is a finding.

Use the supplemental file "Instance permissions assignments to logins and roles.sql". Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Use GRANT, REVOKE, DENY, ALTER SERVER ROLE ... ADD MEMBER ... and/or ALTER SERVER ROLE DROP MEMBER statements to add and remove permissions on server-level securables, bringing them into line with the documented requirements.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271267r1108417_rule

SQL Server must protect against a user falsely repudiating by ensuring only clearly unique Active Directory user accounts can connect to the instance.

Rule version

SQLI-22-004200

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Nonrepudiation of actions taken is required to maintain data integrity. Examples of particular actions taken by individuals include creating information, sending a message, approving information (e.g., indicating concurrence or signing a contract), and receiving a message.

Nonrepudiation protects against later claims by a user of not having created, modified, or deleted a particular data item or collection of data in the database.

In designing a database, the organization must define the types of data and the user actions that must be protected from repudiation. The implementation must then include building audit features into the application data tables and configuring the DBMS's audit tools to capture the necessary audit trail. Design and implementation also must ensure that applications pass individual user identification to the DBMS, even where the application connects to the DBMS with a standard, shared account.

If the computer account of a remote computer is granted access to SQL Server, any service or scheduled task running as NT AUTHORITY\SYSTEM or NT AUTHORITY\NETWORK SERVICE can log into the instance and perform actions. These actions cannot be traced back to a specific user or process.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000166; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Execute the following:

```
SELECT name
FROM sys.server_principals
WHERE type in ('U','G')
AND name LIKE '%$'
```



If no logins are returned, this is not a finding.

If logins are returned, determine whether each login is a computer account.

Launch PowerShell and execute the following code:

Note: <name> represents the username portion of the login. For example, if the login is "CONTOSO\user1\$", the username is "user1".

```
([ADSI Searcher]"(&(ObjectCategory=Computer)(Name=<name>))").FindAll()
```

If no account information is returned, this is not a finding.

If account information is returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove all logins that were returned in the check content.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271268r1136917_rule

SQL Server must protect against a user falsely repudiating by ensuring the NT AUTHORITY SYSTEM account is not used for administration.

Rule version

SQLI-22-004100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Nonrepudiation of actions taken is required to maintain data integrity. Examples of particular actions taken by individuals include creating information, sending a message, approving information (e.g., indicating concurrence or signing a contract), and receiving a message.

Nonrepudiation protects against later claims by a user of not having created, modified, or deleted a particular data item or collection of data in the database.

In designing a database, the organization must define the types of data and the user actions that must be protected from repudiation. The implementation must then include building audit features into the application data tables and configuring the DBMS's audit tools to capture the necessary audit trail. Design and implementation also must ensure that applications pass individual user identification to the DBMS, even where the application connects to the DBMS with a standard, shared account.

Any user with enough access to the server can execute a task that will be run as NT AUTHORITY\SYSTEM either using task scheduler or other tools. At this point, NT AUTHORITY\SYSTEM essentially becomes a shared account because the operating system and SQL Server are unable to determine who created the process.

Prior to SQL Server 2012, NT AUTHORITY\SYSTEM was a member of the sysadmin role by default. This allowed jobs/tasks to be executed in SQL Server without the approval or knowledge of the DBA because it looked like operating system activity.

Documentable: false

References

<http://cyber.mil/cc:CCI-000166>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Execute the following queries. The first query checks for clustering and availability groups being provisioned in the database engine. The second query lists permissions granted to the local system account.



```
SELECT  
SERVERPROPERTY('IsClustered') AS [IsClustered],  
SERVERPROPERTY('IsHadrEnabled') AS [IsHadrEnabled]
```

```
EXECUTE AS LOGIN = 'NT AUTHORITY\SYSTEM'
```

```
SELECT * FROM fn_my_permissions(NULL, 'server')
```

```
REVERT
```

```
GO
```

If "IsClustered" returns "1", "IsHadrEnabled" returns "0", and any permissions have been granted to the Local System account beyond "CONNECT SQL", "VIEW SERVER STATE", "VIEW ANY DATABASE", "VIEW SERVER PERFORMANCE STATE", and "VIEW SERVER SECURITY STATE", this is a finding.

If "IsHadrEnabled" returns "1" and any permissions have been granted to the Local System account beyond "CONNECT SQL", "CREATE AVAILABILITY GROUP", "ALTER ANY AVAILABILITY GROUP", "VIEW SERVER STATE", "VIEW ANY DATABASE", "VIEW SERVER PERFORMANCE STATE", and "VIEW SERVER SECURITY STATE", this is a finding.

If both "IsClustered" and "IsHadrEnabled" return "0" and any permissions have been granted to the Local System account beyond "CONNECT SQL" and "VIEW ANY DATABASE", this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove permissions that were identified as not allowed in the check content.

USE Master;



```
REVOKE <Permission> TO [NT AUTHORITY\SYSTEM]
```

```
GO
```

To grant permissions to services or applications, use the Service SID of the service or a domain service account.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271269r1108423_rule

SQL Server must protect against a user falsely repudiating by ensuring all accounts are individual, unique, and not shared.

Rule version

SQLI-22-004000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Nonrepudiation of actions taken is required to maintain data integrity. Examples of particular actions taken by individuals include creating information, sending a message, approving information (e.g., indicating concurrence or signing a contract), and receiving a message.

Nonrepudiation protects against later claims by a user of not having created, modified, or deleted a particular data item or collection of data in the database.

In designing a database, the organization must define the types of data and the user actions that must be protected from repudiation. The implementation must then include building audit features into the application data tables and configuring SQL Server's audit tools to capture the necessary audit trail. Design and implementation also must ensure that applications pass individual user identification to SQL Server, even where the application connects to SQL Server with a standard, shared account.

Satisfies: SRG-APP-000080-DB-000063, SRG-APP-000815-DB-000160

Documentable: false

References

<http://cyber.mil/cci>: CCI-000166; <http://cyber.mil/cci>: CCI-004045; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Obtain the list of authorized SQL Server accounts in the system documentation.

Determine if any accounts are shared. A shared account is defined as a username and password that are used by multiple individuals to log into SQL Server. An example of a shared account is the SQL Server installation account. Windows Groups are not shared accounts as the group itself does not have a password.

If accounts are determined to be shared, determine if individuals are first individually authenticated.

If individuals are not individually authenticated before using the shared account (e.g., by the operating system or by



an application making calls to the database), this is a finding.

The key is individual accountability. If this can be traced, this is not a finding.

If accounts are determined to be shared, determine if they are directly accessible to end users. If so, this is a finding.

Review contents of audit logs, traces, and data tables to confirm that the identity of the individual user performing the action is captured.

If shared identifiers are found and are not accompanied by individual identifiers, this is a finding.

Note: Privileged installation accounts may be required to be accessed by the DBA or other administrators for system maintenance. In these cases, each use of the account must be logged in some manner to assign accountability for any actions taken during the use of the account. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove user-accessible shared accounts and use individual user IDs.

Build/configure applications to ensure successful individual authentication prior to shared account access.

Ensure each user's identity is received and used in audit data in all relevant circumstances.

Design, develop, and implement a method to log use of any account to which more than one person has access. Restrict interactive access to shared accounts to the fewest persons possible.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release



Release: 4 Benchmark Date: 01 Apr 2026



SV-271270r1108426_rule

SQL Server must be configured to generate audit records for DOD-defined auditable events within all DBMS/database components.

Rule version

SQLI-22-004300

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within SQL Server (e.g., process, module). Certain specific application functionalities may be audited as well. The list of audited events is the set of events for which audits are to be generated. This set of events is typically a subset of the list of all events for which the system is capable of generating audit records.

DOD has defined the list of events for which SQL Server will provide an audit record generation capability as the following:

- (i) Successful and unsuccessful attempts to access, modify, or delete privileges, security objects, security levels, or categories of information (e.g., classification levels);
- (ii) Access actions, such as successful and unsuccessful logon attempts, privileged activities, or other system-level access, starting and ending time for user access to the system, concurrent logons from different workstations, successful and unsuccessful accesses to objects, all program initiations, and all direct access to the information system; and
- (iii) All account creation, modification, disabling, and termination actions.

Organizations may define additional events requiring continuous or ad hoc auditing.

Documentable: false

References

<http://cyber.mil/ccr: CCI-000169; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions



Review the server documentation to determine if any additional events are required to be audited. If no additional events are required, this is not a finding.

Execute the following to get all of the installed audits:

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status
```

All currently defined audits for the SQL server instance will be listed. If no audits are returned, this is a finding.

To view the actions being audited by the audits, execute the following:

```
SELECT a.name AS 'AuditName',  
s.name AS 'SpecName',  
d.audit_action_name AS 'ActionName',  
d.audited_result AS 'Result'  
FROM sys.server_audit_specifications s  
JOIN sys.server_audits a ON s.audit_guid = a.audit_guid  
JOIN sys.server_audit_specification_details d ON s.server_specification_id = d.server_specification_id  
WHERE a.is_state_enabled = 1
```

Compare the documentation to the list of generated audit events. If there are any missing events, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Add all required audit events to the STIG-compliant audit specification server documentation.



Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271271r1108429_rule

SQL Server must allow only the information system security manager (ISSM) (or individuals or roles appointed by the ISSM) to select which auditable events are to be audited.

Rule version

SQLI-22-004400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Without the capability to restrict which roles and individuals can select which events are audited, unauthorized personnel may be able to prevent or interfere with the auditing of critical events.

Suppression of auditing could permit an adversary to evade detection.

Misconfigured audits can degrade the system's performance by overwhelming the audit log. Misconfigured audits may also make it more difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000171; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Obtain the list of approved audit maintainers from the system documentation.

Review the server roles and individual logins that have the following role memberships, all of which enable the ability to create and maintain audit definitions.

sysadmin
dbcreator

Review the server roles and individual logins that have the following permissions, all of which enable the ability to create and maintain audit definitions.

ALTER ANY SERVER AUDIT
CONTROL SERVER
ALTER ANY DATABASE



CREATE ANY DATABASE

Use the following query to determine the roles and logins that have the listed permissions:

```
SELECT-- DISTINCT
CASE
WHEN SP.class_desc IS NOT NULL THEN
CASE
WHEN SP.class_desc = 'SERVER' AND S.is_linked = 0 THEN 'SERVER'
WHEN SP.class_desc = 'SERVER' AND S.is_linked = 1 THEN 'SERVER (linked)'
ELSE SP.class_desc
END
WHEN E.name IS NOT NULL THEN 'ENDPOINT'
WHEN S.name IS NOT NULL AND S.is_linked = 0 THEN 'SERVER'
WHEN S.name IS NOT NULL AND S.is_linked = 1 THEN 'SERVER (linked)'
WHEN P.name IS NOT NULL THEN 'SERVER_PRINCIPAL'
ELSE '???'
END AS [Securable Class],
CASE
WHEN E.name IS NOT NULL THEN E.name
WHEN S.name IS NOT NULL THEN S.name
WHEN P.name IS NOT NULL THEN P.name
ELSE '???'
END AS [Securable],
P1.name AS [Grantee],
P1.type_desc AS [Grantee Type],
sp.permission_name AS [Permission],
sp.state_desc AS [State],
P2.name AS [Grantor],
P2.type_desc AS [Grantor Type],
R.name AS [Role Name]
FROM
sys.server_permissions SP
INNER JOIN sys.server_principals P1
ON P1.principal_id = SP.grantee_principal_id
INNER JOIN sys.server_principals P2
ON P2.principal_id = SP.grantor_principal_id

FULL OUTER JOIN sys.servers S
ON SP.class_desc = 'SERVER'
AND S.server_id = SP.major_id

FULL OUTER JOIN sys.endpoints E
ON SP.class_desc = 'ENDPOINT'
AND E.endpoint_id = SP.major_id

FULL OUTER JOIN sys.server_principals P
ON SP.class_desc = 'SERVER_PRINCIPAL'
AND P.principal_id = SP.major_id

FULL OUTER JOIN sys.server_role_members SRM
```



```
ON P.principal_id = SRM.member_principal_id
```

```
LEFT OUTER JOIN sys.server_principals R  
ON SRM.role_principal_id = R.principal_id  
WHERE sp.permission_name IN ('ALTER ANY SERVER AUDIT','CONTROL SERVER','ALTER ANY  
DATABASE','CREATE ANY DATABASE')  
OR R.name IN ('sysadmin','dbcreator')
```

If any of the logins, roles, or role memberships returned have permissions that are not documented, or the documented audit maintainers do not have permissions, this is a finding. Check reference:

MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Create a server role specifically for audit maintainers and give it permission to maintain audits without granting it unnecessary permissions (the role name used here is an example; other names may be used):

```
CREATE SERVER ROLE SERVER_AUDIT_MAINTAINERS;  
GO
```

```
GRANT ALTER ANY SERVER AUDIT TO SERVER_AUDIT_MAINTAINERS;  
GO
```

Use REVOKE and/or DENY and/or ALTER SERVER ROLE ... DROP MEMBER ... statements to remove the ALTER ANY SERVER AUDIT permission from all logins. Then, for each authorized login, run the statement:

```
ALTER SERVER ROLE SERVER_AUDIT_MAINTAINERS ADD MEMBER;  
GO
```

Use REVOKE and/or DENY and/or ALTER SERVER ROLE ... DROP MEMBER ... statements to remove CONTROL



SERVER, ALTER ANY DATABASE and CREATE ANY DATABASE permissions from logins that do not need them.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271272r1109110_rule

SQL Server must generate audit records when attempts to access privileges, categorized information, and security objects occur.

Rule version

SQLI-22-004600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Under some circumstances, it may be useful to monitor who/what is reading privilege/permission/role information. Therefore, monitoring must be possible. DBMSs typically make such information available through views or functions.

This requirement includes explicit requests for privilege/permission/role membership information. It does not refer to the implicit retrieval of privileges/permissions/role memberships that SQL Server continually performs to determine if any and every action on the database is permitted.

Changes to the security configuration must also be tracked.

Security configuration tracking applies to situations where security data is retrieved or modified via data manipulation operations, as opposed to via specialized security functionality.

In a SQL environment, types of access include but are not necessarily limited to:

SELECT
INSERT
UPDATE
DELETE
EXECUTE

Changes in categorized information must be tracked. Without an audit trail, unauthorized access to protected data could go undetected.

For detailed information on categorizing information, refer to FIPS Publication 199, Standards for Security Categorization of Federal Information and Information Systems, and FIPS Publication 200, Minimum Security Requirements for Federal Information and Information Systems.

To aid in diagnosis, it is necessary to track failed attempts in addition to the successful ones.

Satisfies: SRG-APP-000091-DB-000325, SRG-APP-000091-DB-000066, SRG-APP-000492-DB-000332, SRG-APP-000492-DB-000333, SRG-APP-000494-DB-000344, SRG-APP-000494-DB-000345, SRG-APP-000498-DB-000346, SRG-APP-000498-DB-000347, SRG-APP-000502-DB-000348, SRG-APP-000502-DB-000349, SRG-APP-000507-DB-000356, SRG-APP-000507-DB-000357



Documentable: false

References

<http://cyber.mil/ccci>: CCI-000172; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the system documentation to determine if SQL Server is required to audit when the following events occur:

- Attempts to retrieve privilege/permission/role membership information.
- Security objects are accessed, modified, or deleted.
- Data classifications (e.g., classification levels/security levels) are accessed, modified, or deleted.
- Any other specified objects are accessed, modified, or deleted as required by the site.

If SQL Server is not required to audit any of the above, this is not a finding.

If the documentation does not exist, this is a finding.

Determine if an audit is configured and started by executing the following query. If no records are returned, this is a finding.

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status
```

If auditing the retrieval of the above information or objects is required, execute the following to verify the SCHEMA_OBJECT_ACCESS_GROUP is included in the server audit specification:

```
SELECT a.name AS 'AuditName',  
s.name AS 'SpecName',  
d.audit_action_name AS 'ActionName',  
d.audited_result AS 'Result'  
FROM sys.server_audit_specifications s  
JOIN sys.server_audits a ON s.audit_guid = a.audit_guid  
JOIN sys.server_audit_specification_details d ON s.server_specification_id = d.server_specification_id  
WHERE a.is_state_enabled = 1 AND d.audit_action_name = 'SCHEMA_OBJECT_ACCESS_GROUP'
```

If the SCHEMA_OBJECT_ACCESS_GROUP is not returned in an active audit, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

**Reviewer**

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Deploy an audit to log when attempts to access privileges, categorized information, security objects, and any other specific objects occur.

Refer to the supplemental file "SQL 2022 Audit.sql".

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271273r1109234_rule

SQL Server must initiate session auditing upon startup.

Rule version

SQLI-22-004700

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Session auditing is for use when a user's activities are under investigation. To be sure of capturing all activity during those periods when session auditing is in use, it needs to be in operation for the whole time SQL Server is running.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001464; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

When audits are enabled, they start up when the instance starts. Refer to https://msdn.microsoft.com/en-us/library/cc280386.aspx#Anchor_2

Check if an audit is configured and enabled by executing the following query:

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status  
WHERE status_desc = 'STARTED'
```

All currently defined audits for the SQL server instance will be listed. If no audits are returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

**Reviewer**

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure the SQL audit(s) to automatically start during system startup.

ALTER SERVER AUDIT [<Server Audit Name>] WITH STATE = ON

Execute the following:

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status  
WHERE status_desc = 'STARTED'
```

Ensure the SQL STIG Audit is configured to initiate session auditing upon startup.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271280r1108456_rule

SQL Server must include additional, more detailed, organization-defined information in the audit records for audit events identified by type, location, or subject.

Rule version

SQLI-22-005500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information system auditing capability is critical for accurate forensic analysis. Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information. To support analysis, some types of events will need information to be logged that exceeds the basic requirements of event type, time stamps, location, source, outcome, and user identity. If additional information is not available, it could negatively impact forensic investigations into user actions or other malicious events.

The organization must determine what additional information is required for complete analysis of the audited events. The additional information required is dependent on the type of information (e.g., sensitivity of the data and the environment within which it resides). At a minimum, the organization must employ either full-text recording of privileged commands or the individual identities of users of shared accounts, or both. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise.

Examples of detailed information the organization may require in audit records are full-text recording of privileged commands or the individual identities of shared account users.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000135; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If a SQL Server Audit is not in use for audit purposes, this is a finding unless a third-party product is being used that can perform detailed auditing for SQL Server.

Review system documentation to determine whether SQL Server is required to audit any events, and any fields, in addition to those in the standard audit.

If there are none specified, this is not a finding.



If SQL Server Audit is in use, compare the audit specification(s) with the documented requirements.

If any such requirement is not satisfied by the audit specification(s) (or by supplemental, locally deployed mechanisms), this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Design and deploy an audit that captures all auditable events and data items. In the event a third-party tool is used for auditing, it must contain all the required information, including but not limited to, events, type, location, subject, date and time, and by whom the change occurred.

Implement additional custom audits to capture the additional organizational required information.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271282r1109273_rule

The audit information produced by SQL Server must be protected from unauthorized access, modification, and deletion.

Rule version

SQLI-22-005900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If audit data were to become compromised, competent forensic analysis and discovery of the true source of potentially malicious system activity would be difficult, if not impossible, to achieve. In addition, access to audit records provides information an attacker could potentially use to their advantage.

To ensure the veracity of audit data, the information system and/or the application must protect audit information from any and all unauthorized access. This includes read, write, copy, etc.

This requirement can be achieved through multiple methods, which will depend on system architecture and design. Some commonly employed methods include ensuring log files enjoy the proper file system permissions using file system protections and limiting log data location.

Additionally, applications with user interfaces to audit records should not allow for the unfettered manipulation of or access to those records via the application. If the application provides access to the audit data, the application becomes accountable for ensuring that audit information is protected from unauthorized access. SQL Server is able to view and manipulate audit file data.

Audit information includes all information (e.g., audit records, audit settings, and audit reports) needed to successfully audit information system activity.

Satisfies: SRG-APP-000118-DB-000059, SRG-APP-000119-DB-000060, SRG-APP-000120-DB-000061

Documentable: false

References

<http://cyber.mil/cci>: CCI-000162; <http://cyber.mil/cci>: CCI-000163; <http://cyber.mil/cci>: CCI-000164; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If the database is set up to write audit logs using APPLICATION or SECURITY event logs rather than writing to a file, this is Not Applicable.



Obtain the SQL Server Audit file location(s) by running the following SQL script:

```
SELECT log_file_path AS "Audit Path"  
FROM sys.server_file_audits
```

For each audit, the path column will give the location of the file.

Verify that all audit files have the correct permissions by doing the following for each audit file: Navigate to audit folder location(s) using a command prompt or Windows Explorer.

Right-click the file/folder and click "Properties". On the "Security" tab, verify the following permissions are applied:

- Administrator (read)
- Users (none)
- Audit Administrator (Full Control)
- Auditors group (Read)
- SQL Server Service SID OR Service Account (Full Control)
- SQL Server SQL Agent Service SID OR Service Account, if SQL Server Agent is in use. (Read, Execute, Write)

If any less restrictive permissions are present (and not specifically justified and approved), this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Modify audit file permissions to meet the requirement to protect against unauthorized access.

Application event log and security log permissions are covered in the Windows Server STIGs. Reference these depending on the OS in use.

Navigate to audit folder location(s) using a command prompt or Windows Explorer. Right-click the file and click



"Properties".

On the Security tab, modify the security permissions to:

Administrator (read)

Users (none)

Audit Administrator(Full Control)

Auditors group (Read)

SQL Server Service SID OR Service Account (Full Control) [Notes 1, 2]

SQL Server SQL Agent Service SID OR Service Account, if SQL Server Agent is in use. (Read, Execute, Write)
[Notes 1, 2]

Note 1: It is highly advisable to use a separate account for each service. When installing SQL Server in single-server mode, users can opt to have these provisioned for them. These automatically generated accounts are referred to as virtual accounts. Each virtual account has an equivalent Service SID with the same name. The installer also creates an equivalent SQL Server login, also with the same name. Applying folder and file permissions to Service SIDs rather than to domain accounts or local computer accounts provides tighter control, because these permissions are available only to the specific service when it is running and not in any other context. However, when using failover clustering, a domain account must be specified at installation, rather than a virtual account. For more on this topic, refer to [http://msdn.microsoft.com/en-us/library/ms143504\(v=sql.130\).aspx](http://msdn.microsoft.com/en-us/library/ms143504(v=sql.130).aspx).

Note 2: Tips for adding a service SID/virtual account to a folder's permission list:

1. In Windows Explorer, right-click the folder and select "Properties".
2. Select the "Security" tab.
3. Click "Edit".
4. Click "Add".
5. Click "Locations".
6. Select the computer name.
7. Search for the name.
- 7.a. SQL Server Service
- 7.a.i. Type "NT SERVICE\MSSQL" and click "Check Names". (This is the first 16 characters of the name. At least one character must follow "NT SERVICE\"; this will present with a list of all matches. If the full, correct name was typed, step 7.a.ii is bypassed.)
- 7.a.ii. Select the "MSSQL\$" user and click "OK".
- 7.b. SQL Agent Service
- 7.b.i. Type "NT SERVICE\SQL" and click "Check Names".
- 7.b.ii. Select the "SQLAgent\$" user and click "OK".
8. Click "OK".
9. Permission like a normal user from here.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271283r1108465_rule

SQL Server must protect its audit configuration from authorized and unauthorized access and modification.

Rule version

SQLI-22-006300

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Protecting audit data also includes identifying and protecting the tools used to view and manipulate log data. Therefore, protecting audit tools is necessary to prevent unauthorized operation on audit data.

Applications providing tools to interface with audit data will leverage user permissions and roles identifying the user accessing the tools and the corresponding rights the user enjoys in order make access decisions regarding the modification of audit tools. SQL Server is an application that does provide access to audit data.

Audit tools include, but are not limited to, vendor-provided and open-source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

If an attacker were to gain access to audit tools, they could analyze audit logs for system weaknesses or weaknesses in the auditing itself. An attacker could also manipulate logs to hide evidence of malicious activity.

Satisfies: SRG-APP-000121-DB-000202, SRG-APP-000122-DB-000203, SRG-APP-000123-DB-000204

Documentable: false

References

<http://cyber.mil/cci>: CCI-001493; <http://cyber.mil/cci>: CCI-001494; <http://cyber.mil/cci>: CCI-001495; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Check the server documentation for a list of approved users with access to SQL Server Audits.

To create, alter, or drop a server audit, principals require the ALTER ANY SERVER AUDIT or the CONTROL SERVER permission.

Review the SQL Server permissions granted to principals. Look for permissions ALTER ANY SERVER AUDIT, ALTER ANY DATABASE AUDIT, CONTROL SERVER:



```
SELECT login.name, perm.permission_name, perm.state_desc
FROM sys.server_permissions perm
JOIN sys.server_principals login
ON perm.grantee_principal_id = login.principal_id
WHERE permission_name in ('ALTER ANY DATABASE AUDIT', 'ALTER ANY SERVER AUDIT', 'CONTROL
SERVER')
and login.name not like '##MS_%';
```

If unauthorized accounts have these privileges, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove audit-related permissions from individuals and roles not authorized to have them.

```
USE master;
DENY [ALTER ANY SERVER AUDIT] TO [User];
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271284r1109111_rule

SQL Server must limit privileges to change software modules, to include stored procedures, functions and triggers, and links to software external to SQL Server.

Rule version

SQLI-22-006600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If the system were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process.

Accordingly, only qualified and authorized individuals must be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Unmanaged changes that occur to the database software libraries or configuration can lead to unauthorized or compromised installations.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-001499; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review server documentation to determine the process by which shared software libraries are monitored for change. Ensure the process alerts for changes in a file's ownership, modification dates, and hash value at a minimum.

If alerts do not at least hash their value, this is a finding.

To determine the location for these instance-specific binaries:

1. Launch SQL Server Management Studio (SSMS).
2. Connect to the instance to be reviewed.
3. Right-click server name in Object Explorer.
4. Click "Facets".
5. Select the "Server" facet.
6. Record the value for the "RootDirectory" facet property.



Tip: Use the Get-FileHash cmdlet shipped with PowerShell 5.0 to get the SHA-2 hash of one or more files. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Implement and document a process by which changes made to software libraries are monitored and alerted. A PowerShell based hashing solution is one such process. The Get-FileHash command can be used to compute the SHA-2 hash of one or more files. For more information, refer to the following link:
<https://msdn.microsoft.com/en-us/powershell/reference/5.1/microsoft.powershell.utility/get-filehash>

Using the Export-Clixml command, a baseline can be established and exported to a file:
<https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.utility/export-clixml?view=powershell-7.5>

Using the Compare-Object command, a comparison of the latest baseline versus the original baseline can expose the differences:
[https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-powershell-1.0/ee156812\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-powershell-1.0/ee156812(v=technet.10)?redirectedfrom=MSDN)

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271285r1109236_rule

SQL Server must limit privileges to change software modules and links to software external to SQL Server.

Rule version

SQLI-22-006500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If the system were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process.

Accordingly, only qualified and authorized individuals must be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Unmanaged changes that occur to the database software libraries or configuration can lead to unauthorized or compromised installations.

Documentable: false

References

<http://cyber.mil/ccr:CCI-001499>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review Server documentation to determine the authorized owner and users or groups with modify rights for this SQL instance's binary files. Additionally check the owner and users or groups with modify rights for shared software library paths on disk.

If any unauthorized users are granted modify rights or the owner is incorrect, this is a finding.

To determine the location for these instance-specific binaries:

1. Launch SQL Server Management Studio (SSMS).
2. Connect to the instance to be reviewed.
3. Right-click server name in "Object Explorer".
4. Click "Facets".
5. Select the "Server" facet.
6. Record the value for the "RootDirectory" facet property.



7. Navigate to the folder above and review the "Binn" subdirectory.

TIP: Use the Get-FileHash cmdlet shipped with PowerShell 5.0 to get the SHA-2 hash of one or more files. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Change the ownership of all shared software libraries on disk to the authorized account. Remove any modify permissions granted to unauthorized users or groups.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271286r1108474_rule

SQL Server software installation account must be restricted to authorized users.

Rule version

SQLI-22-006700

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: When dealing with change control issues, it should be noted any changes to the hardware, software, and/or firmware components of the information system and/or application can have significant effects on the overall security of the system.

If the system were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. Accordingly, only qualified and authorized individuals must be allowed access to information system components for purposes of initiating changes, including upgrades and modifications.

DBA and other privileged administrative or application owner accounts are granted privileges that allow actions that can have a great impact on SQL Server security and operation. It is especially important to grant privileged access to only those persons who are qualified and authorized to use them.

Documentable: false

References

<http://cyber.mil/ccci>: CCI-001499; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

From the system documentation, obtain the list of accounts authorized to install/update SQL Server. Run the following PowerShell command to list all users who have installed/modified SQL Server 2022 software and compare the list against those persons who are qualified and authorized to use the software.

```
sl "C:\Program files\Microsoft SQL Server\160\Setup Bootstrap\Log"  
Get-ChildItem -Recurse | Select-String -Pattern "LogonUser = "
```

If any accounts are shown that are not authorized in the system documentation, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence



Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

From a command prompt, open lusrmgr.msc. Navigate to "Users" and right-click "Individual User". Select "Properties", then "Member Of".

Configure SQL Server and OS settings and access controls to restrict user access to objects and data that the user is authorized to view/use.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271287r1108843_rule

Database software, including DBMS configuration files, must be stored in dedicated directories, separate from the host OS and other applications.

Rule version

SQLI-22-006800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: When dealing with change control issues, it should be noted any changes to the hardware, software, and/or firmware components of the information system and/or application can potentially have significant effects on the overall security of the system.

Multiple applications can provide a cumulative negative effect. A vulnerability and subsequent exploit to one application can lead to an exploit of other applications sharing the same security context. For example, an exploit to a web server process that leads to unauthorized administrative access to host system directories can most likely lead to a compromise of all applications hosted by the same system. Database software not installed using dedicated directories both threatens and is threatened by other hosted applications. Access controls defined for one application may by default provide access to the other application's database objects or directories. Any method that provides any level of separation of security context assists in the protection between applications.

Documentable: false

References

<http://cyber.mil/ccr:CCI-001499>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Determine the directory in which SQL Server has been installed:

Using SQL Server Management Studio's Object Explorer, right-click [SQL Server Instance], select "Facets", then record the value of RootDirectory.

Determine the Operating System directory:

1. Click "Start".
2. Type "Run".
3. Press "Enter".
4. Type "%windir%".
5. Click "Ok".
6. Record the value in the address bar.



Verify the SQL Server RootDirectory is not in the Operating System directory.

Compare the SQL RootDirectory and the Operating System directory. If the SQL RootDirectory is in the same directory as the Operating System, this is a finding.

Verify the SQL Server RootDirectory is not in another application's directory.

Navigate to the SQL RootDirectory using Windows Explorer.

Examine each directory for evidence another application is stored in it.

If evidence exists the SQL RootDirectory is in another application's directory, this is a finding.

If the SQL RootDirectory is not in the Operating System directory or another application's directory, this is not a finding.

Examples:

1. The Operating System directory is "C:\Windows". The SQL RootDirectory is "D:\Program Files\MSSQLSERVER\MSSQL". The MSSQLSERVER directory is not living in the Operating System directory or the directory of another application. This is not a finding.

2. The Operating System directory is "C:\Windows". The SQL RootDirectory is "C:\Windows\MSSQLSERVER\MSSQL". This is a finding.

3. The Operating System directory is "C:\Windows". The SQL RootDirectory is "D:\Program Files\Microsoft Office\MSSQLSERVER\MSSQL". The MSSQLSERVER directory is in the Microsoft Office directory, which indicates Microsoft Office is installed here. This is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result



Benchmark remediation guidance

Reinstall SQL Server application components using dedicated directories that are separate from the operating system.

Relocate or reinstall other application software that currently shares directories with SQL Server components separate from the operating system and/or temporary storage.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271290r1109112_rule

Default demonstration and sample databases, database objects, and applications must be removed.

Rule version

SQLI-22-006900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for software products to provide, or install by default, functionality exceeding requirements or mission objectives. Examples include, but are not limited to, installing advertising software, demonstrations, or browser plugins not related to requirements or providing a wide array of functionality, not required for every mission, that cannot be disabled.

DBMSs must adhere to the principles of least functionality by providing only essential capabilities.

Demonstration and sample database objects and applications present publicly known attack points for malicious users. These demonstration and sample objects are meant to provide simple examples of coding specific functions and are not developed to prevent vulnerabilities from being introduced to SQL Server and host system.

Documentable: false

References

<http://cyber.mil/ccr:CCI-000381>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review vendor documentation and vendor websites to identify vendor-provided demonstration or sample databases, database applications, objects, and files. Review the SQL Server to determine if any of the demonstration and sample databases, database applications, or files are installed in the database or included with the SQL Server Instance.

Run the following query to check for names matching known sample databases. Sample databases may have been renamed, so this is not an exhaustive list.

```
SELECT name
```



```
FROM sys.databases
WHERE name LIKE '%pubs%'
OR name LIKE '%northwind%'
OR name LIKE '%adventureworks%'
OR name LIKE '%wideworldimporters%'
OR name LIKE '%contoso%'
```

If any sample databases are found, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove all demonstration or sample databases from production instances.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271291r1108899_rule

Unused database components, DBMS software, and database objects must be removed.

Rule version

SQLI-22-007000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for software products to provide, or install by default, functionality exceeding requirements or mission objectives.

DBMSs must adhere to the principles of least functionality by providing only essential capabilities.

Documentable: false

References

<http://cyber.mil/ccr: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

From the server documentation, obtain a listing of required components.

Generate a listing of components installed on the server.

1. Click "Start".
2. Type "SQL Server 2022 Installation Center".
3. Launch the program.
4. Click "Tools".
5. Click "Installed SQL Server features discovery report".
6. Compare the feature listing against the required components listing.

If any features are installed, but are not required, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence



Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove all features that are not required.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271292r1111143_rule

The SQL Server Replication Xps feature must be disabled unless specifically required and approved.

Rule version

SQLI-22-017900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: SQL Server is capable of providing a wide range of features and services. Some of the default features and services may not be necessary and enabling them could adversely affect the security of the system.

Enabling the replication Xps opens a significant attack surface area that can be used by an attacker to gather information about the system and potentially abuse the privileges of SQL Server.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if [Replication Xps] is enabled, execute the following command:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'Replication Xps'
```

If [value_in_use] is a [1], review the system documentation to determine whether the use of [Replication Xps] is approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned



Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not approved.

To disable the use of [Replication Xps] option, from the query prompt:

```
EXEC SP_CONFIGURE 'show advanced options', 1;  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'replication xps', 0;  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'show advanced options', 0;  
RECONFIGURE WITH OVERRIDE;  
GO  
RECONFIGURE;  
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271293r1111138_rule

The SQL Server External Scripts Enabled feature must be disabled, unless specifically required and approved.

Rule version

SQLI-22-017700

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: SQL Server is capable of providing a wide range of features and services. Some of the default features and services may not be necessary and enabling them could adversely affect the security of the system.

The External Scripts Enabled feature allows scripts external to SQL such as files located in an R library to be executed.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if [External Scripts Enabled] is enabled, execute the following command:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'External Scripts Enabled'
```

If [value_in_use] is a [1], review the system documentation to determine whether the use of [External Scripts Enabled] is approved. If it is not approved, this is a finding. Check reference:

MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer



Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not approved.

To disable the use of [External Scripts Enabled] option, from the query prompt:
EXEC SP_CONFIGURE 'External Scripts Enabled', 0;
RECONFIGURE WITH OVERRIDE;

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271295r1111135_rule

The remote Data Archive feature must be disabled unless specifically required and approved.

Rule version

SQLI-22-017600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

SQL Server is capable of providing a wide range of features and services. Some of the features and services, provided by default, may not be necessary, and enabling them could adversely affect the security of the system.

The Remote Data Archive feature allows an export of local SQL Server data to an Azure SQL Database. An exploit to the SQL Server instance could result in a compromise of the host system and external SQL Server resources.

Documentable: false

References

<http://cyber.mil/ccr: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

To determine if [Remote Data Archive] is enabled, execute the following command:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'Remote Data Archive'
```



If [value_in_use] is a [1], review the system documentation to determine whether the use of [Remote Data Archive] is approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not approved.

To disable the use of [Remote Data Archive] option, from the query prompt:

```
EXEC SP_CONFIGURE 'Remote Data Archive', 0;  
RECONFIGURE WITH OVERRIDE;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271296r1111132_rule

The "Allow Polybase Export" feature must be disabled, unless specifically required and approved.

Rule version

SQLI-22-017500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

The Allow Polybase Export feature allows an export of data to an external data source such as Hadoop File System or Azure Data Lake. An exploit to the SQL Server instance could result in a compromise of the host system and external SQL Server resources.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if [Allow Polybase Export] is enabled, execute the following command:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'Allow Polybase Export'
```

If [value_in_use] is a [1], review the system documentation to determine whether the use of [Allow Polybase Export] is approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

**Evidence**

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not approved.

To disable the use of [Allow Polybase Export] option, from the query prompt:

```
EXEC SP_CONFIGURE 'Allow Polybase Export', 0;  
RECONFIGURE WITH OVERRIDE;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271297r1111129_rule

The "Hadoop Connectivity" feature must be disabled unless specifically required and approved.

Rule version

SQLI-22-017400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

SQL Server is capable of providing a wide range of features and services. Some of the features and services, provided by default, may not be necessary, and enabling them could adversely affect the security of the system.

The "Hadoop Connectivity" feature allows multiple types of external data sources to be created and used across all sessions on the server. An exploit to the SQL Server instance could result in a compromise of the host system and external SQL Server resources.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if [Hadoop Connectivity] is enabled, execute the following command:

```
SELECT name, value, value_in_use
FROM sys.configurations
WHERE name = 'Hadoop Connectivity'
```



If [value_in_use] is a [1], review the system documentation to determine whether the use of [Hadoop Connectivity] is approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not approved.

To disable the use of [Hadoop Connectivity] option, from the query prompt:
EXEC SP_CONFIGURE 'hadoop connectivity', 0;
RECONFIGURE WITH OVERRIDE;

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271298r1111126_rule

The "Remote Access" feature must be disabled unless specifically required and approved.

Rule version

SQLI-22-017200

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

The "Remote Access" option controls the execution of local stored procedures on remote servers or remote stored procedures on local server. Remote access functionality can be abused to launch a denial-of-service (DoS) attack on remote servers by off-loading query processing to a target.

Documentable: false

References

<http://cyber.mil/ccci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if [Remote Access] is enabled, execute the following command:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'Remote Access'
```

If [value_in_use] is a [1], review the system documentation to determine whether the use of [Remote Access] is approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

**Evidence**

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of [Remote Access] if it is not authorized.

To disable the use of [Remote Access], from the query prompt:
EXEC SP_CONFIGURE 'remote access', 0;
RECONFIGURE WITH OVERRIDE;

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271299r1108513_rule

Access to linked servers must be disabled or restricted, unless specifically required and approved.

Rule version

SQLI-22-007500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

A linked server allows for access to distributed, heterogeneous queries against OLE DB data sources. After a linked server is created, distributed queries can be run against this server, and queries can join tables from more than one data source. If the linked server is defined as an instance of SQL Server, remote stored procedures can be executed. This access may be exploited by malicious users who have compromised the integrity of the SQL Server.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

A linked server allows for access to distributed, heterogeneous queries against OLE DB data sources. After a linked server is created, distributed queries can be run against this server, and queries can join tables from more than one data source. If the linked server is defined as an instance of SQL Server, remote stored procedures can be executed.

To obtain a list of linked servers, execute the following command:



```
SELECT name
FROM sys.servers s
WHERE s.is_linked = 1
```

Review the system documentation to determine whether the linked servers listed are required and approved. If it is not approved, this is a finding.

Run the following to get a linked server login mapping:

```
SELECT s.name, p.principal_id, l.remote_name
FROM sys.servers s
JOIN sys.linked_logins l ON s.server_id = l.server_id
LEFT JOIN sys.server_principals p ON l.local_principal_id = p.principal_id
WHERE s.is_linked = 1
```

Review the linked login mapping and check the remote name as it can impersonate sysadmin. If a login in the list is impersonating sysadmin and system documentation does not require this, it is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove any linked servers and all associated logins that are not authorized.

To remove a linked server and all associated logins run the following:

```
sp_dropserver 'LinkedServerName', 'droplogins';
```

To remove a login from a linked server run the following:

```
EXEC sp_droplinkedsvlogin 'LoginName', NULL;
```



Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271300r1109264_rule

Access to nonstandard, extended stored procedures must be disabled or restricted, unless specifically required and approved.

Rule version

SQLI-22-007400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

Extended stored procedures are DLLs that an instance of SQL Server can dynamically load and run. Extended stored procedures run directly in the address space of an instance of SQL Server and are programmed by using the SQL Server Extended Stored Procedure API. Nonstandard extended stored procedures can compromise the integrity of the SQL Server process. This feature will be removed in a future version of Microsoft SQL Server. Do not use this feature in new development work and modify applications that currently use this feature as soon as possible.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Extended stored procedures are DLLs that an instance of SQL Server can dynamically load and run. Extended stored procedures run directly in the address space of an instance of SQL Server and are programmed by using the SQL Server Extended Stored Procedure API.

Nonstandard extended stored procedures can compromise the integrity of the SQL Server process. This feature will



be removed in a future version of SQL Server. Do not use this feature in new development work and modify applications that currently use this feature as soon as possible.

To determine if nonstandard extended stored procedures exist, run the following:

```
USE [master]
GO
DECLARE @xplist AS TABLE
(
    xp_name sysname,
    source_dll nvarchar(255)
)
INSERT INTO @xplist
EXEC sp_helpextendedproc

SELECT X.xp_name, X.source_dll, O.is_ms_shipped FROM @xplist X JOIN sys.all_objects O ON X.xp_name =
O.name WHERE O.is_ms_shipped = 0 ORDER BY X.xp_name
```

If any records are returned, review the system documentation to determine whether the use of nonstandard extended stored procedures are required and approved.

If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove any nonstandard extended stored procedures that are not documented and approved using the following:

```
sp_dropextendedproc 'proc name'
```

Source benchmark



MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271301r1109114_rule

Access to common language runtime (CLR) code must be disabled or restricted unless specifically required and approved.

Rule version

SQLI-22-007300

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

The CLR component of the .NET Framework for Microsoft Windows in SQL Server allows users to write stored procedures, triggers, user-defined types, user-defined functions, user-defined aggregates, and streaming table-valued functions, using any .NET Framework language, including Microsoft Visual Basic .NET and Microsoft Visual C#. CLR packing assemblies can access resources protected by .NET Code Access Security when it runs managed code. Specifying UNSAFE enables the code in the assembly complete freedom to perform operations in the SQL Server process space that can potentially compromise the robustness of SQL Server. UNSAFE assemblies can also potentially subvert the security system of either SQL Server or the common language runtime.

Documentable: false

References

<http://cyber.mil/cc: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

To determine if [CLR] is enabled, execute the following command:

```
SELECT name, value, value_in_use
```



```
FROM sys.configurations  
WHERE name = 'clr enabled'
```

If [value_in_use] is a [1], review the system documentation to determine whether the use of [CLR] is approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any CLR code that is not authorized.

To disable the use of CLR, from the query prompt:

```
EXEC SP_CONFIGURE 'clr enabled', 0;  
RECONFIGURE WITH OVERRIDE;
```

For any approved CLR code with Unsafe or External permissions, use the ALTER ASSEMBLY to change the permission set for the assembly and ensure a certificate is configured.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271302r1109113_rule

Access to xp_cmdshell must be disabled unless specifically required and approved.

Rule version

SQLI-22-007200

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the default functions and services may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different OS security context than SQL Server and provide unauthorized access to the host system.

The xp_cmdshell extended stored procedure allows execution of host executables outside the controls of database access permissions. This access may be exploited by malicious users who have compromised the integrity of the SQL Server database process to control the host operating system to perpetrate additional malicious activity.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if [xp_cmdshell] is enabled, execute the following command:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'xp_cmdshell'
```

If [value_in_use] is a [1], review the system documentation to determine whether the use of [xp_cmdshell] is



approved. If it is not approved, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not approved.

To disable the use of xp_cmdshell, from the query prompt:

```
EXEC SP_CONFIGURE 'show advanced options', 1;  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'xp_cmdshell', 0;  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'show advanced options', 0;  
RECONFIGURE WITH OVERRIDE;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271303r1109116_rule

SQL Server must be configured to prohibit or restrict the use of organization-defined ports, as defined in the Ports, Protocols, and Services Management (PPSM) Category Assurance List (CAL) and vulnerability assessments.

Rule version

SQLI-22-007700

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: To prevent unauthorized connection of devices, unauthorized transfer of information, or unauthorized tunneling (i.e., embedding of data types within data types), organizations must disable or restrict unused or unnecessary physical and logical ports on information systems.

Applications are capable of providing a wide variety of functions and services. Some of the functions and services provided by default may not be necessary to support essential organizational operations. Additionally, it is sometimes convenient to provide multiple services from a single component (e.g., email and web services); however, doing so increases risk over limiting the services provided by any one component.

To support the requirements and principles of least functionality, the application must support the organizational requirements providing only essential capabilities and limiting the use of ports to only those required, authorized, and approved to conduct official business or to address authorized quality of life issues.

SQL Server using ports deemed unsafe is open to attack through those ports. This can allow unauthorized access to the database and through the database to other components of the information system.

Documentable: false

References

<http://cyber.mil/ccr:CCI-000382>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review SQL Server Configuration for the ports used by SQL Server.

To determine whether SQL Server is configured to use a fixed port or dynamic ports, in the right-side pane, double-click on the TCP/IP entry to open the Properties dialog. (The default fixed port is 1433.)



Alternatively, run the following SQL query to determine the port used by SQL Server:

```
SELECT ISNULL(CONVERT(VARCHAR(25),local_tcp_port),'Dynamic Ports are Enabled')
FROM sys.dm_exec_connections
WHERE session_id = @@SPID
```

If any ports in use are in conflict with PPSM guidance and not explained and approved in the system documentation, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Use SQL Server Configuration to change the ports used by SQL Server to comply with PPSM guidance, or document the need for other ports, and obtain written approval. Close ports no longer needed.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271304r1109265_rule

SQL Server must be configured to prohibit or restrict the use of organization-defined protocols as defined in the Ports, Protocols, and Services Management (PPSM) Category Assurance List (CAL) and vulnerability assessments.

Rule version

SQLI-22-007600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: To prevent unauthorized connection of devices, unauthorized transfer of information, or unauthorized tunneling (i.e., embedding of data types within data types), organizations must disable or restrict unused or unnecessary protocols on information systems.

Applications are capable of providing a wide variety of functions and services. Some of the functions and services provided by default may not be necessary to support essential organizational operations. Additionally, it is sometimes convenient to provide multiple services from a single component (e.g., email and web services); however, doing so increases risk over limiting the services provided by any one component.

To support the requirements and principles of least functionality, the application must support the organizational requirements providing only essential capabilities and limiting the use of protocols to only those required, authorized, and approved to conduct official business or to address authorized quality of life issues.

SQL Server using protocols deemed unsafe is open to attack through those protocols. This can allow unauthorized access to the database and through the database to other components of the information system.

Satisfies: SRG-APP-000142-DB-000094, SRG-APP-000383-DB-000364

Documentable: false

References

<http://cyber.mil/cc: CCI-000382; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

To determine the protocol(s) enabled for SQL Server, open SQL Server Configuration Manager. In the left pane, expand SQL Server Network Configuration. Click on the entry for the SQL Server instance under review: "Protocols for". The right-side pane displays the protocols enabled for the instance.



Alternatively, run the following SQL Script and review the registry_key for enabled protocols.

```
SELECT
*
FROM sys.dm_server_registry
WHERE registry_key like 'HKLM\Software\Microsoft\Microsoft SQL Server%\MSSQLServer\SuperSocketNetLib\%'
AND value_name = 'enabled'
AND value_data = 1
```

If any listed protocols are enabled but not documented and authorized, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Navigate to SQL Server Configuration Manager >> SQL Server Network Configuration >> Protocols, then right-click on each listed protocol that is enabled but not authorized and select "Disable".

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271305r1109239_rule

SQL Server must uniquely identify and authenticate users (or processes acting on behalf of organizational users).

Rule version

SQLI-22-007800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: To ensure accountability and prevent unauthenticated access, organizational users must be identified and authenticated to prevent potential misuse and compromise of the system.

Organizational users include organizational employees or individuals the organization deems to have equivalent status of employees (e.g., contractors). Organizational users (and any processes acting on behalf of users) must be uniquely identified and authenticated for all accesses, except the following:

- (i) Accesses explicitly identified and documented by the organization. Organizations document specific user actions that can be performed on the information system without identification or authentication; and
 - (ii) Accesses that occur through authorized use of group authenticators without individual authentication.
- Organizations may require unique identification of individuals using shared accounts for detailed accountability of individual activity.

Satisfies: SRG-APP-000148-DB-000103, SRG-APP-000180-DB-000115

Documentable: false

References

<http://cyber.mil/cci>: CCI-000764; <http://cyber.mil/cci>: CCI-000804; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Obtain the list of authorized SQL Server accounts in the system documentation.

Determine if any accounts are shared. A shared account is defined as a username and password that are used by multiple individuals to log in to SQL Server. Active Directory groups are not shared accounts as the group itself does not have a password.

Run the following query to return all server-level principals:

```
SELECT name
```



```
FROM sys.server_principals
WHERE type in ('U','S','E')
AND name NOT LIKE '%$'
```

If any of the returned accounts are shared, determine if individuals are first individually authenticated.

If individuals are not individually authenticated before using the shared account (e.g., by the operating system or possibly by an application making calls to the database), this is a finding.

The key is individual accountability. If this can be traced, this is not a finding.

If accounts are shared, determine if they are directly accessible to end users. If so, this is a finding.

Review contents of audit logs and data tables to confirm that the identity of the individual user performing the action is captured.

If shared identifiers are found and not accompanied by individual identifiers, this is a finding.

Execute the following query:

```
SELECT name
FROM sys.server_principals
WHERE type in ('U','S','E')
AND name LIKE '%$'
```

If users are returned, determine whether each user is a computer account.

Launch PowerShell.

Execute the following code:

Note: <name> represents the username portion of the user. For example, if the user is "CONTOSO\user1\$", the username is "user1".

```
([ADSI Searcher]"(&(ObjectCategory=Computer)(Name=<name>))").FindAll()
```

If no account information is returned, this is not a finding.

If account information is returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

***Rationale***

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove all shared accounts and computer accounts.

To remove users, run the following command for each user:

```
DROP USER [ IF EXISTS ] <user_name>;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271306r1109119_rule

Contained databases must use Windows principals.

Rule version

SQLI-22-008000

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: OS/enterprise authentication and identification must be used (SRG-APP-000023-DB-000001). Native DBMS authentication may be used only when circumstances make it unavoidable and must be documented and authorizing official (AO)-approved.

The DOD standard for authentication is DOD-approved PKI certificates. Authentication based on User ID and Password may be used only when it is not possible to employ a PKI certificate and requires AO approval.

In such cases, the DOD standards for password complexity and lifetime must be implemented. DBMS products that can inherit the rules for these from the operating system or access control program (e.g., Microsoft Active Directory) must be configured to do so. For other DBMSs, the rules must be enforced using available configuration parameters or custom code.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-004066; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Execute the following query to determine if Contained Databases are used:

```
SELECT * FROM sys.databases WHERE containment = 1
```

If any records are returned, check the server documentation for a list of authorized contained database users.

Execute the following query to ensure contained database users are not using SQL Authentication:

```
EXEC sp_MSforeachdb 'USE [?]; SELECT DB_NAME() AS DatabaseName, *  
FROM sys.database_principals dp  
inner join sys.databases d on d.name = dp.name  
WHERE dp.authentication_type = 2  
and d.containment = 1'
```



If any records are returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure SQL Server contained databases to have users originating from Microsoft Entra (Azure Active Directory) principals. Remove any users not created from Microsoft Entra principals.

Reference Contained Databases:

<https://learn.microsoft.com/en-us/sql/relational-databases/databases/contained-databases?>

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271307r1109241_rule

If DBMS authentication using passwords is employed, SQL Server must enforce the DOD standards for password complexity and lifetime.

Rule version

SQLI-22-007900

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Windows Authentication is the default authentication mode and is much more secure than SQL Server Authentication. Windows Authentication uses Kerberos security protocol, provides password policy enforcement regarding complexity validation for strong passwords, provides support for account lockout, and supports password expiration. A connection made using Windows Authentication is sometimes called a trusted connection, because SQL Server trusts the credentials provided by Windows.

By using Windows Authentication, Windows groups can be created at the domain level, and a login can be created on SQL Server for the entire group. Managing access at the domain level can simplify account administration.

OS/enterprise authentication and identification must be used (SRG-APP-000023-DB-000001). Native SQL Server authentication may be used only when circumstances make it unavoidable and must be documented and authorizing official (AO)-approved.

The DOD standard for authentication is DOD-approved PKI certificates. Authentication based on User ID and Password may be used only when it is not possible to employ a PKI certificate and requires AO approval.

In such cases, the DOD standards for password complexity and lifetime must be implemented. DBMS products that can inherit the rules for these from the operating system or access control program (e.g., Microsoft Active Directory) must be configured to do so. For other DBMSs, the rules must be enforced using available configuration parameters or custom code.

Satisfies: SRG-APP-000164-DB-000401, SRG-APP-000700-DB-000100

Documentable: false

References

<http://cyber.mil/cci>: CCI-004066; <http://cyber.mil/cci>: CCI-003627; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions



Check for use of SQL Authentication:

```
SELECT CASE SERVERPROPERTY('IsIntegratedSecurityOnly')
WHEN 1 THEN 'Windows Authentication' WHEN 0 THEN 'SQL Authentication'
END as [Authentication Mode]
```

If the returned value in the "Authentication Mode" column is "Windows Authentication", this is not a finding.

SQL Server should be configured to inherit password complexity and password lifetime rules from the operating system. Review the SQL Server Instance to ensure logons are created with respect to the complexity settings and password lifetime rules by running the following statement:

```
SELECT
[name],
is_expiration_checked,
is_policy_checked,*
FROM
sys.sql_logins
WHERE
is_disabled = 0
AND name NOT IN ('##MS_PolicyTsqlExecutionLogin##','##MS_PolicyEventProcessingLogin##')
AND sid <> 1
```

If any account does not have both "is_expiration_checked" and "is_policy_checked" equal to "1", this is a finding.
Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Ensure check of policy and expiration are enforced when SQL logins are created.

Use the command below to set CHECK_EXPIRATION and CHECK_POLICY for any login found to be noncompliant:



```
ALTER LOGIN [LoginnameHere] WITH CHECK_EXPIRATION=ON;  
ALTER LOGIN [LoginNameHere] WITH CHECK_POLICY=ON;
```

New SQL authenticated logins must be created with CHECK_EXPIRATION and CHECK_POLICY set to ON.

```
CREATE LOGIN [LoginNameHere] WITH PASSWORD = 'ComplexPasswordHere', CHECK_EXPIRATION = ON,  
CHECK_POLICY = ON;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271309r1109243_rule

If passwords are used for authentication, SQL Server must transmit only encrypted representations of passwords.

Rule version

SQLI-22-008200

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: The DOD standard for authentication is DOD-approved PKI certificates.

Authentication based on User ID and Password may be used only when it is not possible to employ a PKI certificate, and requires authorizing official (AO) approval.

In such cases, passwords need to be protected at all times, and encryption is the standard method for protecting passwords during transmission.

DBMS passwords sent in clear text format across the network are vulnerable to discovery by unauthorized users. Disclosure of passwords may easily lead to unauthorized access to the database.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000197; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If SQL Server is using "Windows Authentication mode" this requirement can be marked as Not Applicable.

Open SQL Server Configuration Manager by typing "SQL Server 2022 Configuration Manager" in the search bar and pressing "Enter".

Navigate to SQL Server Configuration Manager >> SQL Server Network Configuration. Right-click on "Protocols", where there is a placeholder for the SQL Server instance name and click on "Properties".

On the "Flags" tab, if "Force Encryption" is set to "NO", this is a finding.

On the "Flags" tab, if "Force Encryption" is set to "YES", examine the certificate used on the "Certificate" tab.

If it is not a DOD approved certificate, or if no certificate is listed, this is a finding.



For clustered instances, the Certificate will NOT be shown in the SQL Server Configuration Manager.

1. From a command prompt, navigate to the certificate store where the Full Qualified Domain Name (FQDN) certificate is stored, by typing "Manage computer certificates" in the search bar and pressing "Enter".
2. In the left side of the window, expand the "Personal" folder, and click "Certificates".
3. Verify the Certificate with the FQDN name is issued by the DOD. Double-click the certificate, click the "Details" tab, and note the value for the Thumbprint.
4. Ensure the value for the "Thumbprint" field matches the value in the registry by running regedit and looking at "HKLM\SOFTWARE\Microsoft\Microsoft SQL Server\<instance>\MSSQLServer\SuperSocketNetLib\Certificate".
5. Run this on each node of the cluster.

If any nodes have a certificate in use by SQL that is not issued or approved by DOD, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure SQL Server to encrypt authentication data for remote connections using DOD-approved cryptography.

Deploy encryption to the SQL Server Network Connections.

From the search bar, open SQL Server Configuration Manager by typing "SQL Server 2022 Configuration Manager" and pressing "ENTER".

Navigate to SQL Server Configuration Manager >> SQL Server Network Configuration. Right-click on "Protocols for", where there is a placeholder for the SQL Server instance name, and click on "Properties".

In the "Protocols for Properties" dialog box, on the "Certificate" tab, select the DOD certificate from the drop down for the Certificate box, and then click "OK". On the "Flags" tab, in the "ForceEncryption" box, select "Yes", and then click "OK" to close the dialog box. Then restart the SQL Server service.



For clustered instances install the certificate after setting "Force Encryption" to "Yes" in SQL Server Configuration Manager.

1. Navigate to the certificate store where the FQDN certificate is stored, by typing "Manage computer certificates" in the search bar and pressing "ENTER".
2. On the "Properties" page for the certificate, go to the "Details" tab and copy the "thumbprint" value of the certificate to a "Notepad" window.
3. Remove the spaces between the hex characters in the "thumbprint" value in Notepad.
4. Start regedit, navigate to the following registry key, and copy the value from step 2:
HKLM\SOFTWARE\Microsoft\Microsoft SQL Server\<instance>\MSSQLServer\SuperSocketNetLib\Certificate.
5. If the SQL virtual server is currently on this node, failover to another node in the cluster, and then reboot the node where the registry change occurred.
6. Repeat this procedure on all the nodes. Configure SQL Server to encrypt authentication data for remote connections using DOD-approved cryptography.

Deploy encryption to the SQL Server Network Connections.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271310r1111062_rule

Confidentiality of information during transmission must be controlled through the use of an approved TLS version.

Rule version

SQLI-22-008300

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Transport Layer Security (TLS) encryption is a required security setting as a number of known vulnerabilities have been reported against Secure Sockets Layer (SSL) and earlier versions of TLS. Encryption of private information is essential to ensuring data confidentiality. If private information is not encrypted, it can be intercepted and easily read by an unauthorized party. SQL Server must use a FIPS-approved minimum TLS version 1.2, and all non-FIPS-approved SSL and TLS versions must be disabled. NIST SP 800-52 Rev. 2 specifies the preferred configurations for government systems.

References:

TLS Support 1.2 for SQL Server: <https://support.microsoft.com/en-us/kb/3135244>

TLS Registry Settings: <https://docs.microsoft.com/en-us/windows-server/security/tls/tls-registry-settings>

Documentable: false

References

<http://cyber.mil/cci>: CCI-000197; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Access the SQL Server.

Access an administrator command prompt.

Type "regedit" to launch the Registry Editor.

Navigate to:

HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2

If this key does not exist, this is a finding.

Verify a REG_DWORD value of "0" for "DisabledByDefault" and a value of "1" for "Enabled" for both Client and Server.

Navigate to:



HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0

Under each key, verify a REG_DWORD value of "1" for "DisabledByDefault" and a value of "0" for "Enabled" for both Client and Server subkeys.

If any of the respective registry paths are non-existent or contain values other than specified above, this is a finding. If Vendor documentation supporting the configuration is provided, reduce this finding to a CAT III. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Important Note: Incorrectly modifying the Windows Registry can result in serious system errors. Before making any modifications, ensure there is a recent backup of the system and registry settings.

Access the SQL Server.

Access an administrator command prompt.

Type "regedit" to launch the Registry Editor.

Enable TLS 1.2:

1. Navigate to the path HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols.
 - a. If the "TLS 1.2" key does not exist, right-click "Protocols".
 - b. Click "New".
 - c. Click "Key".
 - d. Type the name "TLS 1.2".
2. Navigate to the "TLS 1.2" subkey.



- a. If the subkey "Client" does not exist, right-click "TLS 1.2".
 - b. Click "New".
 - c. Click "Key".
 - d. Type the name "Client".
 - e. Repeat steps A-D for the "Server" subkey.
3. Navigate to the "Client" subkey.
 - a. If the value "Enabled" does not exist, right-click on "Client".
 - b. Click "New".
 - c. Click "DWORD".
 - d. Enter "Enabled" as the name.
 - e. Repeat steps A-D for the value "DisabledByDefault".
 4. Double-click "Enabled".
 5. In Value Data, enter "1".
 6. Click "OK".
 7. Double-click "DisabledByDefault".
 8. In Value Data, enter "0".
 9. Click "OK".
 10. Repeat steps 3-9 for the "Server" subkey.

Disable unwanted SSL/TLS protocol versions:

1. Navigate to the path HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols.
 - a. If the "TLS 1.0" key does not exist, right-click "Protocols".
 - b. Click "New".
 - c. Click "Key".
 - d. Type the name "TLS 1.0".
2. Navigate to the "TLS 1.0" subkey.
 - a. If the subkey "Client" does not exist, right-click "TLS 1.0".
 - b. Click "New".
 - c. Click "Key".
 - d. Type the name "Client".
 - e. Repeat steps A-D for the "Server" subkey.
3. Navigate to the "Client" subkey.
 - a. If the value "Enabled" does not exist, right-click on "Client".
 - b. Click "New".
 - c. Click "DWORD".
 - d. Enter "Enabled" as the name.
 - e. Repeat steps A-D for the value "DisabledByDefault".
4. Double-click "Enabled".



5. In Value Data, enter "0".
6. Click "OK".
7. Double-click "DisabledByDefault".
8. In Value Data, enter "1".
9. Click "OK".
10. Repeat steps 3-9 for the "Server" subkey.
11. Repeat steps 1-10 for "TLS 1.1", "SSL 2.0", and "SSL 3.0".

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271313r1111146_rule

When using command-line tools such as SQLCMD in a mixed-mode authentication environment, users must use a logon method that does not expose the password.

Rule version

SQLI-22-018100

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: To prevent the compromise of authentication information, such as passwords and PINs, during the authentication process, the feedback from the information system must not provide any information that would allow an unauthorized user to compromise the authentication mechanism.

Obfuscation of user-provided information when typed into the system is a method used in addressing this risk.

For example, displaying asterisks when a user types in a password or PIN is an example of obscuring feedback of authentication information.

This requirement is applicable when mixed-mode authentication is enabled. When this is the case, password-authenticated accounts can be created in and authenticated by SQL Server. Other STIG requirements prohibit the use of mixed-mode authentication except when justified and approved. This deals with the exceptions.

SQLCMD and other command-line tools are part of any SQL Server installation. These tools can accept a plain text password but do offer alternative techniques. Since the typical user of these tools is a database administrator, the consequences of password compromise are particularly serious. Therefore, the use of plain-text passwords must be prohibited, as a matter of practice and procedure.

Documentable: false

References

<http://cyber.mil/ccci>: CCI-000206; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Run this query to determine whether SQL Server authentication is enabled:
EXEC master.sys.xp_loginconfig 'login mode';

If the config_value returned is "Windows NT Authentication", this is not a finding.



For SQLCMD, which cannot be configured not to accept a plain-text password, and any other essential tool with the same limitation, verify that the system documentation explains the need for the tool, who uses it, and any relevant mitigations; and that authorizing approval (AO) approval has been obtained; if not, this is a finding.

Request evidence that all users of the tool are trained on the importance of not using the plain-text password option, how to keep the password hidden, and that they adhere to this practice; if not, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Where possible, change the login mode to Windows-only:

```
USE [master]
```

```
GO
```

```
EXEC xp_instance_regwrite N'HKEY_LOCAL_MACHINE', N'Software\Microsoft\MSSQLServer\MSSQLServer',  
N'LoginMode', REG_DWORD, 1;
```

```
GO
```

If mixed-mode authentication is necessary, then for SQLCMD, which cannot be configured not to accept a plain-text password when mixed-mode authentication is enabled, and any other essential tool with the same limitation:

1. Document the need for it, who uses it, and any relevant mitigations, and obtain AO approval.
2. Train all users of the tool in the importance of not using the plain-text password option and in how to keep the password hidden.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271314r1109121_rule

SQL Server must use NIST FIPS 140-2 or 140-3 validated cryptographic operations for encryption, hashing, and signing.

Rule version

SQLI-22-008700

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Use of weak or not validated cryptographic algorithms undermines the purposes of using encryption and digital signatures to protect data. Weak algorithms can be easily broken, and not validated cryptographic modules may not implement algorithms correctly. Unapproved cryptographic modules or algorithms should not be relied on for authentication, confidentiality, or integrity. Weak cryptography could allow an attacker to gain access to, and modify data stored in, the database as well as the administration settings of SQL Server.

Applications, including DBMSs, using cryptography are required to use approved NIST FIPS 140-2 or 140-3 validated cryptographic modules that meet the requirements of applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

NSA Type- (where =1, 2, 3, 4) products are NSA-certified, hardware-based encryption modules.

The standard for validating cryptographic modules will transition to the NIST FIPS 140-3 publication.

FIPS 140-2 modules can remain active for up to five years after validation or until September 21, 2026, when the FIPS 140-2 validations will be moved to the historical list. Even on the historical list, CMVP supports the purchase and use of these modules for existing systems. While Federal Agencies decide when they move to FIPS 140-3 only modules, purchasers are reminded that for several years there may be a limited selection of FIPS 140-3 modules from which to choose. CMVP recommends purchasers consider all modules that appear on the Validated Modules Search Page:

<https://csrc.nist.gov/projects/cryptographic-module-validation-program/validated-modules>

More information on the FIPS 140-3 transition can be found here:

<https://csrc.nist.gov/Projects/fips-140-3-transition-effort/>.

Satisfies: SRG-APP-000179-DB-000114, SRG-APP-000176-DB-000068, SRG-APP-000224-DB-000384, SRG-APP-000514-DB-000381, SRG-APP-000514-DB-000382, SRG-APP-000514-DB-000383

Documentable: false

References



<http://cyber.mil/cci: CCI-000803>; <http://cyber.mil/cci: CCI-000186>; <http://cyber.mil/cci: CCI-001188>;
<http://cyber.mil/cci: CCI-002450>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Verify that Windows is configured to require the use of FIPS compliant algorithms.

1. Click "Start".
2. Type "Local Security Policy".
3. Press "Enter".
4. Expand "Local Policies".
5. Select "Security Options".
6. Review the Security Setting for "System Cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing".

If the Security Setting for this option is "Disabled", this is a finding.

Alternatively, run the following code in PowerShell:

```
Get-ItemProperty -Path HKLM:\SYSTEM\CurrentControlSet\Control\Lsa\FipsAlgorithmPolicy | Select Enabled
```

If the returned value is "0", this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure Windows to require the use of FIPS compliant algorithms for the unclassified information that requires it.

1. Click "Start".
2. Type "Local Security Policy".
3. Press "Enter".



4. Expand "Local Policies".
5. Select "Security Options".
6. Locate "System Cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing".
7. Change the Setting option to "Enabled".
8. Restart Windows.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271322r1108582_rule

The Master Key must be backed up and stored in a secure location that is not on the SQL Server.

Rule version

SQLI-22-009700

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Backup and recovery of the Master Key may be critical to the complete recovery of the database. Not having this key can lead to loss of data during recovery.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001199; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If the application owner and authorizing official have determined that encryption of data at rest is not required, this is not a finding.

Review procedures for and evidence of backup of the Master Key in the System Security Plan.

If the procedures or evidence does not exist, this is a finding.

If the procedures do not indicate that a backup of the Master Key is stored in a secure location that is not on the SQL Server, this is a finding.

If procedures do not indicate access restrictions to the Master Key backup, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer



Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Document and implement procedures to safely back up and store the Master Key in a secure location that is not on the SQL Server. Include in the procedures methods to establish evidence of backup and storage, and careful, restricted access and restoration of the Master Key.

```
BACKUP MASTER KEY TO FILE = 'path_to_file'  
ENCRYPTION BY PASSWORD = 'password';
```

As this requires a password, take care to ensure it is not exposed to unauthorized persons or stored as plain text.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271323r1108585_rule

The Service Master Key must be backed up and stored in a secure location that is not on the SQL Server.

Rule version

SQLI-22-009600

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Backup and recovery of the Service Master Key may be critical to the complete recovery of the database. Creating this backup should be one of the first administrative actions performed on the server. Not having this key can lead to loss of data during recovery.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001199; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review procedures for and evidence of backup of the Server Service Master Key in the System Security Plan.

If the procedures or evidence does not exist, this is a finding.

If the procedures do not indicate that a backup of the Service Master Key is stored in a secure location that is not on the SQL Server, this is a finding.

If procedures do not indicate access restrictions to the Service Master Key backup, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned



Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Document and implement procedures to safely back up and store the Service Master Key in a secure location that is not on the SQL Server. In the procedures, include methods to establish evidence of backup and storage, and careful, restricted access and restoration of the Service Master Key.

```
BACKUP SERVICE MASTER KEY TO FILE = 'path_to_file'  
ENCRYPTION BY PASSWORD = 'password';
```

As this requires a password, take care to ensure it is not exposed to unauthorized persons or stored as plain text.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271324r1192911_rule

SQL Server must protect the confidentiality and integrity of all information at rest.

Rule version

SQLI-22-009500

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: This control is intended to address the confidentiality and integrity of information at rest in nonmobile devices and covers user information and system information. Information at rest refers to the state of information when it is located on a secondary storage device (e.g., disk drive, tape drive) within an organizational information system. Applications and application users generate information throughout the course of their application use.

User data generated, as well as application-specific configuration data, needs to be protected. Organizations may choose to employ different mechanisms to achieve confidentiality and integrity protections, as appropriate.

If the confidentiality and integrity of SQL Server data is not protected, the data will be open to compromise and unauthorized modification.

Documentable: false

References

<http://cyber.mil/ccr: CCI-001199; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

Review system documentation to determine whether the system handles classified information. If the system does not handle classified information, the severity of this check is downgraded to CAT II.

If the application owner and authorizing official (AO) have determined that encryption of data at rest is required, verify the data on secondary devices is encrypted.

If full-disk encryption is being used, this is not a finding.

If data encryption is required, verify the data is encrypted before being put on the secondary device by executing the following:

```
SELECT  
db.name AS DatabaseName,
```



```
db.is_encrypted AS IsEncrypted,  
CASE  
WHEN dm.encryption_state = 0 THEN 'No database encryption key present, no encryption'  
WHEN dm.encryption_state = 1 THEN 'Unencrypted'  
WHEN dm.encryption_state = 2 THEN 'Encryption in progress'  
WHEN dm.encryption_state = 3 THEN 'Encrypted'  
WHEN dm.encryption_state = 4 THEN 'Key change in progress'  
WHEN dm.encryption_state = 5 THEN 'Decryption in progress'  
WHEN dm.encryption_state = 6 THEN 'Protection change in progress'  
END AS EncryptionState,  
dm.encryption_state AS EncryptionState,  
dm.key_algorithm AS KeyAlgorithm,  
dm.key_length AS KeyLength  
FROM  
sys.databases db  
LEFT JOIN sys.dm_database_encryption_keys dm ON db.database_id = dm.database_id  
WHERE db.database_id > 4  
ORDER BY [DatabaseName] ;
```

For each user database where encryption is required, verify encryption is in effect. If it is not, this is a finding.

Verify there are physical security measures, operating system access control lists, and organizational controls appropriate to the sensitivity level of the data in the database(s); if not, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Apply appropriate controls to protect the confidentiality and integrity of data on a secondary device. Where encryption is required, this can be done by full-disk encryption or by database encryption.



To enable database encryption, create a master key, create a database encryption key, protect it by using mechanisms tied to the master key, and then turn encryption on.

Implement physical security measures, operating system access control lists, and organizational controls appropriate to the sensitivity level of the data in the database(s).

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271327r1137657_rule

SQL Server must prevent unauthorized and unintended information transfer via Instant File Initialization (IFI).

Rule version

SQLI-22-009900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: The purpose of this control is to prevent information, including encrypted representations of information, produced by the actions of a prior user/role (or the actions of a process acting on behalf of a prior user/role) from being available to any current user/role (or current process) that obtains access to a shared system resource (e.g., registers, main memory, secondary storage) after the resource has been released back to the information system. Control of information in shared resources is also referred to as object reuse.

When IFI is in use, the deleted disk content is overwritten only as new data is written to the files. For this reason, the deleted content might be accessed by an unauthorized principal until some other data writes on that specific area of the data file.

Historically, transaction log files couldn't be initialized instantaneously. However, starting with SQL Server 2022 (16.x) (all editions), transaction log autogrowth events up to 64 MB can benefit from instant file initialization. The default auto growth size increment for new databases is 64 MB. Transaction log file autogrowth events larger than 64 MB can't benefit from instant file initialization.

Instant file initialization is allowed for transaction log growth on databases that have transparent data encryption (TDE) enabled, due to the nature of how the transaction log file is expanded, and the fact that the transaction log is written into in a serial fashion.

Documentable: false

References

<http://cyber.mil/ccr:CCI-001090>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review system configuration to determine whether IFI support has been enabled (IFI is enabled by default).

Run the following query in SSMS:

```
SELECT
```



```
servicename  
,instant_file_initialization_enabled  
FROM sys.dm_server_services
```

If the column `instant_file_initialization_enabled` returns a value of "Y", then IFI is enabled.

Alternatively, navigate to Start >> Control Panel >> System and Security >> Administrative Tools >> Local Security Policy >> Local Policies >> User Rights Assignment >> Perform volume maintenance tasks.

The default SQL service account for a default instance is NT SERVICE\MSSQLSERVER or for a named instance is NT SERVICE\MSSQL\$InstanceName.

If the SQL service account or SQL service SID has been granted "Perform volume maintenance tasks" Local Rights Assignment, this means that IFI is enabled.

Review the system documentation to determine if IFI is required.

If IFI is enabled but not documented as required, this is a finding.

If IFI is not enabled, this is not a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

If IFI is not documented as being required, disable instant file initialization for the instance of SQL Server by removing the SQL Service SID and/or service account from the "Perform volume maintenance tasks" local rights assignment.

To grant an account the "Perform volume maintenance tasks" permission:

1. On the computer where the data file will be created, open the Local Security Policy application (secpol.msc).
2. In the left pane, expand "Local Policies" then select "User Rights Assignment".



3. In the right pane, double-click "Perform volume maintenance tasks".
4. Select "Add User or Group" and add the SQL Server service account.
5. Select "Apply", then close all Local Security Policy dialog boxes.
6. Restart the SQL Server service.
7. Check the SQL Server error log at startup.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271328r1137657_rule

SQL Server must prevent unauthorized and unintended information transfer via shared system resources.

Rule version

SQLI-22-009800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: The purpose of this control is to prevent information, including encrypted representations of information, produced by the actions of a prior user/role (or the actions of a process acting on behalf of a prior user/role) from being available to any current user/role (or current process) that obtains access to a shared system resource (e.g., registers, main memory, secondary storage) after the resource has been released back to the information system. Control of information in shared resources is also referred to as object reuse.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001090; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review system documentation to determine whether common criteria compliance is required due to potential impact on system performance.

SQL Server Residual Information Protection (RIP) requires a memory allocation to be overwritten with a known pattern of bits before memory is reallocated to a new resource. Meeting the RIP standard can contribute to improved security; however, overwriting the memory allocation can slow performance. After the common criteria compliance enabled option is enabled, the overwriting occurs.

Review the Instance configuration:

```
SELECT value_in_use
FROM sys.configurations
WHERE name = 'common criteria compliance enabled'
```

If "value_in_use" is set to "1" this is not a finding.

If "value_in_use" is set to "0" this is a finding.



If no results are returned, common criteria compliance is not available in the installed version of SQL Server, this is a finding. Common criteria compliance is only supported in Enterprise and Developer editions of SQL Server.

Note: Enabling this feature may impact performance on highly active SQL Server instances. If an exception justifying setting SQL Server RIP to disabled (value_in_use set to "0") has been documented and approved, then this is downgraded to a CAT III finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure SQL Server to effectively protect the private resources of one process or user from unauthorized access by another process or user.

To enable the use of [Common Criteria Compliance], from the query prompt:

```
EXEC SP_CONFIGURE 'show advanced options', 1;  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'common criteria compliance enabled', 1;  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'show advanced options', 0;  
RECONFIGURE WITH OVERRIDE;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271329r1137658_rule

Access to database files must be limited to relevant processes and to authorized, administrative users.

Rule version

SQLI-22-010000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Applications, including SQL Server, must prevent unauthorized and unintended information transfer via shared system resources. Permitting only DBMS processes and authorized, administrative users to have access to the files where the database resides helps ensure that those files are not shared inappropriately and are not open to backdoor access and manipulation.

Documentable: false

References

<http://cyber.mil/ccr:CCI-001090>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the permissions granted to users by the operating system/file system on the database files, database log files, and database backup files.

To obtain the location of SQL Server data, transaction log, and backup files, open and execute the supplemental file "Get SQL Data and Backup Directories.sql".

For each of the directories returned by the above script, verify whether the correct permissions have been applied.

1. Launch Windows Explorer.
2. Navigate to the folder.
3. Right-click the folder and click "Properties".
4. Navigate to the "Security" tab.
5. Review the listing of principals and permissions.

Account Type Directory Type Permission

Database Administrators ALL Full Control
SQL Server Service SID Data; Log; Backup; Full Control
SQL Server Agent Service SID Backup Full Control



SYSTEM ALL Full Control
CREATOR OWNER ALL Full Control

For information on how to determine a "Service SID", refer to <https://aka.ms/sql-service-sids>.

Additional permission requirements, including full directory permissions and operating system rights for SQL Server, are documented at <https://aka.ms/sqlservicepermissions>.

If any additional permissions are granted but not documented as authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove any unauthorized permission grants from SQL Server data, log, and backup directories.

1. On the "Security" tab, highlight the user entry.
2. Click "Remove".

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271331r1108609_rule

SQL Server and associated applications must reserve the use of dynamic code execution for situations that require it.

Rule version

SQLI-22-010010

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: With respect to database management systems, one class of threat is known as SQL Injection, or more generally, code injection. It takes advantage of the dynamic execution capabilities of various programming languages, including dialects of SQL. In such cases, the attacker deduces the manner in which SQL statements are being processed, either from inside knowledge or by observing system behavior in response to invalid inputs. When the attacker identifies scenarios where SQL queries are being assembled by application code (which may be within the database or separate from it) and executed dynamically, the attacker is then able to craft input strings that subvert the intent of the query. Potentially, the attacker can gain unauthorized access to data, including security settings, and severely corrupt or destroy the database.

The principal protection against code injection is not to use dynamic execution except where it provides necessary functionality that cannot be used otherwise. Use strongly typed data items rather than general-purpose strings as input parameters to task-specific, precompiled stored procedures and functions (and triggers).

This calls for inspection of application source code, which will require collaboration with the application developers. It is recognized that in many cases, the database administrator (DBA) is organizationally separate from the application developers, and may have limited, if any, access to source code. Nevertheless, protections of this type are so important to the secure operation of databases that they must not be ignored. At a minimum, the DBA must attempt to obtain assurances from the development organization that this issue has been addressed and must document what has been discovered.

Documentable: false

References

<http://cyber.mil/ccr:CCI-001310>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review DBMS source code (stored procedures, functions, triggers) and application source code, to identify cases of dynamic code execution.

If dynamic code execution is employed in circumstances where the objective could practically be satisfied by static



execution with strongly typed parameters, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Where dynamic code execution is employed in circumstances where the objective could practically be satisfied by static execution with strongly typed parameters, modify the code to do so.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271332r1108612_rule

SQL Server and associated applications, when making use of dynamic code execution, must scan input data for invalid values that may indicate a code injection attack.

Rule version

SQLI-22-010020

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: With respect to database management systems, one class of threat is known as SQL Injection, or more generally, code injection. It takes advantage of the dynamic execution capabilities of various programming languages, including dialects of SQL. In such cases, the attacker deduces the manner in which SQL statements are being processed, either from inside knowledge or by observing system behavior in response to invalid inputs. When the attacker identifies scenarios where SQL queries are being assembled by application code (which may be within the database or separate from it) and executed dynamically, the attacker is then able to craft input strings that subvert the intent of the query. Potentially, the attacker can gain unauthorized access to data, including security settings, and severely corrupt or destroy the database.

The principal protection against code injection is not to use dynamic execution except where it provides necessary functionality that cannot be used otherwise. Use strongly typed data items rather than general-purpose strings as input parameters to task-specific, precompiled stored procedures and functions (and triggers).

When dynamic execution is necessary, ways to mitigate the risk include the following, which should be implemented both in the on-screen application and at the database level, in the stored procedures:

- Allow strings as input only when necessary.
- Rely on data typing to validate numbers, dates, etc. Do not accept invalid values. If substituting other values for them, think carefully about whether this could be subverted.
- Limit the size of input strings to what is truly necessary.
- If single quotes/apostrophes, double quotes, semicolons, equals signs, angle brackets, or square brackets will never be valid as input, reject them.
- If comment markers will never be valid as input, reject them. In SQL, these are -- or /* */
- If HTML and XML tags, entities, comments, etc., will never be valid, reject them.
- If wildcards are present, reject them unless truly necessary. In SQL these are the underscore and the percentage sign, and the word ESCAPE is also a clue that wildcards are in use.
- If SQL key words, such as SELECT, INSERT, UPDATE, DELETE, CREATE, ALTER, DROP, ESCAPE, UNION, GRANT, REVOKE, DENY, MODIFY will never be valid, reject them. Use case-insensitive comparisons when searching for these. Bear in mind that some of these words, particularly Grant (as a person's name), could also be valid input.
- If there are range limits on the values that may be entered, enforce those limits.
- Institute procedures for inspection of programs for correct use of dynamic coding, by a party other than the



developer.

- Conduct rigorous testing of program modules that use dynamic coding, searching for ways to subvert the intended use.
- Record the inspection and testing in the system documentation.
- Bear in mind that all this applies not only to screen input, but also to the values in an incoming message to a web service or to a stored procedure called by a software component that has not itself been hardened in these ways. Not only can the caller be subject to such vulnerabilities; it may itself be the attacker.

This calls for inspection of application source code, which will require collaboration with the application developers. It is recognized that in many cases, the database administrator (DBA) is organizationally separate from the application developers, and may have limited, if any, access to source code. Nevertheless, protections of this type are so important to the secure operation of databases that they must not be ignored. At a minimum, the DBA must attempt to obtain assurances from the development organization that this issue has been addressed and must document what has been discovered.

Documentable: false

References

<http://cyber.mil/ccr: CCI-001310; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

Review DBMS source code (stored procedures, functions, triggers) and application source code to identify cases of dynamic code execution.

If dynamic code execution is employed without protective measures against code injection, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance



Where dynamic code execution is used, modify the code to implement protections against code injection.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271334r1109125_rule

SQL Server must reveal detailed error messages only to documented and approved individuals or roles.

Rule version

SQLI-22-010100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If SQL Server provides too much information in error logs and administrative messages to the screen, this could lead to compromise. The structure and content of error messages need to be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Some default DBMS error messages can contain information that could aid an attacker in, among other things, identifying the database type, host address, or state of the database. Custom errors may contain sensitive customer information.

It is important that detailed error messages be visible only to those who are authorized to view them; that general users receive only generalized acknowledgment that errors have occurred; and that these generalized messages appear only when relevant to the user's task. For example, a message along the lines of, "An error has occurred. Unable to save your changes. If this problem persists, please contact your help desk." would be relevant. A message such as "Warning: your transaction generated a large number of page splits" would likely not be relevant. "ABGQ is not a valid widget code." would be appropriate; but "The INSERT statement conflicted with the FOREIGN KEY constraint "WidgetTransactionFK". The conflict occurred in database "DB7", table "dbo.WidgetMaster", column "WidgetCode"" would not, as it reveals too much about the database structure.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001314; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Error messages within applications, custom database code (stored procedures, triggers) must be enforced by guidelines and code review practices.

SQL Server generates certain system events and user-defined events to the SQL Server error log. The SQL Server error log can be viewed using SQL Server Management Studio GUI. All users granted the security admin or sysadmin level of permission are able to view the logs. Review the users returned in the following script:



```
USE master
GO
SELECT Name
FROM syslogins
WHERE (sysadmin = 1 or securityadmin = 1)
and hasaccess = 1;
```

If any nonauthorized users have access to the SQL Server Error Log located at Program Files\Microsoft SQL Server\MSSQL.n\MSSQL\LOG, this is a finding.

In addition, the SQL Server Error Log is also located at Program Files\Microsoft SQL Server\MSSQL.n\MSSQL\LOG*. Review the permissions on this folder to ensure that only authorized users are listed.

If any nonauthorized users have access to the SQL Server Error Log in SQL Server Management Studio or if documentation does not exist stating that full error messages must be returned, this is a finding.

Otherwise, verify if trace flag 3625 is enabled to mask certain system-level error information returned to nonadministrative users.

Launch SQL Server Configuration Manager >> select SQL Server Services >> select the SQL Server >> right-click and select Properties >> select Startup Parameters tab >> verify -T3625 exists in the dialogue window.

OR

Run the query:
DBCC TRACESTATUS;

If TraceFlag 3625 does not return with Status = 1, and if documentation does not exist stating that full error messages must be returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation



Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure audit logging, tracing, and/or custom code in the database or application to record detailed error messages generated by SQL Server for review by authorized personnel.

If any nonauthorized users have access to the SQL Server Error Log in SQL Server Management Studio, use the REVOKE or DENY commands to remove them from the security admin or sysadmin roles.

If any nonauthorized users have access to the SQL Server Error Log located at Program Files\Microsoft SQL Server\MSSQL.n\MSSQL\LOG, remove their permissions.

Consider enabling trace flag 3625 to mask certain system-level error information returned to nonadministrative users.

Configure audit logging, tracing and/or custom code in the database or application to record detailed error messages generated by SQL Server, for review by authorized personnel.

If any nonauthorized users have access to the SQL Server Error Log in SQL Server Management Studio, use the REVOKE or DENY commands to remove them from the security admin or sysadmin roles.

If any nonauthorized users have access to the SQL Server Error Log located at Program Files\Microsoft SQL Server\MSSQL.n\MSSQL\LOG, remove their permissions.

Enable trace flag 3625 to mask certain system-level error information returned to nonadministrative users.

To launch SQL Server Configuration Manager, select SQL Server Services, select the SQL Server, then right-click and select "Properties". Select the "Startup Parameters" tab, enter "-T3625", and then click "Add". Click "OK", then restart SQL instance.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271341r1111081_rule

SQL Server must prevent nonprivileged users from executing privileged functions, to include disabling, circumventing, or altering implemented security safeguards/countermeasures.

Rule version

SQLI-22-010400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Preventing nonprivileged users from executing privileged functions mitigates the risk that unauthorized individuals or processes may gain unnecessary access to information or privileges.

System documentation should include a definition of the functionality considered privileged.

Depending on circumstances, privileged functions can include, for example, establishing accounts, performing system integrity checks, or administering cryptographic key management activities. Nonprivileged users are individuals that do not possess appropriate authorizations. Circumventing intrusion detection and prevention mechanisms or malicious code protection mechanisms are examples of privileged functions that require protection from nonprivileged users.

A privileged function in SQL Server/database context is any operation that modifies the structure of the database, its built-in logic, or its security settings. This would include all Data Definition Language (DDL) statements and all security-related statements. In an SQL environment, it encompasses, but is not necessarily limited to:

CREATE
ALTER
DROP
GRANT
REVOKE
DENY

There may also be Data Manipulation Language (DML) statements that, subject to context, should be regarded as privileged. Possible examples include:

TRUNCATE TABLE;
DELETE, or
DELETE affecting more than n rows, for some n, or
DELETE without a WHERE clause;

UPDATE or
UPDATE affecting more than n rows, for some n, or
UPDATE without a WHERE clause;



Any SELECT, INSERT, UPDATE, or DELETE to an application-defined security table executed by other than a security principal.

Depending on the capabilities of SQL Server and the design of the database and associated applications, the prevention of unauthorized use of privileged functions may be achieved by means of DBMS security features, database triggers, other mechanisms, or a combination of these.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002235; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review server-level securables and built-in role membership to ensure only authorized users have privileged access and the ability to create server-level objects and grant permissions to themselves or others.

Review the system documentation to determine the required levels of protection for DBMS server securables by type of login.

Review the permissions in place on the server. If the actual permissions do not match the documented requirements, this is a finding.

Get all permission assignments to logins and roles:

```
SELECT DISTINCT
CASE
WHEN SP.class_desc IS NOT NULL THEN
CASE
WHEN SP.class_desc = 'SERVER' AND S.is_linked = 0 THEN 'SERVER'
WHEN SP.class_desc = 'SERVER' AND S.is_linked = 1 THEN 'SERVER (linked)'
ELSE SP.class_desc
END
WHEN E.name IS NOT NULL THEN 'ENDPOINT'
WHEN S.name IS NOT NULL AND S.is_linked = 0 THEN 'SERVER'
WHEN S.name IS NOT NULL AND S.is_linked = 1 THEN 'SERVER (linked)'
WHEN P.name IS NOT NULL THEN 'SERVER_PRINCIPAL'
ELSE '???'
END AS [Securable Class],
CASE
WHEN E.name IS NOT NULL THEN E.name
WHEN S.name IS NOT NULL THEN S.name
WHEN P.name IS NOT NULL THEN P.name
ELSE '???'
END AS [Securable],
P1.name AS [Grantee],
P1.type_desc AS [Grantee Type],
sp.permission_name AS [Permission],
sp.state_desc AS [State],
```



```
P2.name AS [Grantor],
P2.type_desc AS [Grantor Type]
FROM
sys.server_permissions SP
INNER JOIN sys.server_principals P1
ON P1.principal_id = SP.grantee_principal_id
INNER JOIN sys.server_principals P2
ON P2.principal_id = SP.grantor_principal_id
```

```
FULL OUTER JOIN sys.servers S
ON SP.class_desc = 'SERVER'
AND S.server_id = SP.major_id
```

```
FULL OUTER JOIN sys.endpoints E
ON SP.class_desc = 'ENDPOINT'
AND E.endpoint_id = SP.major_id
```

```
FULL OUTER JOIN sys.server_principals P
ON SP.class_desc = 'SERVER_PRINCIPAL'
AND P.principal_id = SP.major_id
```

Get all server role memberships:

```
SELECT
R.name AS [Role],
M.name AS [Member]
FROM
sys.server_role_members X
INNER JOIN sys.server_principals R ON R.principal_id = X.role_principal_id
INNER JOIN sys.server_principals M ON M.principal_id = X.member_principal_id
```

The CONTROL SERVER permission is similar but not identical to the sysadmin fixed server role. Permissions do not imply role memberships, and role memberships do not grant permissions (e.g., CONTROL SERVER does not imply membership in the sysadmin fixed server role).

Ensure only the documented and approved logins have privileged functions in SQL Server.

If the current configuration does not match the documented baseline, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

***Rationale***

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Restrict the granting of permissions to server-level securables to only those authorized, most notably: members of sysadmin and securityadmin built-in instance-level roles, CONTROL SERVER permission, and use of the GRANT with GRANT permission.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271342r1108642_rule

Use of credentials and proxies must be restricted to necessary cases only.

Rule version

SQLI-22-010500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: In certain situations, to provide required functionality, a DBMS needs to execute internal logic (stored procedures, functions, triggers, etc.) and/or external code modules with elevated privileges. However, if the privileges required for execution are at a higher level than the privileges assigned to organizational users invoking the functionality applications/programs, those users are indirectly provided with greater privileges than assigned by organizations.

Privilege elevation must be used only where necessary and protected from misuse.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002233; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the server documentation to obtain a listing of accounts used for executing external processes. Execute the following to obtain a listing of accounts currently configured for use by external processes.

```
SELECT C.name AS credential_name, C.credential_identity
FROM sys.credentials C
GO
```

```
SELECT P.name AS proxy_name, C.name AS credential_name, C.credential_identity
FROM sys.credentials C
JOIN msdb.dbo.sysproxies P ON C.credential_id = P.credential_id
WHERE P.enabled = 1
GO
```

If any Credentials or SQL Agent Proxy accounts are returned that are not documented and authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence



Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove any SQL Agent Proxy accounts and credentials that are not authorized.

```
DROP CREDENTIAL <Credential Name>  
GO
```

```
USE [msdb]  
EXEC sp_delete_proxy @proxy_name = '<Proxy Name>'  
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271343r1108645_rule

SQL Server must allocate audit record storage capacity in accordance with organization-defined audit record storage requirements.

Rule version

SQLI-22-010900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Organizations are required to use a central log management system, so, under normal conditions, the audit space allocated to SQL Server on its own server will not be an issue. However, space will still be required on the server for SQL Server Audit records in transit, and, under abnormal conditions, this could fill up. Since a requirement exists to halt processing upon audit failure, a service outage would result.

If support personnel are not notified immediately upon storage volume utilization reaching 75 percent, they are unable to plan for storage capacity expansion.

The appropriate support staff include, at a minimum, the information system security officer (ISSO), the database administrator (DBA), and system administrator (SA).

Monitoring of free space can be accomplished using Microsoft System Center or a third-party monitoring tool.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001849; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If the database is setup to write audit logs using APPLICATION or SECURITY event logs rather than writing to a file, this is Not Applicable.

Check the server documentation for the SQL Audit file size configurations. Locate the Audit file path and drive.

```
SELECT max_file_size, max_rollover_files, log_file_path AS "Audit Path"
FROM sys.server_file_audits
```

Calculate the space needed as the maximum file size and number of files from the SQL Audit File properties.

If the calculated product of the "max_file_size" times the "max_rollover_files" exceeds the size of the storage



location, this is a finding;

OR if "max_file_size" is set to "0" (Unlimited), this is a finding;

OR if "max_rollover_files" are set to "0" (None) or "2147483647" (Unlimited), this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Review the SQL Audit file location; ensure the destination has enough space available to accommodate the maximum total size of all files that could be written.

Configure the maximum number of audit log files that are to be generated, staying within the number of logs the system was sized to support.

Update the "max_files" or "max_rollover_files" parameter of the audits to ensure the correct number of files is defined.

If writing to application event logs or security logs, space considerations are covered in the Windows Server STIGs. Be sure to reference these depending on the OS in use.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271344r1111082_rule

SQL Server must provide a warning to appropriate support staff when allocated audit record storage volume reaches 75 percent of maximum audit record storage capacity.

Rule version

SQLI-22-011000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Organizations are required to use a central log management system, so, under normal conditions, the audit space allocated to SQL Server on its own server will not be an issue. However, space will still be required on the server for SQL Server Audit records in transit, and, under abnormal conditions, this could fill up. Since a requirement exists to halt processing upon audit failure, a service outage would result.

If support personnel are not notified immediately upon storage volume utilization reaching 75 percent, they are unable to plan for storage capacity expansion.

The appropriate support staff include, at a minimum, the information system security officer (ISSO), the database administrator (DBA), and the system administrator (SA).

Monitoring of free space can be accomplished using Microsoft System Center or a third-party monitoring tool.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001855; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

The operating system and SQL Server offer a number of methods for checking the drive or volume free space. Locate the destination drive where SQL Audits are stored and review system configuration.

If no alert exists to notify support staff in the event the SQL Audit drive reaches 75 percent, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

**Observed at**

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Use operating system alerting mechanisms, SQL Agent, Operations Management tools, and/or third-party tools to configure the system to notify appropriate support staff immediately upon storage volume utilization reaching 75 percent.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271345r1109254_rule

SQL Server must provide an immediate real-time alert to appropriate support staff of all audit log failures.

Rule version

SQLI-22-011100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: It is critical for the appropriate personnel to be aware if a system is at risk of failing to process audit logs as required. Without a real-time alert, security personnel may be unaware of an impending failure of the audit capability, and system operation may be adversely affected.

The appropriate support staff include, at a minimum, the information system security officer (ISSO), the database administrator (DBA), and the system administrator (SA).

A failure of database auditing will result in either the database continuing to function without auditing or in a complete halt to database operations. When audit processing fails, appropriate personnel must be alerted immediately to avoid further downtime or unaudited transactions.

Alerts provide organizations with urgent messages. Real-time alerts provide these messages immediately (i.e., the time from event detection to alert occurs in seconds or less). Alerts can be generated using tools like the SQL Server Agent Alerts and Database Mail.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001858; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review SQL Server settings, OS, or third-party logging software settings to determine whether a real-time alert will be sent to the appropriate personnel when auditing fails for any reason.

If real-time alerts are not sent upon auditing failure, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

**Observed at**

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure the system to provide immediate real-time alerts to appropriate support staff when an audit log failure occurs.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271346r1109256_rule

SQL Server must record time stamps in audit records and application data that can be mapped to Coordinated Universal Time (UTC), formerly Greenwich Mean Time (GMT).

Rule version

SQLI-22-011200

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: If time stamps are not consistently applied and there is no common time reference, it is difficult to perform forensic analysis.

Time stamps generated by SQL Server must include date and time. Time is commonly expressed in UTC, a modern continuation of GMT, or local time with an offset from UTC.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-001890; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

SQL Server Audits store the timestamp in UTC time.

Determine if the computer is joined to a domain.

```
SELECT DEFAULT_DOMAIN()[DomainName]
```

If this is not NULL, this is not a finding.

If the computer is not joined to a domain, determine what the time source is. (Run the following command in an elevated PowerShell session.)

```
w32tm /query /source
```

If the results of the command return "Local CMOS Clock" and this is not documented with justification and authorizing official (AO) authorization, this is a finding.

If the OS does not synchronize with a time server, review the procedure for maintaining accurate time on the system.



If such a procedure does not exist, this is a finding.

If the procedure exists, review evidence that the correct time is actually maintained.

If the evidence indicates otherwise, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Where possible, configure the operating system to automatic synchronize with an official time server, using NTP.

Where there is reason not to implement automatic synchronization with an official time server, using NTP, document the reason, and the procedure for maintaining the correct time, and obtain AO approval. Enforce the procedure.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271349r1108938_rule

Windows must enforce access restrictions associated with changes to the configuration of the SQL Server instance.

Rule version

SQLI-22-011500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Failure to provide logical access restrictions associated with changes to configuration may have significant effects on the overall security of the system.

When dealing with access restrictions pertaining to change control, it should be noted that any changes to the hardware, software, and/or firmware components of the information system can potentially have significant effects on the overall security of the system.

Accordingly, only qualified and authorized individuals should be allowed to obtain access to system components for the purposes of initiating changes, including upgrades and modifications.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001813; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Obtain a list of users who have privileged access to the server via the local administrators group.

1. Launch lusrmgr.msc.
2. Select "Groups".
3. Double-click "Administrators".

Alternatively, execute the following command in PowerShell:

```
net localgroup administrators
```

Check the server documentation to verify the users returned are authorized.

If the users are not documented and authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

**Evidence**

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove users from the local Administrators group who are not authorized.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271350r1111084_rule

SQL Server must enforce access restrictions associated with changes to the configuration of the instance.

Rule version

SQLI-22-011400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Failure to provide logical access restrictions associated with changes to configuration may have significant effects on the overall security of the system.

When dealing with access restrictions pertaining to change control, it should be noted that any changes to the hardware, software, and/or firmware components of the information system can potentially have significant effects on the overall security of the system.

Accordingly, only qualified and authorized individuals should be allowed to obtain access to system components for the purposes of initiating changes, including upgrades and modifications.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001813; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Obtain a list of logins who have privileged permissions and role memberships in SQL.

Execute the following to obtain a list of logins and roles and their respective permissions assignment:

```
SELECT p.name AS Principal,  
p.type_desc AS Type,  
sp.permission_name AS Permission,  
sp.state_desc AS State  
FROM sys.server_principals p  
INNER JOIN sys.server_permissions sp ON p.principal_id = sp.grantee_principal_id  
WHERE sp.permission_name = 'CONTROL SERVER'  
OR sp.state = 'W'
```

Execute the following to obtain a list of logins and their role memberships:

```
SELECT m.name AS Member,
```



```
m.type_desc AS Type,  
r.name AS Role  
FROM sys.server_principals m  
INNER JOIN sys.server_role_members rm ON m.principal_id = rm.member_principal_id  
INNER JOIN sys.server_principals r ON rm.role_principal_id = r.principal_id  
WHERE r.name IN ('sysadmin','securityadmin','serveradmin')
```

Check the server documentation to verify the logins and roles returned are authorized. If the logins and/or roles are not documented and authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Revoke unauthorized permissions from principals.

<https://learn.microsoft.com/en-us/sql/t-sql/statements/revoke-server-permissions-transact-sql?>

Remove unauthorized logins from roles.

ALTER SERVER ROLE DROP MEMBER login;

<https://learn.microsoft.com/en-us/sql/t-sql/statements/alter-server-role-transact-sql?>

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271351r1167494_rule

SQL Server must produce audit records when attempts to modify SQL Server configuration and privileges occur within the database(s).

Rule version

SQLI-22-011800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Without auditing the enforcement of access restrictions against changes to configuration, it would be difficult to identify attempted attacks, and an audit trail would not be available for forensic investigation for after-the-fact actions.

Enforcement actions are the methods or mechanisms used to prevent unauthorized changes to configuration settings. Enforcement action methods may be as simple as denying access to a file based on the application of file permissions (access restriction). Audit items may consist of lists of actions blocked by access restrictions or changes identified after the fact.

Changes in the permissions, privileges, and roles granted to users and roles, as well as privileged activity, must be tracked. Without an audit trail, unauthorized elevation or restriction of privileges could go undetected. Elevated privileges give users access to information and functionality that they should not have; restricted privileges wrongly deny access to authorized users.

A privileged function in this context is any operation that modifies the structure of the database, its built-in logic, or its security settings. This would include all Data Definition Language (DDL) statements and all security-related statements. In a SQL environment, it encompasses, but is not necessarily limited to, CREATE, ALTER, DROP, GRANT, REVOKE, and DENY.

There may also be Data Manipulation Language (DML) statements that, subject to context, should be regarded as privileged. Possible examples in SQL include TRUNCATE TABLE, SELECT, INSERT, UPDATE, or DELETE (to a security table executed by a user other than a security principal).

Depending on the capabilities of SQL Server and the design of the database and associated applications, audit logging may be achieved by means of DBMS auditing features, database triggers, other mechanisms, or a combination of these.

Note that it is particularly important to audit, and tightly control, any action that weakens the implementation of this requirement, since the objective is to have a complete audit trail of all administrative activity.

To aid in diagnosis, it is necessary to track failed attempts in addition to the successful ones.

Satisfies: SRG-APP-000381-DB-000361, SRG-APP-000495-DB-000326, SRG-APP-000495-DB-000327,



SRG-APP-000495-DB-000328, SRG-APP-000495-DB-000329, SRG-APP-000499-DB-000330,
SRG-APP-000499-DB-000331, SRG-APP-000504-DB-000354, SRG-APP-000504-DB-000355

Documentable: false

References

<http://cyber.mil/cci>: CCI-003938; <http://cyber.mil/cci>: CCI-000172; DPMS Target MS SQL Server 2022 Instance DISA
DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the SQL configuration to verify that audit records are produced when denied actions occur.

To determine if an audit is configured, execute the following script:

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status
```

If no records are returned, this is a finding.

Execute the following to verify the following events are included in the server audit specification:

```
APPLICATION_ROLE_CHANGE_PASSWORD_GROUP,  
AUDIT_CHANGE_GROUP,  
BACKUP_RESTORE_GROUP,  
DATABASE_CHANGE_GROUP,  
DATABASE_OBJECT_ACCESS_GROUP,  
DATABASE_OBJECT_CHANGE_GROUP,  
DATABASE_OBJECT_OWNERSHIP_CHANGE_GROUP,  
DATABASE_OBJECT_PERMISSION_CHANGE_GROUP,  
DATABASE_OWNERSHIP_CHANGE_GROUP,  
DATABASE_OPERATION_GROUP,  
DATABASE_PERMISSION_CHANGE_GROUP,  
DATABASE_PRINCIPAL_CHANGE_GROUP,  
DATABASE_PRINCIPAL_IMPERSONATION_GROUP,  
DATABASE_ROLE_MEMBER_CHANGE_GROUP,  
DBCC_GROUP,  
LOGIN_CHANGE_PASSWORD_GROUP,  
LOGOUT_GROUP,  
SCHEMA_OBJECT_OWNERSHIP_CHANGE_GROUP,  
SCHEMA_OBJECT_PERMISSION_CHANGE_GROUP,  
SERVER_OBJECT_CHANGE_GROUP,  
SERVER_OBJECT_OWNERSHIP_CHANGE_GROUP,  
SERVER_OBJECT_PERMISSION_CHANGE_GROUP,  
SERVER_OPERATION_GROUP,  
SERVER_PERMISSION_CHANGE_GROUP,  
SERVER_PRINCIPAL_CHANGE_GROUP,  
SERVER_PRINCIPAL_IMPERSONATION_GROUP,  
SERVER_ROLE_MEMBER_CHANGE_GROUP,  
SERVER_STATE_CHANGE_GROUP,
```



TRACE_CHANGE_GROUP,
USER_CHANGE_PASSWORD_GROUP

```
SELECT a.name AS 'AuditName',  
s.name AS 'SpecName',  
d.audit_action_name AS 'ActionName',  
d.audited_result AS 'Result'  
FROM sys.server_audit_specifications s  
JOIN sys.server_audits a ON s.audit_guid = a.audit_guid  
JOIN sys.server_audit_specification_details d ON s.server_specification_id = d.server_specification_id  
WHERE a.is_state_enabled = 1  
AND d.audit_action_name IN (  
'APPLICATION_ROLE_CHANGE_PASSWORD_GROUP',  
'AUDIT_CHANGE_GROUP',  
'BACKUP_RESTORE_GROUP',  
'DATABASE_CHANGE_GROUP',  
'DATABASE_OBJECT_ACCESS_GROUP',  
'DATABASE_OBJECT_CHANGE_GROUP',  
'DATABASE_OBJECT_OWNERSHIP_CHANGE_GROUP',  
'DATABASE_OBJECT_PERMISSION_CHANGE_GROUP',  
'DATABASE_OWNERSHIP_CHANGE_GROUP',  
'DATABASE_OPERATION_GROUP',  
'DATABASE_PERMISSION_CHANGE_GROUP',  
'DATABASE_PRINCIPAL_CHANGE_GROUP',  
'DATABASE_PRINCIPAL_IMPERSONATION_GROUP',  
'DATABASE_ROLE_MEMBER_CHANGE_GROUP',  
'DBCC_GROUP',  
'LOGIN_CHANGE_PASSWORD_GROUP',  
'LOGOUT_GROUP',  
'SCHEMA_OBJECT_OWNERSHIP_CHANGE_GROUP',  
'SCHEMA_OBJECT_PERMISSION_CHANGE_GROUP',  
'SERVER_OBJECT_CHANGE_GROUP',  
'SERVER_OBJECT_OWNERSHIP_CHANGE_GROUP',  
'SERVER_OBJECT_PERMISSION_CHANGE_GROUP',  
'SERVER_OPERATION_GROUP',  
'SERVER_PERMISSION_CHANGE_GROUP',  
'SERVER_PRINCIPAL_CHANGE_GROUP',  
'SERVER_PRINCIPAL_IMPERSONATION_GROUP',  
'SERVER_ROLE_MEMBER_CHANGE_GROUP',  
'SERVER_STATE_CHANGE_GROUP',  
'TRACE_CHANGE_GROUP',  
'USER_CHANGE_PASSWORD_GROUP'  
)  
Order by d.audit_action_name
```

If the identified groups are not returned, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

**Observed at**

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Add the required events to the server audit specification to audit denied actions.

Refer to the supplemental file "SQL2022Audit.sql" script.

Reference:

<https://learn.microsoft.com/en-us/sql/relational-databases/security/auditing/sql-server-audit-database-engine?>

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271358r1137659_rule

SQL Server services must be configured to run under unique dedicated user accounts.

Rule version

SQLI-22-012400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Database management systems can maintain separate execution domains for each executing process by assigning each process a separate address space. Each process has a distinct address space so that communication between processes is controlled through the security functions, and one process cannot modify the executing code of another process. Maintaining separate execution domains for executing processes can be achieved, for example, by implementing separate address spaces.

Documentable: false

References

<http://cyber.mil/ccr: CCI-002530; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

Review the server documentation to obtain a listing of required service accounts. Review the accounts configured for all SQL Server services installed on the server.

Run the following query in SSMS:

```
SELECT servicename,service_account FROM sys.dm_server_services
```

Review the returned results. If any services are configured with the same service account or with an account that is not documented and authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer



Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure SQL Server services to have a documented, dedicated account.

For nondomain servers, consider using virtual service accounts (VSAs).

For more information, refer to: <https://learn.microsoft.com/en-us/sql/database-engine/configure-windows/configure-windows-service-accounts-and-permissions?>

For standalone domain-joined servers, consider using managed service accounts.

For more information, refer to: <https://learn.microsoft.com/en-us/sql/database-engine/configure-windows/configure-windows-service-accounts-and-permissions?>

For clustered instances, consider using group managed service accounts.

For more information, refer to: <https://learn.microsoft.com/en-us/sql/database-engine/configure-windows/configure-windows-service-accounts-and-permissions?>

or

<https://learn.microsoft.com/en-us/archive/blogs/markweberblog/group-managed-service-accounts-gmsa-and-sql-server-2016>

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271359r1137659_rule

SQL Server must maintain a separate execution domain for each executing process.

Rule version

SQLI-22-012300

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Database management systems can maintain separate execution domains for each executing process by assigning each process a separate address space.

Each process has a distinct address space so that communication between processes is controlled through the security functions, and one process cannot modify the executing code of another process.

Maintaining separate execution domains for executing processes can be achieved, for example, by implementing separate address spaces.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002530; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the server documentation to determine whether use of CLR assemblies is required. Run the following query to determine whether CLR is enabled for the instance:

```
SELECT name, value, value_in_use  
FROM sys.configurations  
WHERE name = 'clr enabled'
```

If "value_in_use" is a "1" and CLR is not required, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

**Reviewer**

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any CLR code that is not authorized.

To disable the use of CLR, from the query prompt:

```
EXEC SP_CONFIGURE 'clr enabled', 0;  
RECONFIGURE WITH OVERRIDE;
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271362r1108702_rule

When invalid inputs are received, the SQL Server must behave in a predictable and documented manner that reflects organizational and system objectives.

Rule version

SQLI-22-012600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: A common vulnerability is unplanned behavior when invalid inputs are received. This requirement guards against adverse or unintended system behavior caused by invalid inputs, where information system responses to the invalid input may be disruptive or cause the system to fail into an unsafe state.

The behavior will be derived from the organizational and system requirements and includes, but is not limited to, notification of the appropriate personnel, creating an audit record, and rejecting invalid input.

This calls for inspection of application source code, which will require collaboration with the application developers. It is recognized that in many cases, the database administrator (DBA) is organizationally separate from the application developers, and may have limited, if any, access to source code. Nevertheless, protections of this type are so important to the secure operation of databases that they must not be ignored. At a minimum, the DBA must attempt to obtain assurances from the development organization that this issue has been addressed and must document what has been discovered.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002754; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review DBMS code (stored procedures, functions, triggers), application code, settings, column and field definitions, and constraints to determine whether the database is protected against invalid input.

If code exists that allows invalid data to be acted upon or input into the database, this is a finding.

If column/field definitions are not reflective of the data, this is a finding.

If columns/fields do not contain constraints and validity checking where required, this is a finding.



Where a column/field is noted in the system documentation as necessarily free form, even though its name and context suggest that it should be strongly typed and constrained, the absence of these protections is not a finding.

Where a column/field is clearly identified by name, caption or context as Notes, Comments, Description, Text, etc., the absence of these protections is not a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Use parameterized queries, stored procedures, constraints and foreign keys to validate data input.

Modify SQL Server to properly use the correct column data types as required in the database.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271364r1137667_rule

Security-relevant software updates to SQL Server must be installed within the time period directed by an authoritative source (e.g., IAVM, CTOs, DTMs, and STIGs).

Rule version

SQLI-22-012800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Security flaws with software applications, including database management systems, are discovered daily. Vendors are constantly updating and patching their products to address newly discovered security vulnerabilities. Organizations (including any contractor to the organization) are required to promptly install security-relevant software updates (e.g., patches, service packs, and hot fixes). Flaws discovered during security assessments, continuous monitoring, incident response activities, or information system error handling must also be addressed expeditiously.

Organization-defined time periods for updating security-relevant software may vary based on a variety of factors including, for example, the security category of the information system or the criticality of the update (i.e., severity of the vulnerability related to the discovered flaw).

This requirement will apply to software patch management solutions that are used to install patches across the enclave and also to applications themselves that are not part of that patch management solution. For example, many browsers today provide the capability to install their own patch software. Patch criticality, as well as system criticality, will vary. Therefore, the tactical situations regarding the patch management process will also vary. This means that the time period used must be a configurable parameter. Time frames for application of security-relevant software updates may be dependent upon the Information Assurance Vulnerability Management (IAVM) process.

SQL Server will be configured to check for and install security-relevant software updates within an identified time period from the availability of the update. The specific time period will be defined by an authoritative source (e.g., IAVM, CTOs, DTMs, and STIGs).

Documentable: false

References

<http://cyber.mil/ccr>: CCI-002605; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions



Obtain evidence that software patches are consistently applied to SQL Server within the time frame defined for each patch. To be considered supported, Microsoft must report that the version is supported by security patches to known vulnerability. Review the Support dates at <https://learn.microsoft.com/en-us/troubleshoot/sql/releases/download-and-install-latest-updates>.

Check the SQL Server version by running the following script:

Print @@version

If the SQL Server version is not shown as supported, this is a finding.

If such evidence cannot be obtained, or the evidence that is obtained indicates a pattern of noncompliance, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Upgrade SQL Server to the Microsoft-supported version. Institute and adhere to policies and procedures to ensure that patches are consistently applied to SQL Server within the time allowed.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271365r1138543_rule

Microsoft SQL Server products must be a version supported by the vendor.

Rule version

SQLI-22-018300

Severity

high

Reported status

NOT_ASSESSED

Requirement

Discussion: Unsupported commercial and database systems should not be used because fixes to newly identified bugs will not be implemented by the vendor. The lack of support can result in potential vulnerabilities.

Systems at unsupported servicing levels or releases will not receive security updates for new vulnerabilities, which leaves them subject to exploitation.

When maintenance updates and patches are no longer available, the database software is no longer considered supported and should be upgraded or decommissioned.

Documentable: false

References

<http://cyber.mil/cci>: CCI-003376; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the system documentation and interview the database administrator.

Identify all database software components.

Review the version and release information.

Verify the SQL Server version via one of the following methods:

Connect to the server by using Object Explorer in SQL Server Management Studio. After Object Explorer is connected, it will show the version information in parentheses with the username used to connect to the specific instance of SQL Server.

Or, from SQL Server Management Studio execute the following:

```
SELECT @@VERSION;
```

More information for finding the version is available at the following link:

<https://learn.microsoft.com/en-us/troubleshoot/sql/releases/find-my-sql-version>.



Access the vendor website or use other means to verify the version is still supported. Refer to <https://learn.microsoft.com/en-us/lifecycle/products/sql-server-2016>.

If the installed version or any of the software components are not supported by the vendor, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Remove or decommission all unsupported software products.

Upgrade unsupported DBMS or unsupported components to a supported version of the product.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271370r1111091_rule

SQL Server must generate audit records when successful and unsuccessful attempts to modify or delete security objects occur.

Rule version

SQLI-22-013800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Changes and deletions of the database objects (tables, views, procedures, functions) that record and control permissions, privileges, and roles granted to users and roles must be tracked. Without an audit trail, unauthorized changes to the security subsystem could go undetected. The database could be severely compromised or rendered inoperative.

To aid in diagnosis, it is necessary to track failed attempts in addition to the successful ones.

Satisfies: SRG-APP-000496-DB-000334, SRG-APP-000496-DB-000335, SRG-APP-000501-DB-000336, SRG-APP-000501-DB-000337

Documentable: false

References

<http://cyber.mil/ccr:CCI-000172>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the SQL configuration to verify that audit records are produced when denied actions occur.

To determine if an audit is configured, execute the following script:

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status
```

If no records are returned, this is a finding.

Execute the following to verify the events below are included in the server audit specification:

SCHEMA_OBJECT_CHANGE_GROUP

```
SELECT a.name AS 'AuditName',
```



```
s.name AS 'SpecName',  
d.audit_action_name AS 'ActionName',  
d.audited_result AS 'Result'  
FROM sys.server_audit_specifications s  
JOIN sys.server_audits a ON s.audit_guid = a.audit_guid  
JOIN sys.server_audit_specification_details d ON s.server_specification_id = d.server_specification_id  
WHERE a.is_state_enabled = 1  
AND d.audit_action_name IN (  
'SCHEMA_OBJECT_CHANGE_GROUP'  
)  
Order by d.audit_action_name
```

If the identified groups are not returned, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Add the required events to the server audit specification to audit denied actions.

Refer to the supplemental file "SQL2022Audit.sql" script.

Reference:

<https://learn.microsoft.com/en-us/sql/relational-databases/security/auditing/sql-server-audit-database-engine?>

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release



Release: 4 Benchmark Date: 01 Apr 2026



SV-271375r1111093_rule

SQL Server must generate audit records when successful and unsuccessful logons or connection attempts occur.

Rule version

SQLI-22-014800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: For completeness of forensic analysis, it is necessary to track who/what (a user or other principal) logs on to SQL Server. It is also necessary to track failed attempts to log on to SQL Server. While positive identification may not be possible in a case of failed authentication, as much information as possible about the incident must be captured.

Satisfies: SRG-APP-000503-DB-000350, SRG-APP-000503-DB-000351, SRG-APP-000506-DB-000353

Documentable: false

References

<http://cyber.mil/ccr: CCI-000172; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

Review the SQL configuration to verify that audit records are produced when denied actions occur.

To determine if an audit is configured, execute the following script:

```
SELECT name AS 'Audit Name',  
status_desc AS 'Audit Status',  
audit_file_path AS 'Current Audit File'  
FROM sys.dm_server_audit_status
```

If no records are returned, this is a finding.

Execute the following to verify the events below are included in the server audit specification:

```
SUCCESSFUL_LOGIN_GROUP  
FAILED_LOGIN_GROUP
```

```
SELECT a.name AS 'AuditName',  
s.name AS 'SpecName',  
d.audit_action_name AS 'ActionName',
```



```
d.audited_result AS 'Result'
FROM sys.server_audit_specifications s
JOIN sys.server_audits a ON s.audit_guid = a.audit_guid
JOIN sys.server_audit_specification_details d ON s.server_specification_id = d.server_specification_id
WHERE a.is_state_enabled = 1
AND d.audit_action_name IN (
'SUCCESSFUL_LOGIN_GROUP',
'FAILED_LOGIN_GROUP'
)
Order by d.audit_action_name
```

If the identified groups are not returned, this is a finding.

Alternatively:

1. In SQL Management Studio, right-click on the instance.
2. Select "Properties".
3. Select "Security" on the left side.
4. Check the setting for "Login auditing".

If "Both failed and successful logins" is not selected, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Add the required events to the server audit specification to audit denied actions.

Refer to the supplemental file "SQL2022Audit.sql" script.

Reference:



<https://learn.microsoft.com/en-us/sql/relational-databases/security/auditing/sql-server-audit-database-engine?>

Alternatively, enable "Both failed and successful logins".

1. In SQL Management Studio, right-click on the instance.
2. Select "Properties".
3. Select "Security" on the left side.
4. Select "Both failed and successful logins".
5. Click "OK".

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271381r1111095_rule

SQL Server must generate audit records for all direct access to the database(s).

Rule version

SQLI-22-015500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: In this context, direct access is any query, command, or call to SQL Server that comes from any source other than the application(s) that it supports. Examples would be the command line or a database management utility program. The intent is to capture all activity from administrative and nonstandard sources.

Documentable: false

References

<http://cyber.mil/ccci>: CCI-000172; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Determine whether any Server Audits are configured to filter records. From SQL Server Management Studio, execute the following query:

```
SELECT name AS AuditName, predicate AS AuditFilter
FROM sys.server_audits
WHERE predicate IS NOT NULL
```

If any audits are returned, review the associated filters. If any direct access to the database(s) is being excluded, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

***Rationale***

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Check the system documentation for required SQL Server Audits. Remove any Audit filters that exclude or reduce required auditing. Update filters to ensure direct access is not excluded.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271385r1108771_rule

The system SQL Server must off-load audit data to a separate log management facility; this must be continuous and in near real time for systems with a network connection to the storage facility and weekly or more often for stand-alone systems.

Rule version

SQLI-22-015900

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information stored in one location is vulnerable to accidental or incidental deletion or alteration.

Off-loading is a common process in information systems with limited audit storage capacity.

The system SQL Server may write audit records to database tables, to files in the file system, to other kinds of local repository, or directly to a centralized log management system. Whatever the method used, it must be compatible with off-loading the records to the centralized system.

Documentable: false

References

<http://cyber.mil/cci>: CCI-001851; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the system documentation for a description of how audit records are off-loaded.

If the system has a continuous network connection to the centralized log management system, but the DBMS audit records are not written directly to the centralized log management system or transferred in near-real-time, this is a finding.

If the system does not have a continuous network connection to the centralized log management system, and the DBMS audit records are not transferred to the centralized log management system weekly or more often, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

**Observed at**

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure the system or deploy and configure software tools to transfer audit records to a centralized log management system, continuously and in near-real time where a continuous network connection to the log management system exists, or at least weekly in the absence of such a connection.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271387r1111140_rule

The SQL Server Browser service must be disabled unless specifically required and approved.

Rule version

SQLI-22-017800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: The SQL Server Browser simplifies the administration of SQL Server, particularly when multiple instances of SQL Server coexist on the same computer. It avoids the need to hard-assign port numbers to the instances and to set and maintain those port numbers in client systems. It enables administrators and authorized users to discover database management system instances, and the databases they support, over the network. SQL Server uses the SQL Server Browser service to enumerate instances of the Database Engine installed on the computer. This enables client applications to browse for a server, and helps clients distinguish between multiple instances of the Database Engine on the same computer.

This convenience also presents the possibility of unauthorized individuals gaining knowledge of the available SQL Server resources. Therefore, it is necessary to consider whether the SQL Server Browser is needed. Typically, if only a single instance is installed, using the default name (MSSQLSERVER) and port assignment (1433), the Browser is not adding any value. The more complex the installation, the more likely SQL Server Browser is to be helpful.

This requirement is not intended to prohibit use of the Browser service in any circumstances. It calls for administrators and management to consider whether the benefits of its use outweigh the potential negative consequences of it being used by an attacker to browse the current infrastructure and retrieve a list of running SQL Server instances.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000366; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Open SQL Server Configuration Manager. Select SQL Server Services. Review the Start Mode and State of SQL Server Browser.

If its Start Type is shown as "Disabled", this is not a finding.

If the need for the SQL Server Browser service is documented and authorized, verify the SQL Instances that do not



require use of the SQL Browser Service are hidden with the following SQL script:

```
DECLARE @HiddenInstance INT
EXEC master.dbo.Xp_instance_regread
N'HKEY_LOCAL_MACHINE',
N'Software\Microsoft\MSSQLServer\MSSQLServer\SuperSocketNetLib',
N'HideInstance',
@HiddenInstance output

SELECT CASE
WHEN @HiddenInstance = 0
AND Serverproperty('IsClustered') = 0 THEN 'No'
ELSE 'Yes'
END AS [Hidden]
```

If the value of "Hidden" is "Yes", this is not a finding.

If the value of "Hidden" is "No" and the startup type of the "SQL Server Browser" service is not "Disabled", this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

If SQL Server Browser is needed, document the justification and obtain the appropriate authorization.

Where SQL Server Browser is judged unnecessary, the Service can be disabled.

To disable, in the Services tool, double-click "SQL Server Browser". Set "Startup Type" to "Disabled". If "Service Status" is "Running", click "Stop" and then click "OK".

Source benchmark

MS_SQL_Server_2022_Instance_STIG



Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271388r1111098_rule

SQL Server must configure SQL Server Usage and Error Reporting Auditing.

Rule version

SQLI-22-016100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: By default, Microsoft SQL Server enables participation in the customer experience improvement program (CEIP). This program collects information about how its customers are using the product. Specifically, SQL Server collects information about the installation experience, feature usage, and performance. This information helps Microsoft improve the product to better meet customer needs. The Local Audit component of SQL Server Usage Feedback collection writes data collected by the service to a designated folder, representing the data (logs) that will be sent to Microsoft. The purpose of the Local Audit is to allow customers to view all data Microsoft collects with this feature, for compliance, regulatory or privacy validation reasons.

Documentable: false

References

<http://cyber.mil/ccr: CCI-000366; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677>

Check instructions

Review the server documentation to determine if auditing of the telemetry data is required. If auditing of telemetry data is not required, this is not a finding.

If auditing of telemetry data is required, determine the telemetry service username by executing the following query:

```
SELECT name  
FROM sys.server_principals  
WHERE name LIKE '%SQLTELEMETRY%'
```

Review the values of the following registry key:

Note: InstanceId refers to the type and instance of the feature (e.g., MSSQL16.SqlInstance, MSAS16.SSASInstance, MSRS16.SSRSInstance).

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Microsoft SQL
Server\[InstanceId]\CPE\UserRequestedLocalAuditDirectory

If the registry key does not exist or the value is blank, this is a finding.

Navigate the path defined in the "UserRequestedLocalAuditDirectory" registry key in file explorer.



Right-click on the folder and choose "Properties". Open the "Security" tab.

Verify the SQLTELEMETRY account has the following permissions:

- List folder contents
- Read
- Write

If the permissions are not set properly on the folder, this is a finding.

Open services.msc and find the telemetry service.

- For Database Engine, use SQL Server CEIP service (<INSTANCENAME>).
- For Analysis Services, use SQL Server Analysis Services CEIP (<INSTANCENAME>).

Right-click on the service and choose "Properties". Verify the "Startup type" is "Automatic."

If the service is not configured to automatically start, this is a finding.

Review the processes and procedures for reviewing the telemetry data. If there is evidence that the telemetry data is periodically reviewed in accordance with the processes and procedures, this is not a finding.

If no processes and procedures exist for reviewing telemetry data, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure the instance to audit telemetry data. More information about auditing telemetry data can be found at <https://msdn.microsoft.com/en-us/library/mt743085.aspx>.

Create a folder to store the telemetry audit data in.



Grant the SQLTELEMETRY service the following permissions on the folder:

- List folder contents
- Read
- Write

Create and configure the following registry key:

Note: InstanceId refers to the type and instance of the feature. (e.g., MSSQL16.SqlInstance, MSAS16.SSASInstance, MSRS16.SSRSInstance)

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Microsoft SQL
Server\[InstanceId]\CPE\UserRequestedLocalAuditDirectory [string]

Set the "UserRequestedLocalAuditDirectory" key value to the path of the telemetry audit folder.

Set the telemetry service to start automatically. Restart the service.

- For Database Engine, use SQL Server CEIP service (<INSTANCENAME>).
- For Analysis Services, use SQL Server Analysis Services CEIP (<INSTANCENAME>).

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271389r1109133_rule

SQL Server must configure Customer Feedback and Error Reporting.

Rule version

SQLI-22-016000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: By default, Microsoft SQL Server enables participation in the customer experience improvement program (CEIP). This program collects information about how its customers are using the product. Specifically, SQL Server collects information about the installation experience, feature usage, and performance. This information helps Microsoft improve the product to better meet customer needs.

Documentable: false

References

<http://cyber.mil/cci>: CCI-000366; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the values for CustomerFeedback and EnableErrorReporting.

Option 1:

Launch "Registry Editor"

Navigate to:

HKEY_LOCAL_MACHINE\Software\Microsoft\Microsoft SQL Server\[InstanceId]\CPE

Review the following values: CustomerFeedback, EnableErrorReporting

Navigate to HKEY_LOCAL_MACHINE\Software\Microsoft\Microsoft SQL Server\160

Review the following values: CustomerFeedback, EnableErrorReporting

Option 2:

Run the PowerShell commands:

```
Get-ItemProperty -Path "HKLM:\Software\Microsoft\Microsoft SQL Server<SqlInstanceId>\CPE"
```

```
Get-ItemProperty -Path "HKLM:\Software\Microsoft\Microsoft SQL Server\160"
```

Review the following values: CustomerFeedback, EnableErrorReporting

If this is a classified system, and any of the above values are not "0", this is a finding.



If this is an unclassified system, review the server documentation to determine whether CEIP participation is authorized.

If CEIP participation is not authorized, and any of the above values are "1", this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

To disable participation in the CEIP program, change the value of the following registry keys to "0".

To enable participation in the CEIP program, change the value of the following registry keys to "1".

HKEY_LOCAL_MACHINE\Software\Microsoft\Microsoft SQL Server\[InstanceId]\CPE\CustomerFeedback
HKEY_LOCAL_MACHINE\Software\Microsoft\Microsoft SQL Server\[InstanceId]\CPE\EnableErrorReporting
HKEY_LOCAL_MACHINE\Software\Microsoft\Microsoft SQL Server\160\CustomerFeedback
HKEY_LOCAL_MACHINE\Software\Microsoft\Microsoft SQL Server\160\EnableErrorReporting

Or in PowerShell, run:

```
Set-ItemProperty -Path "HKLM:\Software\Microsoft\Microsoft SQL Server\[InstanceId]\CPE" -Name  
CustomerFeedback -Value 0  
Set-ItemProperty -Path "HKLM:\Software\Microsoft\Microsoft SQL Server\[InstanceId]\CPE" -Name  
EnableErrorReporting -Value 0  
Set-ItemProperty -Path "HKLM:\Software\Microsoft\Microsoft SQL Server\160" -Name CustomerFeedback -Value 0  
Set-ItemProperty -Path "HKLM:\Software\Microsoft\Microsoft SQL Server\160" -Name EnableErrorReporting -Value  
0
```

Source benchmark



MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-271400r1167497_rule

SQL Server must, for password-based authentication, require immediate selection of a new password upon account recovery.

Rule version

SQLI-22-019500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Password-based authentication applies to passwords regardless of whether they are used in single-factor or multifactor authentication. Long passwords or passphrases are preferable over shorter passwords. Enforced composition rules provide marginal security benefits while decreasing usability. However, organizations may choose to establish certain rules for password generation (e.g., minimum character length for long passwords) under certain circumstances and can enforce this requirement in IA-5(1)(h). Account recovery can occur, for example, in situations when a password is forgotten. Cryptographically protected passwords include salted one-way cryptographic hashes of passwords. The list of commonly used, compromised, or expected passwords includes passwords obtained from previous breach corpuses, dictionary words, and repetitive or sequential characters. The list includes context-specific words, such as the name of the service, username, and derivatives thereof.

Documentable: false

References

<http://cyber.mil/ccr:CCI-004063>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Check for use of SQL Server Authentication:

```
SELECT CASE SERVERPROPERTY('IsIntegratedSecurityOnly') WHEN 1 THEN 'Windows Authentication' WHEN 0 THEN 'SQL Server Authentication' END as [Authentication Mode]
```

If the returned value in the "Authentication Mode" column is "Windows Authentication", this is not a finding.

If the returned value is not "Windows Authentication", verify SQL Server is configured to require immediate selection of a new password upon account recovery.

All scripts, functions, triggers, and stored procedures used to create a user or reset a user's password for SQL logins should include a line similar to the following password_option:

MUST_CHANGE



Example:

```
CREATE LOGIN STIG_test WITH PASSWORD = 'Password' MUST_CHANGE,  
CHECK_EXPIRATION = ON,  
CHECK_POLICY = ON;
```

If they do not, this is a finding.

If SQL Server is not configured to require immediate selection of a new password upon account recovery for accounts using SQL login, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Configure the DBMS to require immediate selection of a new password for accounts using SQL login upon account recovery.

Ensure all scripts, functions, triggers, and stored procedures used to create a user or reset a user's password for SQL logins include a line similar to the following password_option:

MUST_CHANGE

If MUST_CHANGE is specified, CHECK_EXPIRATION and CHECK_POLICY must be set to ON. Otherwise, the statement will fail.

More information can be found at

<https://learn.microsoft.com/en-us/sql/t-sql/statements/alter-login-transact-sql?view=sql-server-ver16>.

Source benchmark

MS_SQL_Server_2022_Instance_STIG



Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274444r1137654_rule

The SQL Server default account [sa] must be disabled.

Rule version

SQLI-22-016200

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: SQL Server's [sa] account has special privileges required to administer the database. The [sa] account is a well-known SQL Server account and is likely to be targeted by attackers and thus more prone to providing unauthorized access to the database.

This [sa] default account is administrative and could lead to catastrophic consequences, including the complete loss of control over SQL Server. If the [sa] default account is not disabled, an attacker might be able to gain access through the account. SQL Server by default disables the [sa] account at installation.

Some applications that run on SQL Server require the [sa] account to be enabled for the application to function properly. These applications that require the [sa] account to be enabled are usually legacy systems.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000213; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Check SQL Server settings to determine if the [sa] (system administrator) account has been disabled by executing the following query:

```
USE master;  
GO  
SELECT name, is_disabled  
FROM sys.sql_logins  
WHERE principal_id = 1;  
GO
```

Verify that the "name" column contains the current name of the [sa] database server account.

If the "is_disabled" column is not set to "1", this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence



Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Modify the enabled flag of SQL Server's [sa] (system administrator) account by running the following script:

```
USE master;
```

```
GO
```

```
ALTER LOGIN [sa] DISABLE;
```

```
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274445r1111103_rule

The SQL Server default account [sa] must have its name changed.

Rule version

SQLI-22-016300

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: SQL Server's [sa] account has special privileges required to administer the database. The [sa] account is a well-known SQL Server account name and is likely to be targeted by attackers, and is thus more prone to providing unauthorized access to the database.

Since the SQL Server [sa] is administrative in nature, the compromise of a default account can have catastrophic consequences, including the complete loss of control over SQL Server. Since SQL Server needs for this account to exist and it should not be removed, one way to mitigate this risk is to change the [sa] account name.

Documentable: false

References

<http://cyber.mil/ccr:CCI-000381>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Verify the SQL Server default [sa] (system administrator) account name has been changed by executing the following query:

```
USE master;  
GO  
SELECT *  
FROM sys.sql_logins  
WHERE [name] = 'sa' OR [principal_id] = 1;  
GO
```

If the login account name "SA" or "sa" appears in the query output, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

**Reviewer**

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Modify the SQL Server's [sa] (system administrator) account by running the following script:

```
USE master;  
GO  
ALTER LOGIN [sa] WITH NAME = <new name>  
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274446r1111106_rule

Execution of startup stored procedures must be restricted to necessary cases only.

Rule version

SQLI-22-016400

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: In certain situations, to provide required functionality, a DBMS needs to execute internal logic (stored procedures, functions, triggers, etc.) and/or external code modules with elevated privileges. However, if the privileges required for execution are at a higher level than the privileges assigned to organizational users invoking the functionality applications/programs, those users are indirectly provided with greater privileges than assigned by organizations.

When "Scan for startup procs" is enabled, SQL Server scans for and runs all automatically run stored procedures defined on the server. The execution of start-up stored procedures will be done under a high privileged context; therefore, it is a commonly used post-exploitation vector.

Documentable: false

References

<http://cyber.mil/cci>: CCI-002233; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the system documentation to obtain a listing of documented stored procedures used by SQL Server during startup. Execute the following query:

```
Select [name] as StoredProc
From sys.procedures
Where OBJECTPROPERTY(OBJECT_ID, 'ExecIsStartup') = 1
```

If any stored procedures are returned that are not documented, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at



Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

To disable startup stored procedure(s), run the following in Master for each undocumented procedure:
sp_procoption @procname = '<procedure name>', @OptionName = 'Startup', @optionValue = 'Off'

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274447r1111109_rule

The SQL Server Mirroring endpoint must use AES encryption.

Rule version

SQLI-22-016500

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information can be unintentionally or maliciously disclosed or modified during preparation for transmission, including, for example, during aggregation, at protocol transformation points, and during packing/unpacking. These unauthorized disclosures or modifications compromise the confidentiality or integrity of the information.

Use of this requirement will be limited to situations where the data owner has a strict requirement for ensuring data integrity and confidentiality is maintained at every step of the data transfer and handling process.

SQL Mirroring endpoints support different encryption algorithms, including no-encryption. Using a weak encryption algorithm or plaintext in communication protocols can lead to data loss, data manipulation, and/or connection hijacking.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000366; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If the data owner does not have a strict requirement for ensuring data integrity and confidentiality is maintained at every step of the data transfer and handling process, and the requirement is documented and authorized, this is not a finding.

If Database Mirroring is in use, run the following to check for encrypted transmissions:

```
SELECT name, type_desc, encryption_algorithm_desc  
FROM sys.database_mirroring_endpoints  
WHERE encryption_algorithm != 2
```

If any records are returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

**Observed at**

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Run the following to enable encryption on the mirroring endpoint:

```
ALTER ENDPOINT <Endpoint Name>
```

```
FOR DATABASE_MIRRORING
```

```
(ENCRYPTION = REQUIRED ALGORITHM AES)
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274448r1111112_rule

The SQL Server Service Broker endpoint must use AES encryption.

Rule version

SQLI-22-016600

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information can be unintentionally or maliciously disclosed or modified during preparation for transmission, including, for example, during aggregation, at protocol transformation points, and during packing/unpacking. These unauthorized disclosures or modifications compromise the confidentiality or integrity of the information.

Use of this requirement will be limited to situations where the data owner has a strict requirement for ensuring that data integrity and confidentiality is maintained at every step of the data transfer and handling process.

SQL Server Service Broker endpoints support different encryption algorithms, including no-encryption. Using a weak encryption algorithm or plaintext in communication protocols can lead to data loss, data manipulation, and/or connection hijacking.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000366; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

If the data owner does not have a strict requirement for ensuring data integrity and confidentiality is maintained at every step of the data transfer and handling process, and the requirement is documented and authorized, this is not a finding.

If SQL Service Broker is in use, run the following to check for encrypted transmissions:

```
SELECT name, type_desc, encryption_algorithm_desc  
FROM sys.service_broker_endpoints  
WHERE encryption_algorithm != 2
```

If any records are returned, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

**Observed at**

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Run the following to enable encryption on the Service Broker endpoint:

```
ALTER ENDPOINT <EndpointName>
```

```
FOR SERVICE_BROKER
```

```
(ENCRYPTION = REQUIRED ALGORITHM AES)
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274449r1111115_rule

SQL Server execute permissions to access the registry must be revoked unless specifically required and approved.

Rule version

SQLI-22-016700

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different operating system security context than SQL Server and provide unauthorized access to the host system.

The registry contains sensitive information, including password hashes and clear text passwords. Registry extended stored procedures allow Microsoft SQL Server to access the machine's registry. The sensitivity of these procedures is exacerbated if Microsoft SQL Server is run under the Windows account LocalSystem. LocalSystem can read and write nearly all values in the registry, even those not accessible by the administrator. Unlike the xp_cmdshell extended stored procedure, which runs under a separate context if executed by a login not in the sysadmin role, the registry extended stored procedures always execute under the security context of the MSSQLServer service. Because the sensitive information is stored in the registry, it is essential that access to that information be properly guarded.

Documentable: false

References

<http://cyber.mil/ccr:CCI-000381>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions



To determine if permissions to execute registry extended stored procedures have been revoked from all users (other than dbo), execute the following command:

```
SELECT OBJECT_NAME(major_id) AS [Stored Procedure]
,dpr.NAME AS [Principal]
FROM sys.database_permissions AS dp
INNER JOIN sys.database_principals AS dpr ON dp.grantee_principal_id = dpr.principal_id
WHERE major_id IN (
OBJECT_ID('xp_regaddmultistring')
,OBJECT_ID('xp_regdeletekey')
,OBJECT_ID('xp_regdeletevalue')
,OBJECT_ID('xp_regenumvalues')
,OBJECT_ID('xp_regenumkeys')
,OBJECT_ID('xp_regremovemultistring')
,OBJECT_ID('xp_regwrite')
,OBJECT_ID('xp_instance_regaddmultistring')
,OBJECT_ID('xp_instance_regdeletekey')
,OBJECT_ID('xp_instance_regdeletevalue')
,OBJECT_ID('xp_instance_regenumkeys')
,OBJECT_ID('xp_instance_regenumvalues')
,OBJECT_ID('xp_instance_regremovemultistring')
,OBJECT_ID('xp_instance_regwrite')
)
AND dp.[type] = 'EX'
ORDER BY dpr.NAME;
```

If any records are returned, review the system documentation to determine if accessing the registry via extended stored procedures is required and authorized. If it is not authorized, this is a finding. Check reference:

MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance



Remove execute permissions to any registry extended stored procedure from all users (other than dbo):

```
USE master
```

```
GO
```

```
REVOKE EXECUTE ON [<procedureName>] FROM [<principal>]
```

```
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274450r1111117_rule

Filestream must be disabled unless specifically required and approved.

Rule version

SQLI-22-016800

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

The most significant potential for attacking an instance is through the use of features that expose an external interface or ad hoc execution capability. FILESTREAM integrates the SQL Server Database Engine with an NTFS file system by storing varbinary(max) binary large object (BLOB) data as files on the file system. Transact-SQL statements can insert, update, query, search, and back up FILESTREAM data.

Documentable: false

References

<http://cyber.mil/ccr>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

Review the system documentation to determine if FileStream is in use. If in use and authorized, this is not a finding.

If FileStream is not documented as being authorized, execute the following query:

```
EXEC sp_configure 'filestream access level'
```

If "run_value" is greater than "0", this is a finding.

This rule checks that the Filestream SQL-specific option is disabled.

```
SELECT CASE  
WHEN EXISTS (SELECT *  
FROM sys.configurations  
WHERE Name = 'filestream access level')
```



```
AND Cast(value AS INT) = 0) THEN 'No'  
ELSE 'Yes'  
END AS TSQLFileStreamAccess;
```

If the above query returns "Yes" in the "FileStreamEnabled" field, this is a finding. Check reference:
MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable the use of Filestream.

1. Delete all FILESTREAM columns from all tables. ALTER TABLE <name> DROP COLUMN <column name>
2. Disassociate tables from the FILESTREAM filegroups. ALTER TABLE <name> SET (FILESTREAM_ON = 'NULL'
3. Remove all FILESTREAM data containers. ALTER DATABASE <name> REMOVE FILE <file name>
4. Remove all FILESTREAM filegroups. ALTER DATABASE <name> REMOVE FILEGROUP <file name>
5. Disable FILESTREAM.
EXEC sp_configure filestream_access_level, 0
RECONFIGURE
6. Restart the SQL Service.

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026



SV-274451r1111120_rule

The Ole Automation Procedures feature must be disabled unless specifically required and approved.

Rule version

SQLI-22-017000

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: Information systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

It is detrimental for applications to provide, or install by default, functionality exceeding requirements or mission objectives.

Applications must adhere to the principles of least functionality by providing only essential capabilities.

SQL Server may spawn additional external processes to execute procedures that are defined in the SQL Server but stored in external host files (external procedures). The spawned process used to execute the external procedure may operate within a different operating system security context than SQL Server and provide unauthorized access to the host system.

SQL Server is capable of providing a wide range of features and services. Some of the features and services, provided by default, may not be necessary, and enabling them could adversely affect system security.

The "Ole Automation Procedures" option controls whether OLE Automation objects can be instantiated within Transact-SQL batches. These are extended stored procedures that allow SQL Server users to execute functions external to SQL Server in the security context of SQL Server.

The "Ole Automation Procedures" extended stored procedure allows execution of host executables outside the controls of database access permissions. This access may be exploited by malicious users who have compromised the integrity of the SQL Server database process to control the host operating system to perpetrate additional malicious activity.

Documentable: false

References

<http://cyber.mil/cc:CCI-000381>; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677



Check instructions

To determine if the "Ole Automation Procedures" option is enabled, execute the following query:

```
EXEC SP_CONFIGURE 'show advanced options', '1';  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'Ole Automation Procedures';
```

If the value of "config_value" is "0", this is not a finding.

If the value of "config_value" is "1", review the system documentation to determine whether the use of "Ole Automation Procedures" is required and authorized. If it is not authorized, this is a finding. Check reference: MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown

Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not authorized. To disable the use of "Ole Automation Procedures" option, from the query prompt:

```
sp_configure 'show advanced options', 1;  
GO  
RECONFIGURE;  
GO  
sp_configure 'Ole Automation Procedures', 0;  
GO  
RECONFIGURE;  
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release



Release: 4 Benchmark Date: 01 Apr 2026



SV-274452r1111123_rule

The SQL Server User Options feature must be disabled unless specifically required and approved.

Rule version

SQLI-22-017100

Severity

medium

Reported status

NOT_ASSESSED

Requirement

Discussion: SQL Server is capable of providing a wide range of features and services. Some of the features and services, provided by default, may not be necessary, and enabling them could adversely affect system security.

The "user options" option specifies global defaults for all users. A list of default query processing options is established for the duration of a user's work session. The "user options" option enables changing the default values of the SET options (if the server's default settings are not appropriate).

Documentable: false

References

<http://cyber.mil/cci>: CCI-000381; DPMS Target MS SQL Server 2022 Instance DISA DPMS Target MS SQL Server 2022 Instance 5677

Check instructions

To determine if "User Options" option is enabled, execute the following query:

```
EXEC SP_CONFIGURE 'show advanced options', '1';  
RECONFIGURE WITH OVERRIDE;  
EXEC SP_CONFIGURE 'user options';
```

If the value of "config_value" is "0", this is not a finding.

If the value of "config_value" is "1", review the system documentation to determine whether the use of "user options" is required and authorized. If it is not authorized, this is a finding. Check reference:

MS_SQL_Server_2022_Instance_STIG.xml M

Evidence

Missing

Observed at

Unknown



Reviewer

Unassigned

Rationale

Determine applicability; collect current evidence

Responsibility

UNDETERMINED; validate Azure service and provider assurance per rule

Recommendation

Review applicability and source fix; collect evidence before assigning a result

Benchmark remediation guidance

Disable use of or remove any external application executable object definitions that are not authorized. To disable the use of the "User Options" option, from the query prompt:

```
sp_configure 'show advanced options', 1;  
GO  
RECONFIGURE;  
GO  
sp_configure 'user options', 0;  
GO  
RECONFIGURE;  
GO
```

Source benchmark

MS_SQL_Server_2022_Instance_STIG

Source release

Release: 4 Benchmark Date: 01 Apr 2026